BÁO CÁO CHÍNH — HW02 Domain Testing on EShop

Sinh viên: MSSV 23120231 (Thành viên 4) — **Môn:** Kiểm thử phần mềm, FIT@HCMUS — **Ngày:** 2026-10-16 **SUT:** EShop (`https://github.com/ttbhanh/eshop-sut`) — **Repo làm việc:** https://github.com/nhaajtdajt/eshop-hw02-domain-testing

Báo cáo này gồm **báo cáo Domain Testing** (mục 4) và **báo cáo Boundary Value Analysis** (mục 5) cho bốn feature được giao, kèm kết quả thực thi (mục 6) và phân tích AI gap (mục 7). Bug report có screenshot ở file riêng `02_BugReport/`; AI Audit Report (mục 10), AI Critique (mục 11) và Mandatory Disclosure (mục 12) nằm cuối báo cáo, các biểu mẫu AI đã điền ở `05_Templates_AI/`.

1. Phạm vi và môi trường

Pool	Feature	Lý do chọn / phạm vi
A	FR-03 Quên & đặt lại mật khẩu	Form 2 bước, OTP, mật khẩu mới; UI web và API
B	FR-10 Máy trạng thái đơn hàng	Ma trận trạng thái 5×5; API Admin, hủy đơn của User, UI Admin và Web
C	FR-16 Import sản phẩm từ CSV	Parse CSV ở client, API import, tính nguyên tử
D	Mobile FR-08/09 Thanh toán & mã giảm giá	Màn thanh toán Mobile, 5 điều kiện mã giảm giá, công thức tính tiền

Môi trường: Windows 11, Node v22.20.0; Backend `localhost:3000`, Web `5173`, Admin `5174`; Mobile chạy bằng Expo Web (`react-native-web`). **Không có thiết bị thật/emulator.** Dữ liệu seed gốc của repo; mỗi nhóm test có bước reset/dọn dữ liệu.

2. Phương pháp (áp dụng cho mọi feature)

Mỗi feature đi qua 6 bước và mỗi bước là **một commit riêng** (xem `04_Git_log/git_commit_log.txt`); mỗi lần dùng AI đều được ghi vào AI Audit Log kèm phần người review đã sửa.

1. **Phân tích:** trích yêu cầu từ SRS (`README.md`), liệt kê input/điều kiện/output, rồi đối chiếu code để lập bảng giả thuyết "Spec vs Code". **Spec là oracle**, code chỉ để biết chỗ nào dễ sai.
2. **Domain Testing:** chia miền từng input thành lớp tương đương hợp lệ/không hợp lệ (mã `EC-…`). Mỗi test hợp lệ phủ nhiều lớp; **mỗi test không hợp lệ chỉ chứa đúng một lỗi**. Có bảng truy vết lớp → test. Với state machine, miền là cặp (trạng thái hiện tại × đích) nên test đủ 25 ô; với coupon dùng bảng quyết định C1..C5.
3. **Boundary Value Analysis:** xác định đại lượng có thứ tự theo spec, nêu biên đóng/mở (`>=` hay `>`), thiết kế 3 giá trị biên−1/biên/biên+1 và cực trị; đại lượng spec không nêu số thì ghi rõ "không có biên" thay vì tự bịa.
4. **Thực thi:** script API lặp lại được (HTTP thật, đếm dữ liệu trước/sau) và thao tác UI thật bằng trình duyệt; kết quả tổng là Fail nếu bất kỳ lớp UI/API lệch spec.
5. **AI gap analysis:** so bản thiết kế đầu của AI với bộ test/bug cuối, phân loại nguyên nhân (Prompt / Giới hạn công cụ / Độ phức tạp feature).
6. **Bug report:** gom các test Fail theo nguyên nhân gốc, mỗi bug có bước tái hiện, expected (trích dòng SRS), actual và bằng chứng; đăng lên GitHub Issues.

Cách dùng AI có kỷ luật: mỗi bước một prompt riêng (liệt kê input → chia lớp → ghép test → biên → thực thi → gap → bug), không dùng một prompt chung kiểu "sinh test và tìm bug". Quy trình được đóng gói thành Agent Skill `skills/domain-testing-bva/` và được chỉnh lại sau mỗi feature (xem bảng "Nhật ký cải tiến skill" trong `SKILL.md`).

3. Tổng hợp kết quả

Feature	Test thiết kế	Đã chạy	Pass	Fail	Bug gốc
FR-03 Quên & đặt lại mật khẩu (Pool A)	60	60	20	40	10
FR-10 Máy trạng thái đơn hàng (Pool B)	71	71	64	7	7
FR-16 Import sản phẩm từ CSV (Pool C)	62	62	28	34	11
Mobile FR-08/09 Thanh toán & mã giảm giá trên Mobile (Pool D)	63	63	42	21	8
Tổng	**256**	**256**	**154**	**102**	**36**

Nhiều test Fail cùng một nguyên nhân gốc nên số bug nhỏ hơn số test Fail. Phát hiện nổi bật:

- **FR-03:** OTP chỉ 4 chữ số (spec: 6); regex form đặt lại mật khẩu từ chối mọi mật khẩu hợp lệ theo spec; thiếu ô xác nhận mật khẩu và Step Indicator; OTP không hết hạn.
- **FR-10:** `canceled → delivered` được phép; User hủy được đơn đang giao; API đổi trạng thái không kiểm tra role Admin; race condition làm đơn đã hủy bị xác nhận đè.
- **FR-16:** import không rollback; không validate giá; parse CSV hỏng trường có nháy kép; API import không kiểm tra role Admin.
- **Mobile FR-08/09:** mã giảm % cho tiền giảm âm (tổng đơn tăng lên 10 lần); đơn đúng bằng ngưỡng bị từ chối; backend tin `total_amount` của client; Mobile bỏ mất sản phẩm cuối của giỏ.

4. Báo cáo Domain Testing

4.1 FR-03 Quên & đặt lại mật khẩu (Pool A)

Phạm vi: Web (`/forgot-password`) và API (`POST /api/forgot-password`, `POST /api/reset-password`). Màn hình quên mật khẩu trên Mobile không thuộc phạm vi FR-03 của bài này.

1. Yêu cầu theo SRS (`README.md`)

> **FR-03** (README.md dòng 46–60) Bước 1 — Lấy mã OTP:
>
> - Người dùng nhập địa chỉ Email đã đăng ký.
> - Hệ thống sinh mã OTP **6 chữ số ngẫu nhiên** và gửi qua Email (demo: hiển thị trực tiếp trên màn hình).
> - Giao diện phải hiển thị **chỉ báo bước (Step Indicator)** — ví dụ: "Bước 1 / 2".
> - Có nút **Quay lại đăng nhập**.
>
> Bước 2 — Đặt lại mật khẩu:
>
> - Người dùng nhập OTP, Mật khẩu mới, và **Xác nhận mật khẩu mới**.
> - Mật khẩu mới phải tuân thủ điều kiện như FR-01.
> - Hai trường mật khẩu phải khớp nhau.
> - OTP chỉ hợp lệ cho email đã yêu cầu, không thể dùng cho email khác.

Các yêu cầu liên quan ở mục khác:

> **FR-01** (dòng 36–43): mật khẩu tối thiểu 8 ký tự, ≥1 chữ hoa, ≥1 chữ thường, ≥1 chữ số, ≥1 ký tự đặc biệt trong `@ $ ! % * ? &`; email hợp lệ. **FR-22** (dòng 250–256): trường bắt buộc có `*`; Email dùng `type="email"`;

> Mật khẩu dùng `type="password"`; thông báo lỗi nằm **trên** nút submit; form ≥2 bước phải có Step Indicator. **SEC-07** (dòng 284): OTP tối thiểu 6 chữ số, **có thời hạn**, **vô hiệu hóa sau khi dùng**. **SEC-05** (dòng 282): truy vấn dùng parameterized query.

Điểm spec chưa định lượng: **thời hạn OTP** (SEC-07 chỉ nói "có thời hạn", không nêu số phút). Không thể tạo test biên thời gian chính xác; sẽ ghi là hạn chế và chỉ test "có hết hạn hay không" theo cách quan sát được.

2. Input / Điều kiện / Output

Loại	Tên	Mô tả	Ràng buộc theo spec
Input (bước 1)	`email`	Email đã đăng ký	Đúng định dạng email; phải là email tồn tại trong hệ thống
Input (bước 2)	`otp` (`resetToken`)	Mã OTP	Đúng 6 chữ số; khớp OTP đã cấp cho **chính email đó**
Input (bước 2)	`newPassword`	Mật khẩu mới	Theo FR-01 (≥8 ký tự, hoa, thường, số, ký tự đặc biệt `@$!%*?&`)
Input (bước 2)	`confirmPassword`	Xác nhận mật khẩu mới	Phải bằng `newPassword`
Hành động	"Lấy mã OTP", "Đặt lại mật khẩu", "Quay lại đăng nhập"		
Tiền đề	Tài khoản tồn tại (`test@eshop.com` / `Test1234!`)		
Trạng thái	OTP đã cấp / đã dùng / hết hạn		OTP hết hạn và đã dùng thì không dùng lại được (SEC-07)
Output	Thông báo, chuyển bước, đổi mật khẩu trong DB		Bước 1: hiện OTP 6 số trên màn hình; bước 2 thành công: về `/login`, đăng nhập được bằng mật khẩu mới
Output UI	Step Indicator "Bước x / 2"		Hiển thị ở cả 2 bước

3. Spec vs Code (giả thuyết cần kiểm chứng)

Nguồn code: `backend/server.js:68-98`, `frontend-web/src/pages/ForgotPassword.jsx`, `frontend-web/src/pages/Login.jsx:50`.

#	Spec nói	Code làm	File:dòng	Trạng thái
H1	OTP 6 chữ số	`Math.floor(1000 + Math.random()*9000)` → 4 chữ số (1000–9999)	server.js:72	Chưa kiểm chứng
H2	Nhãn UI nhất quán với spec	Nhãn "Mã OTP (4 số)"	ForgotPassword.jsx:69	Chưa kiểm chứng
H3	Mật khẩu mới theo FR-01 (có ký tự đặc biệt `@$!%*?&`)	Regex `(?=.*\s)` đòi khoảng trắng và `[A-Za-z\d\s]` cấm ký tự đặc biệt	ForgotPassword.jsx:26	Chưa kiểm chứng
H4	Có trường Xác nhận mật khẩu mới, hai trường khớp	Chỉ có 1 trường mật khẩu	ForgotPassword.jsx:78-87	Chưa kiểm chứng

#	Spec nói	Code làm	File:dòng	Trạng thái
H5	Step Indicator "Bước 1 / 2"	Không có	ForgotPassword.jsx	Chưa kiểm chứng
H6	Nút "Quay lại đăng nhập"	Chỉ có nút "← Quay lại" (về bước 1); không có link về đăng nhập	ForgotPassword.jsx:93	Chưa kiểm chứng
H7	Email dùng `type="email"` (FR-22)	`type="text"`	ForgotPassword.jsx:50	Chưa kiểm chứng
H8	Trường bắt buộc có `*` (FR-22)	Nhãn không có `*`	ForgotPassword.jsx:48,69,79	Chưa kiểm chứng
H9	OTP có thời hạn (SEC-07)	Không lưu thời điểm tạo; không kiểm tra hết hạn	server.js:68-98	Chưa kiểm chứng
H10	OTP vô hiệu sau khi dùng	`reset_token = NULL` sau khi dùng — có vẻ đúng	server.js:90	Chưa kiểm chứng
H11	Mật khẩu mới theo FR-01 được kiểm tra	Backend `reset-password` không kiểm tra độ mạnh; chỉ UI (và UI sai, H3)	server.js:87-98	Chưa kiểm chứng
H12	OTP chỉ dùng cho email đã yêu cầu	SQL `WHERE email=? AND reset_token=?` → đúng ràng buộc theo email	server.js:90	Chưa kiểm chứng
H13	Validate đầu vào	`resetToken` rỗng/`null`/thiếu → `reset_token = NULL` khớp user có `reset_token IS NULL`? (`= NULL` luôn false trong SQL nên có thể an toàn)	server.js:90	Cần thử
H14	Không để lộ thông tin (khuyến nghị)	Email không tồn tại → 404 "User not found" (liệt kê được email)	server.js:71	Quan sát
H15	Email không hợp lệ thì báo lỗi rõ	Backend crash nếu `err` ở `forgot-password`? `if (!user)` xử lý; `err` bị bỏ qua ở `db.get`	server.js:70-71	Cần thử
H16	Thông báo lỗi phía trên nút submit (FR-22)	Bước 1 dùng `alert()`; bước 2 `alert()`	ForgotPassword.jsx:20,28,37	Chưa kiểm chứng
H17	OTP đủ entropy	Dùng `Math.random()` (không an toàn mật mã)	server.js:72	Quan sát (SEC-07)
H18	Sau khi đổi mật khẩu có thể đăng nhập bằng mật khẩu mới	Mật khẩu lưu plaintext (SEC-01 ngoài phạm vi, chỉ ghi chú)	server.js:90	Ngoài phạm vi

Ghi chú: H18 và H14 thuộc yêu cầu của feature khác/khuyến nghị; chỉ dùng để làm test thêm khi chạy, không gom vào số bug chính nếu spec FR-03 không nói.

4. Nhận xét ảnh hưởng thiết kế test

- Với H1, spec yêu cầu OTP **6** chữ số, hệ thống thật sinh **4**. Biên BVA lấy theo spec (5/6/7); khi thực thi sẽ kiểm tra thêm cả OTP 4 chữ số do hệ thống sinh ra để thấy sự lệch.
- Vì UI và API là hai lớp ràng buộc, mỗi test cần chỉ rõ chạy ở lớp nào: **UI** (web form) hay **API** (curl). Nhiều ràng buộc (xác nhận mật khẩu, độ mạnh mật khẩu mới) chỉ có hoặc không có ở một lớp.
- Dữ liệu sạch: chạy `node database.js` trước các test thay đổi mật khẩu để khôi phục `test@eshop.com` / `Test1234!`.

Oracle: SRS `README.md` (FR-03 dòng 46–60, FR-01 dòng 36–43, FR-22 dòng 250–256, SEC-07 dòng 284). Chi tiết ở `01_analysis.md`.

Quy ước:

- Mã lớp: `EC-<input>-V<n>` (hợp lệ), `EC-<input>-I<n>` (không hợp lệ).
- Mỗi test không hợp lệ chỉ chứa **một** lớp I; các input còn lại lấy giá trị hợp lệ "chuẩn" bên dưới, để khi fail biết đúng nguyên nhân.
- Cột **Lớp chạy**: `UI` = form web `/forgot-password`; `API` = gọi trực tiếp `localhost:3000`. Một số ràng buộc chỉ kiểm được ở một lớp (ví dụ trường Xác nhận mật khẩu chỉ có trên UI).

Dữ liệu chuẩn (giá trị hợp lệ mặc định):

- `email` = `test@eshop.com` (đã seed), `otp` = OTP vừa được cấp cho email đó, `newPassword` = `Newpass1!`, `confirmPassword` = `Newpass1!`.
- Dữ liệu sạch: chạy `node database.js` rồi `node server.js` trước nhóm test thay đổi mật khẩu.

1. Lớp tương đương

1.1 `email` (Bước 1)

Mã lớp	Loại	Mô tả lớp	Ví dụ đại diện
EC-email-V1	Hợp lệ	Email đúng định dạng và đã đăng ký	`test@eshop.com`
EC-email-I1	Không hợp lệ	Rỗng	(trống)
EC-email-I2	Không hợp lệ	Sai định dạng (thiếu `@` / thiếu miền)	`testeshop.com`, `test@`
EC-email-I3	Không hợp lệ	Đúng định dạng nhưng chưa đăng ký	`nobody@eshop.com`
EC-email-I4	Không hợp lệ	Chỉ gồm khoảng trắng	`" "`
EC-email-I5	Không hợp lệ	Chứa ký tự đặc biệt/SQL	`' OR '1'='1`

1.2 `otp` (Bước 2)

Mã lớp	Loại	Mô tả lớp	Ví dụ đại diện
EC-otp-V1	Hợp lệ	Đúng 6 chữ số, là OTP đã cấp cho **chính email này**, còn hạn, chưa dùng	OTP vừa nhận
EC-otp-I1	Không hợp lệ	Rỗng	(trống)
EC-otp-I2	Không hợp lệ	Ít hơn 6 chữ số (chỉ gồm số)	`12345`

Mã lớp	Loại	Mô tả lớp	Ví dụ đại diện
EC-otp-I3	Không hợp lệ	Nhiều hơn 6 chữ số (chỉ gồm số)	`1234567`
EC-otp-I4	Không hợp lệ	Đủ 6 ký tự nhưng có chữ cái/ký tự không phải số	`12a45!`
EC-otp-I5	Không hợp lệ	Đủ 6 chữ số nhưng **sai giá trị**	OTP thật ± 1
EC-otp-I6	Không hợp lệ	OTP hợp lệ của **email khác**	OTP của user B dùng cho email A
EC-otp-I7	Không hợp lệ	OTP **đã dùng** rồi (dùng lại lần 2)	OTP đã reset thành công
EC-otp-I8	Không hợp lệ	OTP **hết hạn** (SEC-07)	OTP cấp từ lâu

1.3 `newPassword` (Bước 2) — theo FR-01

Mã lớp	Loại	Mô tả lớp	Ví dụ đại diện
EC-pw-V1	Hợp lệ	≥8 ký tự, có hoa, thường, số và ký tự đặc biệt thuộc `@$!%*?&`	`Newpass1!`
EC-pw-I1	Không hợp lệ	Rỗng	(trống)
EC-pw-I2	Không hợp lệ	Dưới 8 ký tự (đủ 4 loại)	`Ab1!xyz`
EC-pw-I3	Không hợp lệ	Thiếu chữ hoa	`newpass1!`
EC-pw-I4	Không hợp lệ	Thiếu chữ thường	`NEWPASS1!`
EC-pw-I5	Không hợp lệ	Thiếu chữ số	`Newpass!!`
EC-pw-I6	Không hợp lệ	Thiếu ký tự đặc biệt	`Newpass12`
EC-pw-I7	Không hợp lệ (diễn giải chặt)	Ký tự đặc biệt nằm **ngoài** tập `@$!%*?&` và không có ký tự nào trong tập	`Newpass1#`

Ghi chú EC-pw-I7: FR-01 liệt kê tập `@ $ ! % * ? &`; diễn giải chặt là chỉ các ký tự này tính là "đặc biệt". Đây là điểm spec có thể hiểu hai cách, nên khi kết quả lệch sẽ ghi "theo diễn giải chặt", không tính ngay là bug chắc chắn.

1.4 `confirmPassword` (Bước 2)

Mã lớp	Loại	Mô tả lớp	Ví dụ đại diện
EC-cf-V1	Hợp lệ	Giống hệt `newPassword`	`Newpass1!`
EC-cf-I1	Không hợp lệ	Khác `newPassword` hoàn toàn	`Other123!`
EC-cf-I2	Không hợp lệ	Rỗng (khi `newPassword` có giá trị)	(trống)
EC-cf-I3	Không hợp lệ	Chỉ khác hoa/thường (phân biệt chữ hoa thường)	`newpass1!`

1.5 Yêu cầu giao diện của feature (GUI)

Mã lớp	Mô tả
EC-gui-1	Step Indicator "Bước 1 / 2" hiển thị ở bước 1
EC-gui-2	Step Indicator "Bước 2 / 2" hiển thị ở bước 2
EC-gui-3	Nút "Quay lại đăng nhập" có ở form
EC-gui-4	Trường email dùng `type="email"` (FR-22)
EC-gui-5	Trường bắt buộc có ký hiệu `*` (FR-22)
EC-gui-6	Thông báo lỗi nằm **trên** nút submit (FR-22)
EC-gui-7	Trường mật khẩu dùng `type="password"` (FR-22)

2. Test case

Expected luôn theo **spec**. "Mật khẩu không đổi" nghĩa là đăng nhập bằng `Test1234!` vẫn thành công và mật khẩu mới không đăng nhập được.

2.1 Bước 1 — Lấy OTP

TC ID	Lớp phủ	Tiền đề	Dữ liệu vào	Expected (theo spec)	Lớp chạy	Truy vết
FR03-DT-01	EC-email-V1	DB sạch	email = `test@eshop.com`	Sinh OTP **6 chữ số**, hiển thị trên màn hình, chuyển sang bước 2	UI+API	FR-03 B1
FR03-DT-02	EC-email-I1	—	email rỗng	Từ chối, báo lỗi, không sinh OTP, ở lại bước 1	UI+API	FR-03 B1
FR03-DT-03	EC-email-I2	—	`testeshop.com`	Từ chối vì sai định dạng, ở lại bước 1	UI+API	FR-03 B1, FR-22
FR03-DT-04	EC-email-I3	—	`nobody@eshop.com`	Từ chối, báo lỗi rõ ràng, không cấp OTP	UI+API	FR-03 B1
FR03-DT-05	EC-email-I4	—	`" "` (3 khoảng trắng)	Từ chối, báo lỗi, ở lại bước 1	UI+API	FR-03 B1
FR03-DT-06	EC-email-I5	—	`' OR '1'='1`	Từ chối như email không hợp lệ; không lỗi server, không cấp OTP cho user nào	API	SEC-05

2.2 Bước 2 — Đặt lại mật khẩu (happy path)

TC ID	Lớp phủ	Tiền đề	Dữ liệu vào	Expected (theo spec)	Lớp chạy	Truy vết
FR03-DT-07	EC-email-V1, EC-otp-V1, EC-pw-V1, EC-cf-V1	Đã có OTP của `test@eshop.com`	otp thật, `Newpass1!`, `Newpass1!`	Đổi mật khẩu thành công, về `/login`; đăng nhập `Newpass1!` OK, `Test1234!` bị từ chối; OTP bị vô hiệu	UI	FR-03 B2, SEC-07

2.3 Bước 2 — OTP không hợp lệ (mật khẩu còn lại hợp lệ)

TC ID	Lớp phủ	Tiền đề	Dữ liệu vào	Expected (theo spec)	Lớp chạy	Truy vết
FR03-DT-08	EC-otp-I1	Đã có OTP	otp rỗng	Từ chối, mật khẩu không đổi	UI+API	FR-03 B2
FR03-DT-09	EC-otp-I2	Đã có OTP	`12345`	Từ chối, mật khẩu không đổi	UI+API	FR-03 B2
FR03-DT-10	EC-otp-I3	Đã có OTP	`1234567`	Từ chối, mật khẩu không đổi	UI+API	FR-03 B2
FR03-DT-11	EC-otp-I4	Đã có OTP	`12a45!`	Từ chối, mật khẩu không đổi	UI+API	FR-03 B2
FR03-DT-12	EC-otp-I5	Đã có OTP = X	OTP khác X (6 số)	Từ chối, mật khẩu không đổi	UI+API	FR-03 B2
FR03-DT-13	EC-otp-I6	Tạo user B; lấy OTP của B	email = A, otp = OTP của B	Từ chối: OTP chỉ hợp lệ cho email đã yêu cầu; mật khẩu A không đổi	API	FR-03 B2
FR03-DT-14	EC-otp-I7	Vừa reset thành công bằng OTP X	Dùng lại OTP X lần 2	Từ chối: OTP vô hiệu sau khi dùng	UI+API	SEC-07
FR03-DT-15	EC-otp-I8	Có OTP cấp từ lâu	Dùng OTP sau thời gian dài	Từ chối: OTP có thời hạn (thời hạn không định lượng trong SRS)	API	SEC-07

2.4 Bước 2 — Mật khẩu mới không hợp lệ (OTP hợp lệ)

TC ID	Lớp phủ	Tiền đề	Dữ liệu vào	Expected (theo spec)	Lớp chạy	Truy vết
FR03-DT-16	EC-pw-I1	Đã có OTP	newPassword rỗng	Từ chối, mật khẩu không đổi	UI+API	FR-03 B2
FR03-DT-17	EC-pw-I2	Đã có OTP	`Ab1!xyz`	Từ chối (<8 ký tự), mật khẩu không đổi	UI+API	FR-01
FR03-DT-18	EC-pw-I3	Đã có OTP	`newpass1!`	Từ chối (thiếu hoa)	UI+API	FR-01
FR03-DT-19	EC-pw-I4	Đã có OTP	`NEWPASS1!`	Từ chối (thiếu thường)	UI+API	FR-01
FR03-DT-20	EC-pw-I5	Đã có OTP	`Newpass!!`	Từ chối (thiếu số)	UI+API	FR-01
FR03-DT-21	EC-pw-I6	Đã có OTP	`Newpass12`	Từ chối (thiếu ký tự đặc biệt)	UI+API	FR-01
FR03-DT-22	EC-pw-I7	Đã có OTP	`Newpass1#`	Từ chối (diễn giải chặt: `#` không thuộc `@$!%*?&`)	UI+API	FR-01

2.5 Bước 2 — Xác nhận mật khẩu

TC ID	Lớp phủ	Tiền đề	Dữ liệu vào	Expected (theo spec)	Lớp chạy	Truy vết
FR03-DT-23	EC-cf-I1	Đã có OTP	new=`Newpass1!`, confirm=`Other123!`	Từ chối vì hai trường không khớp, mật khẩu không đổi	UI	FR-03 B2
FR03-DT-24	EC-cf-I2	Đã có OTP	new=`Newpass1!`, confirm rỗng	Từ chối, mật khẩu không đổi	UI	FR-03 B2
FR03-DT-25	EC-cf-I3	Đã có OTP	new=`Newpass1!`, confirm=`newpass1!`	Từ chối (phân biệt hoa/thường)	UI	FR-03 B2

2.6 Giao diện (GUI)

TC ID	Lớp phủ	Tiền đề	Thao tác	Expected (theo spec)	Lớp chạy	Truy vết
FR03-DT-26	EC-gui-1	Mở `/forgot-password`	Quan sát bước 1	Có chỉ báo "Bước 1 / 2"	UI	FR-03, FR-22
FR03-DT-27	EC-gui-2	Hoàn tất bước 1	Quan sát bước 2	Có chỉ báo "Bước 2 / 2"	UI	FR-03, FR-22
FR03-DT-28	EC-gui-3	Mở trang	Tìm nút	Có nút "Quay lại đăng nhập" dẫn về `/login`	UI	FR-03 B1
FR03-DT-29	EC-gui-4	Mở trang	Kiểm tra thuộc tính input email	`type="email"`	UI	FR-22
FR03-DT-30	EC-gui-5	Cả 2 bước	Quan sát nhãn	Trường bắt buộc có `*`	UI	FR-22
FR03-DT-31	EC-gui-6	Gây lỗi	Quan sát vị trí thông báo lỗi	Thông báo nằm trên nút submit	UI	FR-22
FR03-DT-32	EC-gui-7	Bước 2	Kiểm tra input mật khẩu mới	`type="password"`	UI	FR-22

3. Truy vết lớp → test

Mã lớp	Test phủ
EC-email-V1	DT-01, DT-07
EC-email-I1	DT-02
EC-email-I2	DT-03
EC-email-I3	DT-04
EC-email-I4	DT-05
EC-email-I5	DT-06
EC-otp-V1	DT-07
EC-otp-I1..I8	DT-08..DT-15 (theo thứ tự)
EC-pw-V1	DT-07
EC-pw-I1..I7	DT-16..DT-22 (theo thứ tự)
EC-cf-V1	DT-07
EC-cf-I1..I3	DT-23..DT-25
EC-gui-1..7	DT-26..DT-32

Tổng: **32** test case Domain Testing. Mọi lớp đều có ít nhất một test.

4. Giới hạn và giả định

- **Thời hạn OTP** không có số trong SRS (SEC-07 chỉ nói "có thời hạn"), nên DT-15 chỉ kiểm hành vi "có hết hạn hay không", không kiểm biên thời gian.
- DT-23..DT-25 chỉ chạy được trên UI; nếu UI không có trường xác nhận, kết quả là **Fail** (spec yêu cầu có trường) và các test này không thể thực thi đầy đủ.
- Kết quả của DT-22 phụ thuộc diễn giải "ký tự đặc biệt" (xem ghi chú ở 1.3).
- Test đổi mật khẩu thành công (DT-07) thay đổi dữ liệu; sau đó phải reset DB trước các test dùng `Test1234!`.

4.2 FR-10 Máy trạng thái đơn hàng (Pool B)

Phạm vi: API `PUT /api/admin/orders/:id/status` (Admin), `PUT /api/orders/:id/cancel` (User), cùng giao diện **Web Admin** (`:5174`, tab Đơn hàng) và **Web user** (`/profile`, danh sách đơn). Màn hình hủy đơn trên **Mobile** thuộc feature Mobile FR-10 của thành viên khác nên **không** nằm trong phạm vi; backend dùng chung nên phần API đã bao phủ.

1. Yêu cầu theo SRS (`README.md`)

> **FR-10** (dòng 141–162): Đơn hàng có **5 trạng thái** và phải tuân theo sơ đồ:
>
> - `pending` → `confirmed` [Admin xác nhận]; `confirmed` → `shipping` [Admin giao hàng]; `shipping` → `delivered` [Admin hoàn tất].
> - `pending` → `canceled` và `confirmed` → `canceled` [User/Admin hủy].
>
> **Ràng buộc trạng thái kết thúc:** `delivered` và `canceled` là trạng thái kết thúc — không được chuyển sang bất kỳ trạng thái nào khác. Khi đơn ở `shipping`, **User không được phép tự hủy** — chỉ Admin mới có thể thao tác. Mọi chuyển đổi không hợp lệ phải trả về lỗi với thông báo phù hợp.

Các yêu cầu liên quan ở mục khác:

> **FR-12** (dòng 176–179): mọi API `/api/admin/*` yêu cầu JWT hợp lệ **và** `role = 'admin'`. **SEC-03** (dòng 280): API Admin phải kiểm tra `role = 'admin'` trong token, không chỉ kiểm tra có token. **FR-18** (dòng 220–222): Admin chuyển trạng thái đơn theo đúng State Machine FR-10. **FR-21** (dòng 244): toàn bộ giao diện dùng tiếng Việt. **FR-20** (dòng 236): hủy đơn trên Mobile tuân theo FR-10 (thuộc feature khác).

Điểm mơ hồ của spec:

- "chỉ Admin mới có thể thao tác" khi đơn ở `shipping` — sơ đồ chỉ có mũi tên `shipping → delivered`, **không** có `shipping → canceled`. Diễn giải dùng ở đây: Admin chỉ được `shipping → delivered`, không được hủy. Nếu kết quả thực tế cho phép Admin hủy đơn đang giao, sẽ ghi là "theo diễn giải chặt".
- Spec không định nghĩa chuyển ngược (ví dụ `confirmed → pending`) nhưng sơ đồ không có mũi tên ngược → không hợp lệ.

2. Input / Điều kiện / Output

Loại	Tên	Mô tả	Ràng buộc theo spec
Input	trạng thái hiện tại	`pending`, `confirmed`, `shipping`, `delivered`, `canceled`	5 giá trị
Input	trạng thái đích (`status`)	body của `PUT /api/admin/orders/:id/status`	chỉ chuyển hợp lệ theo sơ đồ
Input	`id` đơn hàng	tham số đường dẫn	đơn phải tồn tại
Input	vai trò người gọi	không token / User thường / Admin	API Admin chỉ cho `admin`; hủy chỉ cho chủ đơn
Input	hành động User	nút "Hủy đơn" trên trang Profile (web)	chỉ khi `pending` hoặc `confirmed`
Precondition	đơn hàng được tạo bằng `POST /api/checkout`	trạng thái đầu `pending`	

Loại	Tên	Mô tả	Ràng buộc theo spec
Output	HTTP + JSON, trạng thái đơn trong DB, giao diện (nút hiển thị, thông báo lỗi)		chuyển không hợp lệ → lỗi + trạng thái không đổi

Nguồn dữ liệu khởi tạo: `POST /api/checkout` (token user) tạo đơn `pending`; đưa đơn về các trạng thái khác bằng chuỗi chuyển hợp lệ qua API Admin (token `admin@eshop.com` / `Admin123!`).

3. Spec vs Code (giả thuyết cần kiểm chứng)

Nguồn: `backend/server.js:100-110` (xác thực), `:311-342` (my-orders, hủy), `:525-568` (đổi trạng thái admin); `frontend-admin/src/App.jsx:85-92,805-870`; `frontend-web/src/pages/Profile.jsx:66-80,199-206`.

#	Spec nói	Code làm	File:dòng	Trạng thái
H1	`canceled` là trạng thái cuối, không chuyển tiếp	Cho phép `canceled → delivered`	server.js:550-551	Chưa kiểm chứng
H2	UI không nên cho thao tác sai	Admin UI hiện nút "Đánh dấu Đã giao" ở đơn `canceled`	App.jsx:862-869	Chưa kiểm chứng
H3	User không được hủy khi `shipping`	Backend chỉ chặn `delivered` và `canceled` → User hủy được đơn `shipping`	server.js:329 (kèm comment "Lẽ ra phải là...")	Chưa kiểm chứng
H4	Nút hủy chỉ khi `pending/confirmed`	Web Profile hiện nút "Hủy đơn" cho mọi trạng thái trừ `delivered/canceled` (gồm `shipping`)	Profile.jsx:199-206	Chưa kiểm chứng
H5	API Admin kiểm tra `role = 'admin'` (FR-12, SEC-03)	`authenticateToken` chỉ kiểm tra token hợp lệ, không kiểm tra role → User thường đổi được trạng thái mọi đơn	server.js:525 + :100-110	Chưa kiểm chứng
H6	Chủ đơn mới được hủy	Truy vấn `WHERE id=? AND user_id=?` → hủy đơn người khác trả 404	server.js:321-327	Có vẻ đúng, cần thử
H7	Chuyển không hợp lệ trả lỗi "phù hợp"	Trả 400 `Invalid state transition from X to Y` (tiếng Anh)	server.js:553-557	Chưa kiểm chứng; liên quan FR-21
H8	`delivered` là trạng thái cuối	Không có nhánh cho phép rời `delivered` → đúng	server.js:537-551	Có vẻ đúng
H9	Admin không hủy được đơn `shipping` (sơ đồ)	Không có nhánh `shipping → canceled` → bị từ chối (đúng với diễn giải chặt)	server.js:547	Có vẻ đúng
H10	Giá trị `status` không hợp lệ bị từ chối	`status` không khớp nhánh nào → `isValidTransition=false` → 400	server.js:553	Có vẻ đúng, cần thử
H11	Chuyển cùng trạng thái (`pending→pending`) không hợp lệ	Không có nhánh → 400	server.js:537-551	Có vẻ đúng
H12	Thao tác trên đơn không tồn tại báo lỗi	`SELECT` rỗng → 404	server.js:532	Có vẻ đúng
H13	Thông báo lỗi UI bằng tiếng Việt (FR-21)	Admin UI hiện `"Lỗi: " + err.response.data.error` → lộ chuỗi tiếng Anh	App.jsx:90-91	Chưa kiểm chứng
H14	`GET /api/orders/:id` chỉ cho chủ đơn xem (FR-11)	Không có xác thực, ai cũng xem được	server.js:344-349	Ngoài phạm vi FR-10 (thuộc FR-11)

#	Spec nói	Code làm	File:dòng	Trạng thái
H15	Hiển thị an toàn (FR-18)	`dangerouslySetInnerHTML` cho địa chỉ giao hàng	App.jsx:799-804	Ngoài phạm vi FR-10 (thuộc FR-18)

H14, H15 chỉ ghi chú vì thuộc feature của thành viên khác, không đưa vào bug của FR-10.

4. Nhận xét ảnh hưởng thiết kế test

- Miền đầu vào chính là **cặp (trạng thái hiện tại × trạng thái đích)**: 5 × 5 = 25 ô; hợp lệ chỉ 5 ô. Mỗi ô là một lớp tương đương nên sẽ test đủ cả 25.
- "Biên" của state machine không phải số: gồm (a) ranh giới giữa trạng thái cho phép và không cho phép hủy trong chuỗi `pending < confirmed < shipping < delivered`, (b) ID đơn hàng (0, 1, lớn nhất, lớn nhất+1, không phải số), (c) chuỗi `status` sát giá trị hợp lệ (thiếu/thừa 1 ký tự, khoảng trắng), (d) số lần lặp một thao tác (hủy lần 1 và lần 2).
- Có hai lớp thực thi cho mỗi ràng buộc: **API** (backend) và **UI** (Web Admin, Web user). Backend phải chặn dù UI đã ẩn nút.
- Chuẩn bị dữ liệu: mỗi test tạo đơn mới bằng checkout rồi đưa tới trạng thái cần thiết bằng các chuyển hợp lệ, để các test độc lập nhau.

Oracle: SRS `README.md` (FR-10 dòng 141–162; FR-12 dòng 176–179; FR-21 dòng 244; SEC-03 dòng 280). Chi tiết và điểm mơ hồ ở `01_analysis.md`.

Quy ước:

- Miền đầu vào chính của feature là **cặp (trạng thái hiện tại × trạng thái đích)**, hữu hạn 5 × 5 nên mỗi ô là một lớp tương đương và được test đủ.
- Mỗi test không hợp lệ chỉ vi phạm **một** điều kiện; các điều kiện còn lại hợp lệ (đúng chủ đơn/đúng vai trò, id tồn tại).
- Sau mỗi test không hợp lệ, kiểm tra **trạng thái đơn trong DB không đổi**.
- Cột **Lớp chạy**: `API` = HTTP trực tiếp `localhost:3000`; `UI-Admin` = Web Admin `:5174`; `UI-Web` = Web user `:5173/profile`.
- Dữ liệu: mỗi test tạo đơn `pending` mới bằng `POST /api/checkout` (user `test@eshop.com`), rồi đưa tới trạng thái nguồn bằng các chuyển hợp lệ qua API Admin (`admin@eshop.com` / `Admin123!`).

1. Lớp tương đương

1.1 (trạng thái hiện tại × trạng thái đích) — gọi bởi Admin

Chiều hợp lệ theo sơ đồ SRS: ✓ = được phép, ✗ = phải bị từ chối (400, trạng thái không đổi).

Hiện tại \ Đích	pending	confirmed	shipping	delivered	canceled
pending	✗	✓	✗	✗	✓
confirmed	✗	✗	✓	✗	✓
shipping	✗	✗	✗	✓	✗ (*)
delivered (cuối)	✗	✗	✗	✗	✗

Hiện tại \ Đích	pending	confirmed	shipping	delivered	canceled
canceled (cuối)	✗	✗	✗	✗	✗

(*) Diễn giải chặt: sơ đồ SRS không có `shipping → canceled`; xem điểm mơ hồ ở `01_analysis.md`. Tổng: 5 ô hợp lệ + 20 ô không hợp lệ. Mã lớp: `EC-M-<hiện tại>-<đích>`.

1.2 Người thực hiện (actor) và quyền

Mã lớp	Mô tả
EC-act-V1	Admin (token `role=admin`) gọi API Admin
EC-act-V2	User đã đăng nhập, **chủ đơn**, gọi hủy đơn
EC-act-I1	Không có token
EC-act-I2	User thường (`role=user`) gọi API Admin
EC-act-I3	User hủy đơn của **người khác**

1.3 Đơn hàng được chỉ định

Mã lớp	Mô tả
EC-ord-V1	`id` của đơn tồn tại
EC-ord-I1	`id` không tồn tại

1.4 Giá trị `status` trong body

Mã lớp	Mô tả	Ví dụ
EC-sv-V1	Một trong 5 giá trị hợp lệ (viết thường)	`confirmed`
EC-sv-I1	Chuỗi rỗng	`""`
EC-sv-I2	Chuỗi lạ	`refunded`
EC-sv-I3	Sai chữ hoa/thường	`CONFIRMED`
EC-sv-I4	`null`	`null`
EC-sv-I5	Sai kiểu (số)	`123`

1.5 Giao diện

Mã lớp	Mô tả
EC-gui-A-	Web Admin: tập nút hành động hiển thị cho đơn ở trạng thái đó chỉ gồm chuyển hợp lệ
EC-gui-W-	Web user (Profile): nút "Hủy đơn" chỉ hiển thị khi `pending`/`confirmed`
EC-gui-err	Thông báo lỗi khi chuyển không hợp lệ rõ ràng, tiếng Việt (FR-21)

2. Test case

2.1 Ma trận chuyển trạng thái (API Admin) — Expected theo SRS

TC ID	Lớp	Hiện tại → Đích	Expected (theo spec)	Lớp chạy
FR10-DT-01	EC-M-pending-pending	pending → pending	Từ chối (400), không đổi	API
FR10-DT-02	EC-M-pending-confirmed	pending → confirmed	Chấp nhận (200), trạng thái = confirmed	API
FR10-DT-03	EC-M-pending-shipping	pending → shipping	Từ chối (bỏ qua `confirmed`)	API
FR10-DT-04	EC-M-pending-delivered	pending → delivered	Từ chối	API
FR10-DT-05	EC-M-pending-canceled	pending → canceled	Chấp nhận, trạng thái = canceled	API
FR10-DT-06	EC-M-confirmed-pending	confirmed → pending	Từ chối (không chuyển ngược)	API
FR10-DT-07	EC-M-confirmed-confirmed	confirmed → confirmed	Từ chối	API
FR10-DT-08	EC-M-confirmed-shipping	confirmed → shipping	Chấp nhận, = shipping	API
FR10-DT-09	EC-M-confirmed-delivered	confirmed → delivered	Từ chối (bỏ qua `shipping`)	API
FR10-DT-10	EC-M-confirmed-canceled	confirmed → canceled	Chấp nhận, = canceled	API
FR10-DT-11	EC-M-shipping-pending	shipping → pending	Từ chối	API
FR10-DT-12	EC-M-shipping-confirmed	shipping → confirmed	Từ chối	API
FR10-DT-13	EC-M-shipping-shipping	shipping → shipping	Từ chối	API
FR10-DT-14	EC-M-shipping-delivered	shipping → delivered	Chấp nhận, = delivered	API
FR10-DT-15	EC-M-shipping-canceled	shipping → canceled	Từ chối (diễn giải chặt)	API
FR10-DT-16	EC-M-delivered-pending	delivered → pending	Từ chối (trạng thái cuối)	API
FR10-DT-17	EC-M-delivered-confirmed	delivered → confirmed	Từ chối	API
FR10-DT-18	EC-M-delivered-shipping	delivered → shipping	Từ chối	API
FR10-DT-19	EC-M-delivered-delivered	delivered → delivered	Từ chối	API
FR10-DT-20	EC-M-delivered-canceled	delivered → canceled	Từ chối	API
FR10-DT-21	EC-M-canceled-pending	canceled → pending	Từ chối (trạng thái cuối)	API
FR10-DT-22	EC-M-canceled-confirmed	canceled → confirmed	Từ chối	API
FR10-DT-23	EC-M-canceled-shipping	canceled → shipping	Từ chối	API
FR10-DT-24	EC-M-canceled-delivered	canceled → delivered	Từ chối (`canceled` là trạng thái cuối)	API
FR10-DT-25	EC-M-canceled-canceled	canceled → canceled	Từ chối	API

2.2 User hủy đơn của chính mình (`PUT /api/orders/:id/cancel`)

TC ID	Lớp	Trạng thái đơn	Expected (theo spec)	Lớp chạy
FR10-DT-26	EC-act-V2	pending	Chấp nhận, = canceled	API
FR10-DT-27	EC-act-V2	confirmed	Chấp nhận, = canceled	API
FR10-DT-28	EC-act-V2	shipping	**Từ chối** (User không được hủy khi shipping), không đổi	API
FR10-DT-29	EC-act-V2	delivered	Từ chối, không đổi	API
FR10-DT-30	EC-act-V2	canceled	Từ chối, không đổi	API

2.3 Quyền và đối tượng

TC ID	Lớp	Dữ liệu vào	Expected (theo spec)	Lớp chạy
FR10-DT-31	EC-act-I1	Admin API, không token, pending → confirmed	401, không đổi	API
FR10-DT-32	EC-act-I1	Hủy đơn, không token	401, không đổi	API
FR10-DT-33	EC-act-I2	Token User thường gọi Admin API pending → confirmed	Từ chối (403), không đổi (FR-12, SEC-03)	API
FR10-DT-34	EC-act-I3	User B hủy đơn pending của User A	Từ chối, đơn A không đổi	API
FR10-DT-35	EC-ord-I1	Admin API, id không tồn tại	404	API
FR10-DT-36	EC-ord-I1	User hủy, id không tồn tại	404	API

2.4 Giá trị `status` không hợp lệ (đơn đang `pending`, Admin)

TC ID	Lớp	`status`	Expected (theo spec)	Lớp chạy
FR10-DT-37	EC-sv-I1	`""`	Từ chối (400), không đổi	API
FR10-DT-38	EC-sv-I2	`refunded`	Từ chối, không đổi	API
FR10-DT-39	EC-sv-I3	`CONFIRMED`	Từ chối, không đổi	API
FR10-DT-40	EC-sv-I4	`null`	Từ chối, không đổi	API
FR10-DT-41	EC-sv-I5	`123`	Từ chối, không đổi	API

2.5 Luồng nghiệp vụ

TC ID	Lớp	Kịch bản	Expected (theo spec)	Lớp chạy
FR10-DT-42	EC-M (chuỗi hợp lệ)	pending → confirmed → shipping → delivered	Mỗi bước thành công; sau `delivered` mọi chuyển tiếp bị từ chối	API
FR10-DT-43	EC-M, EC-act-V2	pending → confirmed → User hủy → thử `canceled → delivered`	Hủy thành công; chuyển tiếp từ `canceled` bị từ chối	API

2.6 Giao diện

TC ID	Lớp	Trạng thái đơn	Expected (theo spec)	Lớp chạy
FR10-DT-44	EC-gui-A-pending	pending	Chỉ nút "Xác nhận", "Hủy"	UI-Admin

TC ID	Lớp	Trạng thái đơn	Expected (theo spec)	Lớp chạy
FR10-DT-45	EC-gui-A-confirmed	confirmed	Chỉ nút "Giao hàng", "Hủy"	UI-Admin
FR10-DT-46	EC-gui-A-shipping	shipping	Chỉ nút "Hoàn thành"	UI-Admin
FR10-DT-47	EC-gui-A-delivered	delivered	Không có nút hành động	UI-Admin
FR10-DT-48	EC-gui-A-canceled	canceled	Không có nút hành động (trạng thái cuối)	UI-Admin
FR10-DT-49	EC-gui-W-pending	pending	Có nút "Hủy đơn"	UI-Web
FR10-DT-50	EC-gui-W-confirmed	confirmed	Có nút "Hủy đơn"	UI-Web
FR10-DT-51	EC-gui-W-shipping	shipping	**Không** có nút "Hủy đơn"	UI-Web
FR10-DT-52	EC-gui-W-delivered	delivered	Không có nút "Hủy đơn"	UI-Web
FR10-DT-53	EC-gui-W-canceled	canceled	Không có nút "Hủy đơn"	UI-Web
FR10-DT-54	EC-gui-err	Màn hình Admin đang hiển thị đơn `pending` (cũ), trong lúc đó đơn đã chuyển `confirmed` bằng API; bấm "Xác nhận"	Thông báo lỗi rõ ràng, **tiếng Việt**, không lộ chi tiết kỹ thuật	UI-Admin

3. Truy vết lớp → test

Nhóm lớp	Test phủ
EC-M (25 ô)	DT-01..DT-25 (mỗi ô một test), DT-42, DT-43 (chuỗi)
EC-act-V1 / V2	DT-02, 05, 08, 10, 14 (Admin); DT-26, 27 (chủ đơn)
EC-act-I1	DT-31, DT-32
EC-act-I2	DT-33
EC-act-I3	DT-34
EC-ord-V1 / I1	mọi test khác / DT-35, DT-36
EC-sv-V1	DT-02, 08, 10 (và các ô hợp lệ khác)
EC-sv-I1..I5	DT-37..DT-41
EC-gui-A-*	DT-44..DT-48
EC-gui-W-*	DT-49..DT-53
EC-gui-err	DT-54

Tổng: **54** test case Domain Testing; mọi lớp đều có ít nhất một test.

4. Giới hạn và giả định

- Hủy đơn trên Mobile không thuộc phạm vi (feature của thành viên khác); logic backend dùng chung đã được test qua API.

- `shipping → canceled` do Admin (DT-15) phụ thuộc diễn giải "chỉ Admin mới có thể thao tác" (xem `01_analysis.md`); nếu kết quả khác diễn giải, ghi "theo diễn giải chặt", không coi chắc chắn là bug.
- DT-54 cần tạo tình huống dữ liệu cũ (stale) trên Web Admin vì giao diện không cho bấm hành động không hợp lệ ở trạng thái mới nhất.

4.3 FR-16 Import sản phẩm từ CSV (Pool C)

Phạm vi: Web Admin `http://localhost:5174` → tab **Sản phẩm** → khối "Import sản phẩm từ CSV" (chọn file, xem trước, nút Import) và API `POST /api/admin/import-products`. Việc đọc/parse file CSV được làm ***ở client*** (trình duyệt) rồi gửi lên API dưới dạng mảng JSON, nên có hai lớp cần test: **UI (file CSV thật)** và **API (mảng JSON)**.

1. Yêu cầu theo SRS (`README.md`)

> **FR-16** (dòng 200–211):
>
> - Admin có thể tải lên file CSV để import nhiều sản phẩm cùng lúc.
> - **Yêu cầu file CSV:** đuôi file phải là `.csv`; dòng đầu tiên là header `name,price,description,imageUrl,category_id`; hỗ trợ trường chứa dấu phẩy nếu được bọc trong dấu nháy kép (RFC 4180).
> - **Validation trước khi import:** `name` không được rỗng; `price` phải là số dương.
> - Nếu có lỗi ở bất kỳ dòng nào, toàn bộ import phải được **rollback** (giao dịch nguyên tử — all-or-nothing).
> - Hệ thống hiển thị báo cáo rõ ràng: bao nhiêu dòng thành công, bao nhiêu dòng lỗi và lý do.

Các yêu cầu liên quan ở mục khác:

> **FR-12** (dòng 176–179) và **SEC-03** (dòng 280): API Admin yêu cầu JWT hợp lệ **và** `role = 'admin'`. **FR-15** (dòng 191–198): ràng buộc sản phẩm — tên tối đa 255 ký tự, giá > 0, danh mục chọn từ danh sách có sẵn (thuộc feature khác; chỉ dùng làm tham chiếu cho `category_id`). **FR-21** (dòng 244–246): giao diện tiếng Việt; tiền dùng ký hiệu `đ`.

Điểm spec chưa định lượng/mơ hồ:

- "Báo cáo bao nhiêu dòng thành công, bao nhiêu dòng lỗi": khi rollback thì số dòng thành công = 0; vẫn phải có thông báo rõ rằng import **bị hủy** và liệt kê các dòng lỗi.
- "price phải là số dương": 0 và âm là không hợp lệ; số thập phân dương (ví dụ `0.5`) vẫn là số dương nên diễn giải là hợp lệ.
- Spec không quy định `category_id` phải tồn tại (FR-15 nói danh mục phải chọn từ danh sách) nên dùng làm test khám phá, không tính chắc chắn là bug.

2. Input / Điều kiện / Output

Loại	Tên	Mô tả	Ràng buộc theo spec
Input	file	file tải lên	đuôi `.csv`
Input	header	dòng đầu	đúng `name,price,description,imageUrl,category_id`
Input	định dạng trường	dấu phẩy, nháy kép	RFC 4180 (trường có dấu phẩy được bọc `"..."`)

Loại	Tên	Mô tả	Ràng buộc theo spec
Input	`name`	tên SP của từng dòng	không rỗng
Input	`price`	giá của từng dòng	số dương
Input	`description`, `imageUrl`, `category_id`	các cột còn lại	spec không ràng buộc riêng
Input	số dòng dữ liệu	số bản ghi	≥ 1 (file rỗng/chỉ header không có gì để import)
Input	vị trí dòng lỗi	đầu/giữa/cuối	một dòng lỗi → hủy toàn bộ
Precondition	tài khoản	Admin	token JWT, `role = admin`
Output	số sản phẩm trong DB	trước/sau	có lỗi → không thêm bản ghi nào
Output	báo cáo	thông báo trên UI	số dòng thành công/lỗi và lý do

3. Spec vs Code (giả thuyết cần kiểm chứng)

Nguồn: `backend/server.js:198-241` (API), `frontend-admin/src/App.jsx:18-22,341-481` (UI).

#	Spec nói	Code làm	File:dòng	Trạng thái
H1	Có lỗi ở bất kỳ dòng nào thì rollback toàn bộ	Mỗi dòng `INSERT` riêng, không có transaction; dòng lỗi chỉ bị bỏ qua, các dòng khác vẫn được thêm	server.js:209-232	Chưa kiểm chứng
H2	`price` phải là số dương	Backend không kiểm tra giá; UI lấy `row.price || … || 0` rồi gửi nguyên. Âm, 0, chữ đều được chèn	server.js:218-223; App.jsx:392	Chưa kiểm chứng
H3	Hỗ trợ trường có dấu phẩy bọc trong nháy kép (RFC 4180)	Parse bằng `line.split(",")` nên cắt sai trường có dấu phẩy	App.jsx:367-377	Chưa kiểm chứng
H4	Chỉ nhận file `.csv`	`<input type="file">` không có `accept`; code không kiểm tra tên file/đuôi	App.jsx:356-358	Chưa kiểm chứng
H5	Header phải đúng `name,price,description,imageUrl,category_id`	Không kiểm tra header; thiếu/sai cột chỉ cho giá trị rỗng; còn chấp nhận alias `ten`, `gia`, `Name`…	App.jsx:370-401	Chưa kiểm chứng
H6	Báo cáo rõ ràng số dòng thành công/lỗi + lý do	`message` chỉ ghi "x/y sản phẩm được thêm"; `errors[]` liệt kê lý do; HTTP luôn 200 kể cả khi có lỗi	server.js:234-240	Chưa kiểm chứng
H7	API Admin kiểm tra `role = admin` (FR-12, SEC-03)	`authenticateToken` chỉ xác thực token, không kiểm tra role	server.js:199	Chưa kiểm chứng
H8	`name` không rỗng	Có kiểm tra `!row.name` (đúng); nhưng tên toàn khoảng trắng bị UI `trim()` thành rỗng nên cũng bị chặn; API nhận `" "` truyền thẳng → `" "` là truthy nên **được chèn**	server.js:214; App.jsx:371	Cần thử (UI đúng, API có thể sai)
H9	`category_id` thuộc danh sách danh mục (FR-15)	Thiếu/không hợp lệ → mặc định `1`; không kiểm tra tồn tại	server.js:223; App.jsx:400-402	Cần thử

#	Spec nói	Code làm	File:dòng	Trạng thái
H10	File rỗng/chỉ header không import được	UI: không có dòng dữ liệu nên nút Import bị vô hiệu; API: mảng rỗng → 400	App.jsx:418; server.js:202-204	Có vẻ đúng, cần thử
H11	Lỗi số dòng chính xác	`index + 2` (tính cả header); dòng trống giữa file thành dòng lỗi "Thiếu tên"	server.js:215; App.jsx:367-377	Cần thử
H12	File mẫu đúng header	Link "Tải file mẫu" tạo CSV đúng header	App.jsx:347-353	Có vẻ đúng
H13	Chống XSS khi hiển thị dữ liệu (SEC-04)	Bảng xem trước render `{v}` bằng React (an toàn); danh sách sản phẩm sau import thuộc FR-15	App.jsx:446-450	Ngoài phạm vi, chỉ ghi chú

4. Nhận xét ảnh hưởng thiết kế test

- Miền đầu vào chia thành 3 tầng: **file** (đuôi, rỗng, header), **định dạng** (dấu phẩy/nháy kép, xuống dòng, BOM) và **nội dung từng dòng** (`name`, `price`, `category_id`). Mỗi test lỗi chỉ chứa một lỗi để biết nguyên nhân.
- Tính nguyên tử cần test theo **vị trí dòng lỗi** (đầu/giữa/cuối) và **số dòng lỗi** (1, nhiều, tất cả); tiêu chí kiểm tra là **số sản phẩm trong DB trước và sau** import, không chỉ thông báo.
- Parse CSV nằm ở client nên test về nháy kép, header, BOM, CRLF phải chạy trên **UI** với file thật; còn validate `name`/`price` và quyền phải chạy trên **API** (mảng JSON) để bắt lỗi thiếu validate phía server.
- Biên: số dòng dữ liệu (0, 1, nhiều), số trường mỗi dòng (n−1, n, n+1), giá (−1, 0, 1, …), độ dài tên (0, 1), vị trí dòng lỗi.
- Mỗi test phải dọn dữ liệu (xóa sản phẩm vừa chèn) để các test không ảnh hưởng nhau.

Oracle: SRS `README.md` (FR-16 dòng 200–211; FR-12 dòng 176–179; FR-15 dòng 191–198; SEC-03 dòng 280). Chi tiết ở `01_analysis.md`.

Quy ước:

- Mã lớp: `EC-<nhóm>-V<n>` (hợp lệ), `EC-<nhóm>-I<n>` (không hợp lệ).
- Mỗi test không hợp lệ chỉ chứa **một** lỗi; phần còn lại của file hợp lệ (dòng dữ liệu chuẩn bên dưới).
- Tiêu chí "không import" = **số sản phẩm trong DB không đổi** (đếm `GET /api/products` trước/sau), không chỉ dựa vào thông báo.
- Cột **Lớp chạy**: `UI` = chọn file `.csv` thật trên Web Admin (tab Sản phẩm), parse ở client; `API` = gọi `POST /api/admin/import-products` với mảng JSON.
- Dữ liệu chuẩn: header `name,price,description,imageUrl,category_id`; dòng hợp lệ `SP Test 1,100000,Mô tả 1,https://placehold.co/300,1`. Tên sản phẩm test dùng tiền tố `FR16-` để dễ đếm và dọn dẹp sau mỗi test.
- Tài khoản: Admin `admin@eshop.com` / `Admin123!` (token), User `test@eshop.com` / `Test1234!`.

1. Lớp tương đương

1.1 File

Mã lớp	Loại	Mô tả	Ví dụ
EC-file-V1	Hợp lệ	File `.csv` có header và ≥ 1 dòng dữ liệu	`products.csv`
EC-file-I1	Không hợp lệ	Sai đuôi `.txt` (nội dung vẫn là CSV đúng)	`products.txt`
EC-file-I2	Không hợp lệ	Sai đuôi `.xlsx` (nội dung CSV)	`products.xlsx`
EC-file-I3	Không hợp lệ	File `.csv` rỗng (0 byte)	
EC-file-I4	Không hợp lệ	Chỉ có header, không có dòng dữ liệu	
EC-file-I5	Không hợp lệ	Chỉ có khoảng trắng/xuống dòng	

1.2 Header

Mã lớp	Loại	Mô tả	Ví dụ
EC-hdr-V1	Hợp lệ	Đúng 5 cột, đúng thứ tự, đúng tên	`name,price,description,imageUrl,category_id`
EC-hdr-I1	Không hợp lệ	Sai thứ tự	`price,name,description,imageUrl,category_id`
EC-hdr-I2	Không hợp lệ	Thiếu cột `price`	`name,description,imageUrl,category_id`
EC-hdr-I3	Không hợp lệ	Thừa cột	`name,price,description,imageUrl,category_id,sku`
EC-hdr-I4	Không hợp lệ	Sai tên (hoa/thường)	`Name,Price,Description,ImageUrl,Category_id`
EC-hdr-I5	Không hợp lệ	Không có header (dòng đầu là dữ liệu)	

1.3 Định dạng trường (RFC 4180)

Mã lớp	Loại	Mô tả	Ví dụ
EC-fmt-V1	Hợp lệ	Trường thường không có ký tự đặc biệt	
EC-fmt-V2	Hợp lệ	Trường có dấu phẩy bọc trong nháy kép	`"Áo, size M"`
EC-fmt-V3	Hợp lệ	Nháy kép được escape bằng `""`	`"Màn hình 27"" IPS"`
EC-fmt-V4	Hợp lệ	Xuống dòng kiểu CRLF	
EC-fmt-V5	Hợp lệ	Ký tự tiếng Việt UTF-8	`Điện thoại Samsung`
EC-fmt-I1	Không hợp lệ	Nháy kép mở nhưng không đóng	`"Áo, size M,100000,...`

1.4 `name`

Mã lớp	Loại	Mô tả	Ví dụ
EC-name-V1	Hợp lệ	Chuỗi không rỗng	`FR16-A`
EC-name-I1	Không hợp lệ	Rỗng	``
EC-name-I2	Không hợp lệ	Chỉ khoảng trắng	` `

1.5 `price`

Mã lớp	Loại	Mô tả	Ví dụ
EC-price-V1	Hợp lệ	Số nguyên dương	`100000`
EC-price-V2	Hợp lệ	Số thập phân dương	`0.5`
EC-price-I1	Không hợp lệ	Số âm	`-1`
EC-price-I2	Không hợp lệ	Bằng 0	`0`
EC-price-I3	Không hợp lệ	Không phải số	`abc`
EC-price-I4	Không hợp lệ	Rỗng	``

1.6 `category_id` (diễn giải theo FR-15: danh mục phải có trong danh sách)

Mã lớp	Loại	Mô tả	Ví dụ
EC-cat-V1	Hợp lệ	Id danh mục tồn tại	`1`
EC-cat-I1	Không hợp lệ (diễn giải)	Id không tồn tại	`999`
EC-cat-I2	Không hợp lệ (diễn giải)	Rỗng	``

1.7 Tính nguyên tử (vị trí và số dòng lỗi, mỗi dòng lỗi dùng lỗi `price = -1`)

Mã lớp	Mô tả
EC-atom-V1	Mọi dòng hợp lệ (đối chứng)
EC-atom-I1	1 dòng lỗi ở **đầu** file (3 dòng)
EC-atom-I2	1 dòng lỗi ở **giữa** (3 dòng)
EC-atom-I3	1 dòng lỗi ở **cuối** (3 dòng)
EC-atom-I4	**Nhiều** dòng lỗi (2 trong 5 dòng)
EC-atom-I5	**Tất cả** dòng lỗi (3 dòng)

1.8 Quyền và hình dạng request (API)

Mã lớp	Loại	Mô tả
EC-auth-V1	Hợp lệ	Token Admin
EC-auth-I1	Không hợp lệ	Không token
EC-auth-I2	Không hợp lệ	Token User thường
EC-body-I1	Không hợp lệ	Thiếu `products`
EC-body-I2	Không hợp lệ	`products` là mảng rỗng
EC-body-I3	Không hợp lệ	`products` không phải mảng (chuỗi)
EC-body-I4	Không hợp lệ	Mảng chứa phần tử không phải object (`null`)

1.9 Báo cáo và giao diện

Mã lớp	Mô tả
EC-rep-1	Báo cáo khi thành công: số dòng thành công
EC-rep-2	Báo cáo khi thất bại: lý do theo dòng, số dòng lỗi, nói rõ **không có sản phẩm nào được thêm**
EC-rep-3	Mã phản hồi API khi có lỗi cho thấy thất bại
EC-ui-1	Nút Import bị vô hiệu khi chưa có dữ liệu
EC-ui-2	Bảng xem trước đúng số dòng và tên cột
EC-ui-3	File mẫu tải về đúng header và import được

2. Test case

2.1 Hợp lệ và định dạng (UI, file thật)

TC ID	Lớp phủ	Dữ liệu vào	Expected (theo spec)	Lớp chạy
FR16-DT-01	EC-file-V1, EC-hdr-V1, EC-fmt-V1, EC-name-V1, EC-price-V1, EC-cat-V1	3 dòng hợp lệ	Import 3/3; DB tăng 3	UI
FR16-DT-02	EC-fmt-V2	tên `"FR16-Áo, size M"`	Tạo 1 SP có tên đúng `FR16-Áo, size M` (không bị cắt tại dấu phẩy)	UI
FR16-DT-03	EC-fmt-V3	tên `"FR16-Màn hình 27"" IPS"`	Tạo 1 SP tên `FR16-Màn hình 27" IPS`	UI
FR16-DT-04	EC-fmt-V4	file dùng CRLF, 3 dòng	Import 3 SP, tên/giá không chứa ký tự `\r`	UI
FR16-DT-05	EC-fmt-V5	tên tiếng Việt có dấu	Lưu đúng, không lỗi mã hóa	UI
FR16-DT-06	EC-price-V2	price `0.5`	Chấp nhận (số dương)	UI+API
FR16-DT-43	EC-fmt-I1	tên mở nháy kép không đóng	Từ chối file không hợp lệ, DB không đổi	UI

2.2 File

TC ID	Lớp phủ	Dữ liệu vào	Expected (theo spec)	Lớp chạy
FR16-DT-07	EC-file-I1	`products.txt` nội dung CSV đúng	Từ chối (đuôi phải `.csv`), DB không đổi	UI
FR16-DT-08	EC-file-I2	`products.xlsx` nội dung CSV đúng	Từ chối, DB không đổi	UI
FR16-DT-09	EC-file-I3	`.csv` 0 byte	Không import được, có thông báo/ nút vô hiệu, DB không đổi	UI
FR16-DT-10	EC-file-I4	chỉ header	Không import, DB không đổi	UI
FR16-DT-11	EC-file-I5	chỉ khoảng trắng/xuống dòng	Không import, DB không đổi	UI

2.3 Header

TC ID	Lớp phủ	Dữ liệu vào	Expected (theo spec)	Lớp chạy
FR16-DT-12	EC-hdr-I1	header sai thứ tự (+ dữ liệu theo thứ tự đó)	Từ chối, DB không đổi	UI
FR16-DT-13	EC-hdr-I2	thiếu cột `price`	Từ chối, DB không đổi	UI
FR16-DT-14	EC-hdr-I3	thừa cột `sku`	Từ chối, DB không đổi	UI
FR16-DT-15	EC-hdr-I4	header `Name,Price,...`	Từ chối, DB không đổi	UI
FR16-DT-16	EC-hdr-I5	không có header	Từ chối, DB không đổi	UI

2.4 Nội dung dòng (mỗi test chỉ một lỗi; 1 dòng dữ liệu)

TC ID	Lớp phủ	Dữ liệu vào	Expected (theo spec)	Lớp chạy
FR16-DT-17	EC-name-I1	name rỗng	Từ chối, DB không đổi	UI+API
FR16-DT-18	EC-name-I2	name `" "`	Từ chối, DB không đổi	UI+API
FR16-DT-19	EC-price-I1	price `-1`	Từ chối, DB không đổi	UI+API
FR16-DT-20	EC-price-I2	price `0`	Từ chối, DB không đổi	UI+API
FR16-DT-21	EC-price-I3	price `abc`	Từ chối, DB không đổi	UI+API
FR16-DT-22	EC-price-I4	price rỗng	Từ chối, DB không đổi	UI+API
FR16-DT-23	EC-cat-I1	category_id `999`	Từ chối (danh mục không tồn tại; diễn giải FR-15), DB không đổi	UI+API
FR16-DT-24	EC-cat-I2	category_id rỗng	Từ chối (danh mục bắt buộc; diễn giải FR-15), DB không đổi	UI+API

2.5 Tính nguyên tử

TC ID	Lớp phủ	Dữ liệu vào	Expected (theo spec)	Lớp chạy
FR16-DT-25	EC-atom-I1	3 dòng, dòng 1 lỗi	**Không** dòng nào được thêm (rollback)	UI+API
FR16-DT-26	EC-atom-I2	3 dòng, dòng 2 lỗi	Không dòng nào được thêm	UI+API
FR16-DT-27	EC-atom-I3	3 dòng, dòng 3 lỗi	Không dòng nào được thêm	UI+API
FR16-DT-28	EC-atom-I4	5 dòng, dòng 2 và 4 lỗi	Không dòng nào được thêm	UI+API
FR16-DT-29	EC-atom-I5	3 dòng, cả 3 lỗi	Không dòng nào được thêm	UI+API
FR16-DT-30	EC-atom-V1	5 dòng hợp lệ	Thêm cả 5	UI+API

2.6 Báo cáo

TC ID	Lớp phủ	Kịch bản	Expected (theo spec)	Lớp chạy
FR16-DT-31	EC-rep-1	Import thành công 3 dòng	Báo cáo nêu số dòng thành công (3)	UI

TC ID	Lớp phủ	Kịch bản	Expected (theo spec)	Lớp chạy
FR16-DT-32	EC-rep-2	Import file có 1 dòng lỗi (dòng 2 của 3)	Báo cáo nêu rõ lỗi ở dòng nào và lý do, **số dòng lỗi**, và việc import đã bị hủy (0 sản phẩm được thêm)	UI
FR16-DT-33	EC-rep-3	API với 1 dòng lỗi	Phản hồi cho thấy thất bại (HTTP 4xx hoặc `inserted = 0` kèm lỗi), không phải "hoàn tất" thành công	API

2.7 Quyền và hình dạng request (API)

TC ID	Lớp phủ	Dữ liệu vào	Expected (theo spec)	Lớp chạy
FR16-DT-34	EC-auth-I1	không token	401, DB không đổi	API
FR16-DT-35	EC-auth-I2	token User thường, 1 dòng hợp lệ	Từ chối (403), DB không đổi (FR-12, SEC-03)	API
FR16-DT-36	EC-body-I1	body không có `products`	400, server vẫn sống	API
FR16-DT-37	EC-body-I2	`products: []`	400	API
FR16-DT-38	EC-body-I3	`products: "abc"`	400	API
FR16-DT-39	EC-body-I4	`products: [null]`	400, server không crash	API

2.8 Giao diện

TC ID	Lớp phủ	Kịch bản	Expected (theo spec)	Lớp chạy
FR16-DT-40	EC-ui-1	Mở tab Sản phẩm, chưa chọn file	Nút Import bị vô hiệu	UI
FR16-DT-41	EC-ui-2	Chọn file 3 dòng hợp lệ	Bảng xem trước hiển thị 3 dòng và đủ 5 tên cột	UI
FR16-DT-42	EC-ui-3	Nội dung link "Tải file mẫu"	Header đúng chuẩn; import được file mẫu	UI

3. Truy vết lớp → test

Nhóm lớp	Test phủ
EC-file-V1, EC-hdr-V1, EC-fmt-V1, EC-name-V1, EC-price-V1, EC-cat-V1	DT-01 (và mọi test hợp lệ khác)
EC-file-I1..I5	DT-07..DT-11
EC-hdr-I1..I5	DT-12..DT-16
EC-fmt-V2..V5	DT-02..DT-05
EC-fmt-I1	DT-43
EC-name-I1, I2	DT-17, DT-18
EC-price-V2	DT-06
EC-price-I1..I4	DT-19..DT-22
EC-cat-I1, I2	DT-23, DT-24
EC-atom-V1, I1..I5	DT-30, DT-25..DT-29
EC-rep-1..3	DT-31..DT-33
EC-auth-I1, I2	DT-34, DT-35
EC-body-I1..I4	DT-36..DT-39

Nhóm lớp	Test phủ
EC-ui-1..3	DT-40..DT-42

Tổng: **43** test case Domain Testing; mọi lớp đều có ít nhất một test.

4. Giới hạn và giả định

- DT-23, DT-24 (danh mục) dựa trên FR-15 ("danh mục phải chọn từ danh sách có sẵn"); FR-16 không nêu rõ nên nếu lệch thì ghi "theo diễn giải", không coi chắc chắn là bug.
- DT-06: số thập phân dương được coi là số dương; cột `price` trong DB là `INTEGER` nên chỉ kiểm tra hệ thống có chấp nhận hay không, không đánh giá việc làm tròn.
- Parse CSV được làm ở client nên các test về định dạng (nháy kép, header, CRLF) chỉ chạy được trên UI; validate `name`/`price`, quyền và hình dạng request chạy trên API.
- Đuôi file `.csv` chỉ có thể kiểm tra khi chọn file qua UI (`<input type="file">` không có `accept`).

4.4 Mobile FR-08/09 Thanh toán & mã giảm giá trên Mobile (Pool D)

Phạm vi: màn hình **Giỏ hàng** → **Xác Nhận Đơn Hàng (checkout)** và khối **Mã Giảm Giá** của ứng dụng Mobile (`frontend-mobile/App.js`: `renderCart`, `renderCheckout`, `openCheckout`, `handleApplyCoupon`, `handleConfirmCheckout`), cùng các API mà nó gọi: `POST /api/apply-coupon`, `POST /api/checkout`, `POST /api/coupon-usage`.

Lưu ý ranh giới với thành viên khác: logic server của FR-08 (checkout) và FR-09 (coupon) cũng được test ở phiên bản Web bởi người khác, còn **giao diện và luồng Mobile** là phần của feature này. Bug ở backend dùng chung vẫn được báo kèm bằng chứng từ Mobile, có ghi chú "dùng chung với Web".

1. Yêu cầu theo SRS (`README.md`)

> **FR-08 — Thanh toán** (dòng 102–108):
>
> - Chỉ người dùng **đã đăng nhập** mới tiến hành thanh toán được.
> - **Tổng tiền thanh toán** được tính tự động từ giỏ hàng và không cho phép người dùng chỉnh sửa trực tiếp.
> - Giao diện hiển thị đầy đủ danh sách sản phẩm đặt mua.
> - Backend phải tự tính lại tổng tiền; không chấp nhận giá trị `total_amount` do client gửi lên.
> - Sau thanh toán thành công, giỏ hàng được xóa.
>
> **FR-09 — Mã giảm giá** (dòng 110–135): tại bước Checkout, nhập mã giảm giá; áp dụng khi **cả 5 điều kiện** thỏa mãn: | C1 | Mã tồn tại và `is_active = 1` | C2 | Còn hạn: ngày hiện tại trước `expired_at` | C3 | Tổng đơn **>=** `min_order_amount` | C4 | Đã đăng nhập (JWT hợp lệ) | C5 | Số lần đã dùng < `max_uses_per_user` | Công thức: `percent`: `discount_amount = total × discount_value / 100`; `fixed`: `discount_amount = discount_value`; `final_amount = total − discount_amount`. Mã mẫu: `SAVE10` (percent 10%, min 300,000, 1 lần/người), `BIGBUY` (fixed 50,000, min 500,000, 1 lần), `VIP100` (fixed 100,000, min 300,000, 2 lần), `EXPIRED` (percent 20%, min 100,000, hết hạn 2020-01-01).

Các yêu cầu liên quan ở mục khác:

> **FR-20** (dòng 235): Mobile có đầy đủ chức năng, trong đó có Thanh toán. **FR-21** (dòng 246): tiền luôn dùng ký hiệu `đ` với phân cách hàng nghìn. **SEC-02** (dòng 279): API có tính bảo mật phải yêu cầu JWT hợp lệ.

Điểm spec mơ hồ/chưa định lượng:

- Thứ tự thông báo lỗi khi vi phạm nhiều điều kiện (ví dụ mã hết hạn **và** chưa đủ ngưỡng) không được quy định; chỉ cần mã bị từ chối với lý do hợp lý.
- Hành vi khi `discount_amount > total` (mã cố định lớn hơn đơn): spec không nêu; giá trị cuối âm là bất hợp lý nên coi "tổng thanh toán không âm" là kỳ vọng hợp lý (ghi là diễn giải).
- Không nêu làm tròn khi giảm theo phần trăm.

2. Input / Điều kiện / Output

Loại	Tên	Mô tả	Ràng buộc theo spec
Precondition	trạng thái đăng nhập	Đã/chưa đăng nhập	Chỉ người đã đăng nhập thanh toán (FR-08) và dùng mã (C4)
Precondition	giỏ hàng	danh sách sản phẩm, số lượng	tổng = Σ đơn giá × số lượng; hiển thị đủ sản phẩm
Input	mã giảm giá `code`	nhập ở ô "Nhập mã giảm giá..."	tồn tại, đang hoạt động (C1)
Input	tổng đơn `total_amount`	= tổng giỏ	`>= min_order_amount` (C3)
Input	ngày hiện tại so với `expired_at`		trước `expired_at` (C2)
Input	số lần đã dùng của user		`< max_uses_per_user` (C5)
Input	loại mã, giá trị	`percent` / `fixed`	công thức ở trên
Hành động	"Áp dụng", "Xác Nhận Thanh Toán"		
Output	`discount_amount`, `final_amount`, thông báo	hiển thị "Tiết kiệm", "Thành tiền", "Tổng thanh toán"	tính đúng theo công thức
Output	đơn hàng được tạo	`status = pending`, `total_amount` do **backend** tính	không tin `total_amount` từ client
Output	giỏ hàng sau thanh toán	rỗng	

3. Spec vs Code (giả thuyết cần kiểm chứng)

Nguồn: `frontend-mobile/App.js:16,75-77,342-420,590-757`; `backend/server.js:297-309` (checkout), `:363-441` (apply-coupon), `:444-454` (coupon-usage).

#	Spec nói	Code làm	File:dòng	Trạng thái
H1	`percent`: `total × value / 100`	`Math.floor(total * (1 - discount_value))` → với `SAVE10` (value = 10) ra số **âm**; `final_amount` lớn hơn tổng	server.js:399-401, 419-421	Chưa kiểm chứng
H2	C3: tổng đơn **`>= min_order_amount`**	Dùng `>` → đúng bằng ngưỡng bị từ chối	server.js:379	Chưa kiểm chứng
H3	C4: phải đăng nhập (JWT)	`apply-coupon` không yêu cầu token; `user_id` do client gửi; bỏ trống `user_id` thì **bỏ qua** kiểm tra C5	server.js:363-433	Chưa kiểm chứng
H4	C5: đã dùng < `max_uses_per_user`	Kiểm tra bằng `count >= max` (đúng) nhưng chỉ khi có `user_id`; lượt dùng chỉ ghi sau checkout bởi request riêng `/coupon-usage`	server.js:386-396, 444-454; App.js:399-408	Cần thử

#	Spec nói	Code làm	File:dòng	Trạng thái
H5	Backend tự tính lại tổng, không tin `total_amount` của client	`checkout` lưu thẳng `total_amount` từ body; không kiểm tra giỏ hàng/mã	server.js:297-309	Chưa kiểm chứng
H6	Hiển thị đầy đủ sản phẩm đặt mua	Gửi `items: cart.slice(0, -1)` khi giỏ có hơn 1 món → **bỏ mất món cuối** (backend hiện bỏ qua `items`)	App.js:391	Cần thử (bắt request)
H7	Chỉ người đã đăng nhập thanh toán	UI chặn ở `openCheckout`; API trả 401 nếu không token	App.js:343-347; server.js:297	Có vẻ đúng, cần thử
H8	Tổng tiền thanh toán không cho sửa	Ô "Tổng tiền thanh toán" `editable={false}`, hiển thị `cartTotal`	App.js:684-690	Có vẻ đúng
H9	Sau thanh toán giỏ hàng được xóa	`setCart([])`, xóa mã	App.js:410-414	Có vẻ đúng, cần thử
H10	Lý do hợp lý khi mã bị từ chối	Kiểm tra ngưỡng **trước** hạn dùng nên mã hết hạn + đơn nhỏ báo "chưa đủ giá trị tối thiểu"	server.js:379-384	Cần thử
H11	Tổng thanh toán không âm (diễn giải)	Mã `fixed` lớn hơn tổng cho `final_amount` âm	server.js:402-406	Cần thử (tạo mã bằng API admin)
H12	`Tổng thanh toán` hiển thị đúng	Ô trên cùng luôn là `cartTotal` (chưa giảm), dòng "Tổng thanh toán" mới là số sau giảm	App.js:684-741	Có vẻ đúng
H13	Địa chỉ giao hàng của đơn	Mobile không gửi `shipping_address` → đơn không có địa chỉ	App.js:390-394; server.js:299	Quan sát
H14	Cấu hình chạy được	`API_URL` cứng là `http://192.168.10.13:3000/api`, không khớp IP máy test (192.168.1.225) → app không kết nối nếu không sửa	App.js:16	Quan sát môi trường
H15	Số lượng trong giỏ đúng (FR-20)	Ô số lượng trong giỏ cộng thêm 1 (`parsed + 1`) khi gõ → sai tổng	App.js:615-623	Ngoài phạm vi (FR-20 của thành viên khác), nhưng ảnh hưởng dữ liệu test nên tránh dùng ô này
H16	Mã không phân biệt hoa/thường khi nhập	Client `toUpperCase()` rồi gửi; API so sánh chính xác	App.js:366	Cần thử

4. Nhận xét ảnh hưởng thiết kế test

- Miền đầu vào của coupon gồm 5 điều kiện C1..C5 độc lập: dùng bảng quyết định, mỗi test chỉ làm sai **một** điều kiện, các điều kiện khác đúng; thêm test mã hợp lệ cho từng loại `percent`/`fixed` và test tính tiền.
- Tính tiền kiểm tra bằng **công thức của spec**, không lấy số do hệ thống trả làm chuẩn.
- Biên: ngưỡng `min_order_amount` (−1, =, +1), hạn dùng (hôm qua/hôm nay/ngày mai), số lần dùng (`max−1`, `max`), số lượng/tổng giỏ, mã có khoảng trắng và chữ thường.
- Hai lớp thực thi: **UI Mobile** (chạy bằng Expo Web / `react-native-web`) và **API**. Giới hạn: không có thiết bị thật/emulator; hộp thoại `Alert.alert` không hiển thị trên bản web, nên các thông báo dạng `Alert` chỉ kiểm tra gián tiếp (chuyển màn hình, trạng thái giỏ/đơn).
- Dữ liệu tạo qua API trước mỗi test: user có token (đăng nhập), mã tùy chỉnh bằng `POST /api/admin/coupons` (API này không kiểm tra role nên dùng được để tạo mã hết hạn/ngưỡng khác).

Oracle: SRS `README.md` (FR-08 dòng 102–108; FR-09 dòng 110–135; FR-20 dòng 235; FR-21 dòng 246; SEC-02 dòng 279). Chi tiết ở `01_analysis.md`.

Quy ước:

- Mã lớp: `EC-<nhóm>-V<n>` (hợp lệ), `EC-<nhóm>-I<n>` (không hợp lệ).
- Mỗi test không hợp lệ chỉ làm sai **một** điều kiện; các điều kiện khác hợp lệ (mã đang hoạt động, còn hạn, đủ ngưỡng, user còn lượt...).
- Số tiền kỳ vọng tính **bằng công thức SRS**: `percent`: `total × value / 100`; `fixed`: `value`; `final = total − discount`.
- Cột **Lớp chạy**: `UI` = ứng dụng Mobile chạy bằng Expo Web (`react-native-web`); `API` = HTTP trực tiếp `localhost:3000`.
- Dữ liệu chuẩn: user `test@eshop.com` / `Test1234!` (trừ khi nói khác); sản phẩm seed: *iPhone 15 Pro Max* 30,000,000 ₫; *Samsung Galaxy S24 Ultra* 28,000,000 ₫; *MacBook Pro M3* 45,000,000 ₫; *AirPods Pro 2* 6,000,000 ₫; *Keychron Q1* 4,000,000 ₫. Để có tổng đơn nhỏ (200,000–600,000) dùng sản phẩm tạo riêng qua API với giá phù hợp (ví dụ `FRM-100k` giá 100,000 ₫).
- Mã seed: `SAVE10` (percent 10, min 300,000, 1 lần), `BIGBUY` (fixed 50,000, min 500,000, 1 lần), `VIP100` (fixed 100,000, min 300,000, 2 lần), `EXPIRED` (percent 20, min 100,000, hết hạn 2020-01-01). Reset trạng thái dùng mã giữa các test bằng cách xóa `coupon_usage` của user.
- Giới hạn môi trường: không có thiết bị/emulator; `Alert.alert` không hiển thị trên bản web nên thông báo dạng Alert chỉ kiểm tra gián tiếp (chuyển màn hình, trạng thái giỏ/đơn).

1. Lớp tương đương

1.1 Điều kiện thanh toán (FR-08)

Mã lớp	Loại	Mô tả
EC-auth-V1	Hợp lệ	Đã đăng nhập (có token)
EC-auth-I1	Không hợp lệ	Chưa đăng nhập (không token)
EC-cart-V1	Hợp lệ	Giỏ có đúng 1 sản phẩm
EC-cart-V2	Hợp lệ	Giỏ có nhiều sản phẩm
EC-cart-I1	Không hợp lệ	Giỏ rỗng
EC-total-V1	Hợp lệ	`total_amount` đúng bằng Σ đơn giá × số lượng
EC-total-I1	Không hợp lệ	`total_amount` do client sửa (khác tổng thật)
EC-total-I2	Không hợp lệ	Thiếu `total_amount`
EC-total-I3	Không hợp lệ	`total_amount` âm
EC-total-I4	Không hợp lệ	`total_amount` không phải số

1.2 Mã giảm giá (FR-09, C1..C5)

Mã lớp	Loại	Mô tả
EC-code-V1	Hợp lệ	Mã tồn tại và đang hoạt động (C1)
EC-code-I1	Không hợp lệ	Mã không tồn tại

Mã lớp	Loại	Mô tả
EC-code-I2	Không hợp lệ	Mã tồn tại nhưng `is_active = 0`
EC-code-I3	Không hợp lệ	Rỗng
EC-code-I4	Không hợp lệ	Chứa ký tự SQL/đặc biệt
EC-code-V2	Hợp lệ (diễn giải)	Chữ thường hoặc có khoảng trắng thừa nhưng đúng mã
EC-exp-V1	Hợp lệ	Còn hạn (C2)
EC-exp-I1	Không hợp lệ	Hết hạn
EC-min-V1	Hợp lệ	Tổng đơn ≥ ngưỡng (C3)
EC-min-I1	Không hợp lệ	Tổng đơn < ngưỡng
EC-login-V1	Hợp lệ	Có JWT hợp lệ (C4)
EC-login-I1	Không hợp lệ	Không có JWT
EC-use-V1	Hợp lệ	Số lần đã dùng < giới hạn (C5)
EC-use-I1	Không hợp lệ	Đã dùng đủ giới hạn

1.3 Loại giảm giá và tính tiền

Mã lớp	Loại	Mô tả
EC-type-V1	Hợp lệ	`percent`, kết quả số nguyên (ví dụ 10% của 400,000)
EC-type-V2	Hợp lệ	`percent`, kết quả có phần lẻ (10% của 333,333)
EC-type-V3	Hợp lệ	`fixed`, nhỏ hơn tổng đơn
EC-type-I1	Không hợp lệ (diễn giải)	`fixed` lớn hơn tổng đơn (tổng thanh toán không được âm)

1.4 Hình dạng request áp mã

Mã lớp	Loại	Mô tả
EC-body-I1	Không hợp lệ	Thiếu `code`
EC-body-I2	Không hợp lệ	Thiếu `total_amount`
EC-body-I3	Không hợp lệ	`total_amount` âm
EC-body-I4	Không hợp lệ	`total_amount` không phải số
EC-usage-I1	Không hợp lệ	`coupon-usage` không token
EC-usage-I2	Không hợp lệ	`coupon-usage` với `coupon_id` không tồn tại

1.5 Giao diện Mobile

Mã lớp	Mô tả
EC-ui-1	Màn hình thanh toán liệt kê đầy đủ sản phẩm, số lượng, thành tiền
EC-ui-2	Ô tổng tiền thanh toán không chỉnh sửa được
EC-ui-3	Khối mã giảm giá: nút "Áp dụng" bị vô hiệu khi mã rỗng; lỗi/kết quả hiển thị đúng và tự xóa khi sửa mã

Mã lớp	Mô tả
EC-ui-4	Hiển thị tiền có `đ` và phân cách hàng nghìn; "Tổng thanh toán" cập nhật sau khi áp mã
EC-ui-5	Luồng hoàn tất: đơn tạo đúng, giỏ được xóa, lượt dùng mã được ghi

2. Test case

2.1 Thanh toán và đăng nhập (FR-08)

TC ID	Lớp phủ	Dữ liệu / thao tác	Expected (theo spec)	Lớp chạy
MFR-DT-01	EC-auth-I1	Chưa đăng nhập, giỏ có 1 SP, bấm "Tiến hành thanh toán"	Không vào màn thanh toán; chuyển sang đăng nhập	UI
MFR-DT-02	EC-auth-I1	`POST /api/checkout` không token	401, không tạo đơn	API
MFR-DT-03	EC-auth-V1, EC-cart-V1, EC-ui-1	Đăng nhập, giỏ 1 SP	Màn thanh toán liệt kê SP với số lượng, thành tiền; tổng = đơn giá × số lượng	UI
MFR-DT-04	EC-cart-V2, EC-ui-1	Giỏ 3 SP khác nhau	Liệt kê đủ 3 SP; tổng = Σ	UI
MFR-DT-05	EC-ui-2	Thử gõ vào ô "Tổng tiền thanh toán"	Không chỉnh sửa được	UI
MFR-DT-06	EC-cart-I1	Giỏ rỗng	Không có đường vào thanh toán; hiển thị thông báo giỏ trống	UI
MFR-DT-07	EC-total-I1	`POST /api/checkout` với `items` hợp lệ nhưng `total_amount = 1`	Backend tự tính lại; đơn có tổng = Σ giá × số lượng (không phải 1) hoặc bị từ chối	API
MFR-DT-08	EC-ui-5	Thanh toán thành công (không mã)	"Thanh toán thành công!"; giỏ rỗng; đơn `pending` trong lịch sử với đúng tổng	UI

2.2 Mã giảm giá hợp lệ và loại mã

TC ID	Lớp phủ	Dữ liệu	Expected (theo spec)	Lớp chạy
MFR-DT-09	EC-code-V1, EC-type-V1	`SAVE10`, tổng 400,000	discount 40,000; final 360,000	UI+API
MFR-DT-10	EC-code-V1, EC-type-V3	`BIGBUY`, tổng 600,000	discount 50,000; final 550,000	UI+API
MFR-DT-11	EC-code-V1, EC-type-V3	`VIP100`, tổng 400,000	discount 100,000; final 300,000	UI+API

2.3 Mã không hợp lệ (C1)

TC ID	Lớp phủ	Dữ liệu	Expected (theo spec)	Lớp chạy
MFR-DT-12	EC-code-I1	`NOPE`, tổng 400,000	Từ chối với lý do; tổng không đổi	UI+API

TC ID	Lớp phủ	Dữ liệu	Expected (theo spec)	Lớp chạy
MFR-DT-13	EC-code-I2	mã tồn tại nhưng `is_active = 0`	Từ chối; tổng không đổi	UI+API
MFR-DT-14	EC-code-I3	để trống	Nút "Áp dụng" vô hiệu / không gửi request	UI
MFR-DT-15	EC-code-V2	`save10` (chữ thường)	Chấp nhận như `SAVE10` (diễn giải: nhập chữ thường vẫn dùng được)	UI
MFR-DT-16	EC-code-V2	`SAVE10`	Chấp nhận (bỏ khoảng trắng thừa)	UI
MFR-DT-17	EC-code-I4	`' OR '1'='1`	Từ chối như mã không tồn tại; không lỗi server	API

2.4 Điều kiện C2–C5

TC ID	Lớp phủ	Dữ liệu	Expected (theo spec)	Lớp chạy
MFR-DT-18	EC-exp-I1	`EXPIRED`, tổng 200,000 (≥ min 100,000)	Từ chối vì hết hạn	UI+API
MFR-DT-19	EC-exp-I1, EC-min-I1	`EXPIRED`, tổng 50,000 (< min)	Từ chối (lý do hợp lý; thứ tự báo lỗi không quy định)	API
MFR-DT-20	EC-min-I1	`SAVE10`, tổng 200,000 (< 300,000)	Từ chối vì chưa đủ ngưỡng	UI+API
MFR-DT-21	EC-min-I1	`BIGBUY`, tổng 400,000 (< 500,000)	Từ chối vì chưa đủ ngưỡng	UI+API
MFR-DT-22	EC-login-I1	`SAVE10`, tổng 400,000, không token	Từ chối (C4: phải đăng nhập)	API
MFR-DT-23	EC-use-I1	User đã dùng `SAVE10` một lần (đã thanh toán), áp lại	Từ chối vì đã dùng hết lượt	UI+API
MFR-DT-24	EC-use-I1, EC-login-I1	Như trên nhưng request **không** có `user_id`	Vẫn từ chối (C5 áp cho người dùng đã đăng nhập; không thể né bằng cách bỏ `user_id`)	API

2.5 Tính tiền và hiển thị

TC ID	Lớp phủ	Dữ liệu	Expected (theo spec)	Lớp chạy
MFR-DT-25	EC-type-V2	`SAVE10`, tổng 333,333	discount ≈ 33,333 (làm tròn xuống/nhất quán), final ≈ 300,000	API
MFR-DT-26	EC-type-I1	mã `fixed` 1,000,000, min 0, tổng 100,000	final không âm (0)	API
MFR-DT-27	EC-ui-4	Áp `SAVE10` ở tổng 400,000	Ô "Tổng tiền thanh toán" giữ 400,000; "Tiết kiệm: 40,000 ₫"; "Thành tiền" và "Tổng thanh toán": 360,000 ₫; có `₫` và phân cách nghìn	UI
MFR-DT-28	EC-ui-3	Áp mã thành công rồi sửa ô mã	Kết quả mã cũ bị xóa; "Tổng thanh toán" quay về tổng gốc	UI

TC ID	Lớp phủ	Dữ liệu	Expected (theo spec)	Lớp chạy
MFR-DT-29	EC-ui-3	Áp mã sai rồi nhập mã đúng	Lỗi cũ biến mất; hiển thị kết quả mã đúng	UI

2.6 Luồng hoàn tất có mã

TC ID	Lớp phủ	Dữ liệu	Expected (theo spec)	Lớp chạy
MFR-DT-30	EC-ui-5	Áp `SAVE10` (tổng 400,000) rồi "Xác Nhận Thanh Toán"	Đơn có tổng 360,000 (do backend tính); giỏ rỗng; lượt dùng mã được ghi (`coupon_usage` +1)	UI
MFR-DT-31	EC-ui-1	Giỏ 3 SP, bấm xác nhận, quan sát request gửi đi	Request chứa **đủ 3** sản phẩm của giỏ	UI

2.7 Hình dạng request (API)

TC ID	Lớp phủ	Dữ liệu	Expected (theo spec)	Lớp chạy
MFR-DT-32	EC-total-I2	`checkout` thiếu `total_amount`	400, không tạo đơn	API
MFR-DT-33	EC-total-I3	`total_amount = -100`	400, không tạo đơn	API
MFR-DT-34	EC-total-I4	`total_amount = "abc"`	400, không tạo đơn	API
MFR-DT-35	EC-usage-I1	`coupon-usage` không token	401	API
MFR-DT-36	EC-usage-I2	`coupon-usage` với `coupon_id = 99999`	Từ chối (4xx), không ghi bản ghi	API
MFR-DT-37	EC-body-I1	`apply-coupon` thiếu `code`	400	API
MFR-DT-38	EC-body-I2	`apply-coupon` thiếu `total_amount`	400, không trả `final_amount` bất thường	API
MFR-DT-39	EC-body-I3	`apply-coupon` `total_amount = -400000`	400	API
MFR-DT-40	EC-body-I4	`apply-coupon` `total_amount = "abc"`	400	API

3. Truy vết lớp → test

Nhóm lớp	Test phủ
EC-auth	DT-01, DT-02, DT-03
EC-cart	DT-03, DT-04, DT-06
EC-total	DT-07, DT-32..DT-34
EC-code	DT-09..DT-11, DT-12..DT-17
EC-exp, EC-min	DT-18..DT-21
EC-login	DT-22, DT-24
EC-use	DT-23, DT-24
EC-type	DT-09..DT-11, DT-25, DT-26
EC-body, EC-usage	DT-35..DT-40
EC-ui-1..5	DT-03, 04, 05, 27, 28, 29, 08, 30, 31

Tổng: **40** test case Domain Testing; mọi lớp đều có ít nhất một test.

4. Giới hạn và giả định

- Cách đọc "tổng đơn" để so ngưỡng: coi bằng `total_amount` của request (tổng giỏ trước giảm).
- DT-15, DT-16, DT-26 là diễn giải; nếu lệch ghi "theo diễn giải", không coi chắc chắn là bug.
- Không test trên thiết bị thật/emulator; kết quả UI từ bản Expo Web dùng cùng mã nguồn `App.js` (đổi tạm `API_URL` sang `localhost`).
- Hiển thị ký hiệu `₫` và phân cách nghìn phụ thuộc `toLocaleString()` của môi trường (locale trình duyệt); có thể khác trên máy thật.

5. Báo cáo Boundary Value Analysis

5.1 FR-03 Quên & đặt lại mật khẩu (Pool A)

Oracle: SRS `README.md` (FR-03 dòng 46–60, FR-01 dòng 36–43, SEC-07 dòng 284). Nhập từ `02_domain_testing.md`. Kỹ thuật: 3 giá trị tại mỗi biên (biên−1, biên, biên+1), có thêm giá trị cực trị khi hữu ích.

1. Chọn input có thứ tự và biên theo spec

Input / đại lượng	Miền theo spec	Biên	Đóng/Mở	Giá trị kiểm thử	Nguồn
Độ dài OTP (người dùng nhập)	đúng 6 chữ số	6	đóng (`= 6`)	0, 1, **5**, **6**, **7**	FR-03 dòng 51; SEC-07
Giá trị OTP có số 0 đầu	000000–999999	000000	đóng	`012345` (nhận), `12345` (mất số 0, từ chối)	FR-03 dòng 51 (6 chữ số ngẫu nhiên)
Độ dài OTP do hệ thống **sinh**	đúng 6 chữ số	6	đóng	mọi OTP sinh ra đều dài 6	FR-03 dòng 51
Độ dài mật khẩu mới	≥ 8 (không nêu tối đa)	8	đóng (`>= 8`)	**7**, **8**, **9**, 256	FR-01 dòng 39
Số chữ hoa	≥ 1	1	đóng	0 (đã có ở DT-18), **1**	FR-01 dòng 39
Số chữ thường	≥ 1	1	đóng	0 (DT-19), **1**	FR-01 dòng 39
Số chữ số	≥ 1	1	đóng	0 (DT-20), **1**	FR-01 dòng 39
Số ký tự đặc biệt	≥ 1, thuộc `@ $ ! % * ? &`	1	đóng	0 (DT-21), **1**	FR-01 dòng 39
Thành viên của tập ký tự đặc biệt	7 ký tự	từng phần tử; hàng xóm ngoài tập	—	mỗi ký tự trong tập (7); ngoài tập sát về mã ASCII: `"` (0x22), `#` (0x23, DT-22), `+` (0x2B)	FR-01 dòng 39
Độ dài `confirmPassword` so với `newPassword`	bằng nhau	n	đóng	n−1, n, n+1 (và n + khoảng trắng)	FR-03 dòng 59
Số lần dùng OTP	tối đa 1 lần	1	mở (`< 1` lần đã dùng)	lần 1 nhận, lần 2 từ chối (xem DT-07, DT-14)	SEC-07
Thời hạn OTP	"có thời hạn", không có số	—	—	**Không có biên số học → không thiết kế BVA thời gian**	SEC-07

Input / đại lượng	Miền theo spec	Biên	Đóng/Mở	Giá trị kiểm thử	Nguồn
Độ dài email	không nêu tối thiểu/tối đa	—	—	**Không có biên theo spec** (email chỉ có lớp định dạng, đã ở Domain Testing)	FR-01 dòng 38

Ghi chú: mật khẩu mới ≥ 8 nhưng spec không có tối đa → BV-12 (256 ký tự) là kiểm tra cực trị khám phá, expected "chấp nhận" vì không có giới hạn.

2. Test case BVA

Điều kiện chung: nhóm OTP (BV-01..08) dùng API trực tiếp vì UI không cho đặt trước OTP 6 số; **tiền đề seed**: đặt `reset_token` của `test@eshop.com` bằng script `evidence/seed_otp.js` (sẽ tạo ở Bước 4) rồi gọi `POST /api/reset-password`. Mỗi lần OTP bị dùng hoặc mật khẩu đổi thì chạy lại `node database.js` + seed để trở về trạng thái đầu. Nhóm mật khẩu (BV-09..25) chạy cả UI và API với OTP hợp lệ.

2.1 Độ dài OTP (tại bước đặt lại; token seed `123456` trừ khi nói khác)

TC ID	Input	Giá trị	Vị trí so với biên	Lớp	Expected (theo spec)
FR03-BV-01	otp	`` (0 chữ số)	cực trị thấp	EC-otp-I1	Từ chối, mật khẩu không đổi
FR03-BV-02	otp	`1` (1 chữ số)	cực trị thấp	EC-otp-I2	Từ chối, mật khẩu không đổi
FR03-BV-03	otp	`12345` (5)	biên−1	EC-otp-I2	Từ chối, mật khẩu không đổi
FR03-BV-04	otp	`123456` (6)	**biên**	EC-otp-V1	Chấp nhận, đổi mật khẩu thành công
FR03-BV-05	otp	`1234567` (7)	biên+1	EC-otp-I3	Từ chối, mật khẩu không đổi
FR03-BV-06	otp	token seed `012345`, nhập `012345`	biên giá trị (số 0 đầu)	EC-otp-V1	Chấp nhận (6 chữ số, số 0 đầu hợp lệ)
FR03-BV-07	otp	token seed `012345`, nhập `12345`	số 0 đầu bị mất	EC-otp-I2	Từ chối (khác OTP đã cấp)
FR03-BV-08	otp	gọi `forgot-password` 20 lần, lấy `resetToken`	độ dài OTP sinh ra	EC-otp-V1	Cả 20 mã đều đúng 6 chữ số (000000–999999)

2.2 Độ dài mật khẩu mới (OTP hợp lệ; confirm = newPassword)

TC ID	Input	Giá trị	Vị trí so với biên	Lớp	Expected (theo spec)
FR03-BV-09	newPassword	`Ab1!xyz` (7)	biên−1	EC-pw-I2	Từ chối, mật khẩu không đổi
FR03-BV-10	newPassword	`Ab1!wxyz` (8)	**biên**	EC-pw-V1	Chấp nhận

TC ID	Input	Giá trị	Vị trí so với biên	Lớp	Expected (theo spec)
FR03-BV-11	newPassword	`Ab1!vwxyz` (9)	biên+1	EC-pw-V1	Chấp nhận
FR03-BV-12	newPassword	`Aa1!` lặp để đủ 256 ký tự	cực trị cao (khám phá)	EC-pw-V1	Chấp nhận (spec không nêu tối đa); không lỗi server

2.3 Số lượng tối thiểu từng loại ký tự (độ dài ≥ 8)

TC ID	Input	Giá trị	Vị trí so với biên	Lớp	Expected (theo spec)
FR03-BV-13	newPassword	`newpass1!A` (đúng 1 chữ hoa)	biên (min=1)	EC-pw-V1	Chấp nhận
FR03-BV-14	newPassword	`NEWPASS1!a` (đúng 1 chữ thường)	biên	EC-pw-V1	Chấp nhận
FR03-BV-15	newPassword	`Newpass!1` (đúng 1 chữ số)	biên	EC-pw-V1	Chấp nhận
FR03-BV-16	newPassword	`Newpass12!` (đúng 1 ký tự đặc biệt)	biên	EC-pw-V1	Chấp nhận

(Giá trị biên−1 = 0 ký tự của từng loại đã có ở DT-18..DT-21.)

2.4 Thành viên tập ký tự đặc biệt

Mẫu: `Newpass1<X>` với `<X>` là ký tự đặc biệt duy nhất. | TC ID | `<X>` | Vị trí | Lớp | Expected (theo spec) | |---|---|---|---|---| | FR03-BV-17 | `@` | trong tập | EC-pw-V1 | Chấp nhận | | FR03-BV-18 | `$` | trong tập | EC-pw-V1 | Chấp nhận | | FR03-BV-19 | `!` | trong tập | EC-pw-V1 | Chấp nhận | | FR03-BV-20 | `%` | trong tập | EC-pw-V1 | Chấp nhận | | FR03-BV-21 | `*` | trong tập | EC-pw-V1 | Chấp nhận | | FR03-BV-22 | `?` | trong tập | EC-pw-V1 | Chấp nhận | | FR03-BV-23 | `&` | trong tập | EC-pw-V1 | Chấp nhận | | FR03-BV-24 | `+` | ngoài tập (hàng xóm ASCII) | EC-pw-I7 | Từ chối (diễn giải chặt) | | FR03-BV-25 | `"` | ngoài tập (hàng xóm ASCII) | EC-pw-I7 | Từ chối (diễn giải chặt) |

2.5 Xác nhận mật khẩu (chỉ UI)

`newPassword` = `Newpass1!` (9 ký tự). | TC ID | confirmPassword | Vị trí so với biên | Lớp | Expected (theo spec) | |---|---|---|---|---| | FR03-BV-26 | `Newpass1` (n−1) | biên−1 | EC-cf-I1 | Từ chối vì không khớp | | FR03-BV-27 | `Newpass1!!` (n+1) | biên+1 | EC-cf-I1 | Từ chối vì không khớp | | FR03-BV-28 | `Newpass1!` (thêm khoảng trắng cuối) | biên+1 | EC-cf-I1 | Từ chối vì không khớp |

(Giá trị bằng nhau, n, đã có ở DT-07.)

3. Tham chiếu chéo với Domain Testing

Các giá trị biên đã nằm sẵn ở Domain Testing nên không lặp lại ở đây: DT-09/10 (OTP 5/7 chữ số, đại diện), DT-14 (lần dùng thứ 2 của OTP), DT-17 (mật khẩu 7 ký tự, đại diện), DT-18..21 (0 ký tự của từng loại), DT-22 (`#`). BV-03/05 và DT-09/10 khác nhau ở chỗ: BV-03/05 dùng giá trị sát biên của OTP seed `123456` (là tiền tố/mở rộng của OTP thật), nên phát hiện được cả lỗi khớp tiền tố; DT-09/10 chỉ là đại diện cho lớp.

4. Thống kê

- **28** test case BVA (BV-01..BV-28).
- Cùng 32 test Domain Testing → **60** test case thiết kế cho FR-03 (một số có thể bị trùng kết quả khi thực thi, tính theo ID).

5. Giới hạn

- Hệ thống thực sinh OTP 4 chữ số nên BV-04, BV-08 không thể thành công trên luồng thật; BV-04 chạy bằng OTP **seed** để kiểm tra riêng logic `reset-password`, BV-08 kiểm tra riêng bộ sinh OTP.
- Không có biên thời gian OTP và không có biên độ dài email vì SRS không nêu số liệu.

5.2 FR-10 Máy trạng thái đơn hàng (Pool B)

Oracle: SRS `README.md` (FR-10 dòng 141–162). Nhập từ `02_domain_testing.md`. FR-10 không có đại lượng số học nên "biên" ở đây gồm bốn loại: (a) ranh giới giữa trạng thái được và không được hủy trong chuỗi có thứ tự; (b) biên của ID đơn hàng; (c) độ dài/dạng chuỗi `status` sát giá trị hợp lệ; (d) biên của số lần lặp một thao tác. Dùng 3 giá trị tại mỗi biên (biên−1, biên, biên+1) khi có ý nghĩa.

1. Chọn đại lượng có thứ tự và biên theo spec

Đại lượng	Thứ tự / miền theo spec	Biên	Đóng/Mở	Giá trị kiểm thử	Nguồn
Vị trí trạng thái trong chuỗi `pending(0) < confirmed(1) < shipping(2) < delivered(3)` — **User được hủy**	chỉ vị trí 0–1	giữa 1 và 2	đóng ở 1	pending (min), confirmed (max cho phép), shipping (biên+1), delivered	FR-10 dòng 150–161
Khoảng cách chuyển trạng thái (số bước tiến)	chỉ +1 hợp lệ	+1	đóng	−2, −1 (ngược), +1, +2, +3 (bỏ bước)	FR-10 sơ đồ
ID đơn hàng	các ID có trong DB: 1..N (N = đơn mới nhất)	1 và N	đóng	0, −1, **1**, **N**, **N+1**, `abc`, `1.5`, 9223372036854775808	FR-10 / API 6.2
Chuỗi `status` hợp lệ `confirmed` (9 ký tự)	đúng 1 giá trị	độ dài 9	đóng	`confirme` (8), `confirmed` (9), `confirmedd` (10), có khoảng trắng đầu/cuối	FR-10 dòng 143–156
Số lần hủy cùng một đơn	tối đa 1 lần (sau đó là trạng thái cuối)	1	đóng	lần 1, lần 2	FR-10 dòng 160
Số bước trong chuỗi tiến tới trạng thái cuối	3 bước (`pending→confirmed→shipping→delivered`)	3	đóng	bước 1–3 thành công, bước thứ 4 bị từ chối	FR-10 dòng 145–160

2. Test case BVA

Điều kiện chung: trước nhóm này, xóa bảng `orders` và tạo 3 đơn `pending` mới cho `test@eshop.com` để có ID **1, 2, 3** (N = 3, N+1 = 4); các test cần đơn riêng thì tạo thêm đơn mới và dùng ID của nó. Người gọi là Admin (`admin@eshop.com`) trừ khi nói khác.

2.1 ID đơn hàng (`PUT /api/admin/orders/:id/status`, body `{"status":"confirmed"}`)

TC ID	`:id`	Vị trí so với biên	Expected (theo spec)
FR10-BV-01	`0`	biên−1 (dưới ID nhỏ nhất)	404 Order not found
FR10-BV-02	`-1`	cực trị thấp	404
FR10-BV-03	`1`	**biên** (ID nhỏ nhất, đang `pending`)	Chấp nhận, đơn 1 = confirmed
FR10-BV-04	`3` (= N)	**biên** (ID lớn nhất, đang `pending`)	Chấp nhận, đơn 3 = confirmed
FR10-BV-05	`4` (= N+1)	biên+1	404
FR10-BV-06	`abc`	sai kiểu	404 (không phải 500), server sống
FR10-BV-07	`1.5`	sai kiểu	404, không đổi đơn nào
FR10-BV-08	`9223372036854775808`	cực trị cao	404, không lỗi server

2.2 ID đơn hàng trên API User hủy (`PUT /api/orders/:id/cancel`, token chủ đơn)

TC ID	`:id`	Vị trí so với biên	Expected (theo spec)
FR10-BV-09	`0`	biên−1	404
FR10-BV-10	N+1	biên+1	404

2.3 Chuỗi tiến tới trạng thái cuối và số lần lặp

TC ID	Kịch bản	Vị trí so với biên	Expected (theo spec)
FR10-BV-11	Đơn mới: `pending→confirmed→shipping→delivered` (3 bước), rồi thử bước thứ 4 `delivered→canceled`	bước 3 = biên; bước 4 = biên+1	3 bước đầu thành công; bước 4 bị từ chối, vẫn `delivered`
FR10-BV-12	User hủy đơn `pending` của mình hai lần liên tiếp	lần 1 = biên; lần 2 = biên+1	Lần 1 thành công; lần 2 bị từ chối (đã là trạng thái cuối)

2.4 Chuỗi `status` sát giá trị hợp lệ (đơn `pending`)

TC ID	`status`	Vị trí so với biên	Expected (theo spec)
FR10-BV-13	`confirme` (8 ký tự)	độ dài−1	Từ chối, không đổi
FR10-BV-14	`confirmed` (9 ký tự)	**biên**	Chấp nhận, = confirmed
FR10-BV-15	`confirmedd` (10 ký tự)	độ dài+1	Từ chối, không đổi
FR10-BV-16	`confirmed` (khoảng trắng đầu)	sát biên	Từ chối, không đổi
FR10-BV-17	`confirmed` (khoảng trắng cuối)	sát biên	Từ chối, không đổi

3. Tham chiếu chéo với Domain Testing

Các biên còn lại đã có ở `02_domain_testing.md`, không lặp lại:

- **Ranh giới hủy của User** (vị trí 0, 1, 2, 3): DT-26 (pending), DT-27 (confirmed), **DT-28 (shipping = biên+1)**, DT-29 (delivered), DT-30 (canceled); trên UI: DT-49..DT-53.
- **Khoảng cách bước chuyển:** +1 hợp lệ: DT-02, 08, 14; **+2 (bỏ bước):** DT-03 (pending→shipping), DT-09 (confirmed→delivered); **+3:** DT-04 (pending→delivered); **−1 / −2 (ngược):** DT-06, DT-11, DT-12, DT-17, DT-18, DT-21..DT-23.
- **Giá trị `status` sai kiểu/định dạng:** DT-37..DT-41 (rỗng, lạ, sai hoa/thường, null, số).

4. Thống kê

- **17** test case BVA (BV-01..BV-17).
- Cùng 54 test Domain Testing → **71** test case thiết kế cho FR-10.

5. Giới hạn

- ID `1.5` và `9223372036854775808` kiểm tra khả năng chịu lỗi của truy vấn (tham số SQL); spec không nêu hành vi cụ thể nên expected chỉ ở mức "không lỗi server, không đổi dữ liệu".
- Không có biên thời gian hay số tiền nào liên quan trực tiếp tới FR-10 trong SRS.

5.3 FR-16 Import sản phẩm từ CSV (Pool C)

Oracle: SRS `README.md` (FR-16 dòng 200–211, FR-15 dòng 195–197 để tham chiếu độ dài tên). Nhập từ `02_domain_testing.md`. Kỹ thuật: 3 giá trị tại mỗi biên (biên−1, biên, biên+1), kèm cực trị khi SRS không nêu giới hạn.

1. Chọn đại lượng có thứ tự và biên theo spec

Đại lượng	Miền theo spec	Biên	Đóng/Mở	Giá trị kiểm thử	Nguồn
Số dòng dữ liệu của file	≥ 1 (file phải có dữ liệu để import)	1	đóng	0 (header-only, DT-10), **1**, **2**, 100, 1000 (không nêu tối đa)	FR-16 dòng 202
Số trường mỗi dòng	đúng 5 (khớp header)	5	đóng	**4** (n−1), 5, **6** (n+1)	FR-16 dòng 205
Giá `price`	số dương (> 0)	0	**mở** (`> 0`)	−1 (DT-19), 0 (DT-20), **1**, **0.01**, cực trị 2147483647, 2147483648, 9223372036854775808	FR-16 dòng 209
Độ dài `name`	không rỗng (≥ 1); tối đa 255 theo FR-15 (diễn giải)	1 và 255	đóng	0 (DT-17), **1**, **255**, **256**	FR-16 dòng 208; FR-15 dòng 195
Vị trí dòng lỗi trong file	bất kỳ dòng nào lỗi → hủy toàn bộ	dòng 1 và dòng N	đóng	N=1 (dòng đầu = dòng cuối), N=2 dòng 2 lỗi, N=100 dòng 100 lỗi, N=1000 dòng 1000 lỗi	FR-16 dòng 210
Số thứ tự dòng trong báo cáo lỗi	dòng 1 là header, dòng dữ liệu đầu là dòng 2	2 và N+1	đóng	lỗi ở dòng dữ liệu đầu, ở dòng dữ liệu cuối	FR-16 dòng 211
Kích thước request	spec không nêu giới hạn	—	—	~100 dòng (nhỏ), ~1000 dòng (lớn; có thể vượt giới hạn body mặc định 100 KB của `body-parser`)	FR-16 dòng 202 ("nhiều sản phẩm")

Ghi chú: các biên 0 dòng, giá −1/0, tên rỗng, 1 dòng lỗi đầu/giữa/cuối đã có ở Domain Testing (tham chiếu bên dưới), BVA chỉ thêm các giá trị mới.

2. Test case BVA

Điều kiện chung: Admin đã đăng nhập; mỗi test đếm số sản phẩm trước/sau; tên SP test có tiền tố `FR16-`; dọn dẹp sau mỗi test. Dòng "hợp lệ" mặc định: `FR16-<n>,100000,Mô tả sản phẩm test dòng <n>,https://placehold.co/300,1`.

2.1 Số dòng dữ liệu

TC ID	Số dòng hợp lệ	Vị trí so với biên	Expected (theo spec)	Lớp chạy
FR16-BV-01	1	**biên** (min)	Import 1/1, DB +1	UI+API
FR16-BV-02	2	biên+1	Import 2/2, DB +2	UI+API
FR16-BV-03	100	giá trị lớn vừa	Import 100/100, DB +100	UI+API
FR16-BV-04	1000	cực trị cao	Import 1000/1000, DB +1000 (SRS không nêu giới hạn); nếu bị từ chối thì phải có thông báo rõ ràng, DB không đổi	API

2.2 Số trường mỗi dòng (UI, một dòng dữ liệu)

TC ID	Dữ liệu dòng	Vị trí so với biên	Expected (theo spec)	Lớp chạy
FR16-BV-05	`FR16-X,100000,Mô tả,https://placehold.co/300` (4 trường, thiếu `category_id`)	n−1	File không hợp lệ (RFC 4180: mỗi dòng cùng số trường), từ chối, DB không đổi	UI
FR16-BV-06	`FR16-X,100000,Mô tả,https://placehold.co/300,1,thua` (6 trường)	n+1	Từ chối, DB không đổi	UI

2.3 Giá

TC ID	`price`	Vị trí so với biên	Expected (theo spec)	Lớp chạy
FR16-BV-07	`1`	biên+1 (số nguyên dương nhỏ nhất)	Chấp nhận	UI+API
FR16-BV-08	`0.01`	sát biên mở 0	Chấp nhận (số dương)	UI+API
FR16-BV-09	`2147483647`	cực trị ($2^{31}-1$)	Chấp nhận, lưu đúng giá trị	API
FR16-BV-10	`2147483648`	cực trị (2^{31})	Chấp nhận (SRS không nêu tối đa), lưu đúng giá trị	API

TC ID	`price`	Vị trí so với biên	Expected (theo spec)	Lớp chạy
FR16-BV-11	`9223372036854775808` (2^{63})	cực trị	Không lỗi server; hoặc từ chối rõ ràng, hoặc lưu đúng; không được lưu giá trị sai	API

2.4 Độ dài `name` (diễn giải FR-15 cho 256)

TC ID	Độ dài	Vị trí so với biên	Expected	Lớp chạy
FR16-BV-12	1 ký tự	**biên** (min)	Chấp nhận	UI+API
FR16-BV-13	255 ký tự	**biên** (max theo FR-15)	Chấp nhận	UI+API
FR16-BV-14	256 ký tự	biên+1	Từ chối (diễn giải FR-15), DB không đổi	UI+API

2.5 Vị trí dòng lỗi (lỗi `price = -1`) và số dòng trong báo cáo

TC ID	Cấu hình	Vị trí so với biên	Expected (theo spec)	Lớp chạy
FR16-BV-15	1 dòng dữ liệu và dòng đó lỗi	dòng đầu = dòng cuối	Không thêm gì; báo lỗi dòng 2	UI+API
FR16-BV-16	2 dòng dữ liệu, dòng thứ 2 lỗi	biên (dòng cuối của N=2)	Không thêm gì (dòng 1 hợp lệ cũng không được lưu); báo lỗi dòng 3	UI+API
FR16-BV-17	100 dòng, chỉ dòng 100 lỗi	dòng cuối	Không thêm dòng nào (99 dòng hợp lệ cũng bị hủy); báo lỗi dòng 101	UI+API
FR16-BV-18	1000 dòng, chỉ dòng 1000 lỗi	cực trị	Không thêm dòng nào; báo lỗi dòng 1001 (hoặc từ chối toàn bộ rõ ràng)	API
FR16-BV-19	3 dòng, dòng dữ liệu **đầu tiên** lỗi	dòng đầu	Báo lỗi **dòng 2** (dòng 1 là header)	UI+API

3. Tham chiếu chéo với Domain Testing

Các biên còn lại đã có ở `02_domain_testing.md`, không lặp lại: 0 dòng dữ liệu (DT-10, DT-09, DT-11), `price` −1 (DT-19) và 0 (DT-20), `name` rỗng (DT-17), 1 dòng lỗi ở đầu/giữa/cuối của file 3 dòng (DT-25..27), nhiều dòng lỗi (DT-28), tất cả dòng lỗi (DT-29).

4. Thống kê

- **19** test case BVA (BV-01..BV-19).
- Cùng 43 test Domain Testing → **62** test case thiết kế cho FR-16.

5. Giới hạn

- BV-04, BV-18 (1000 dòng) kiểm tra khả năng xử lý dữ liệu lớn và giới hạn kích thước body; SRS không nêu số dòng tối đa nên expected chỉ ở mức "import đủ hoặc từ chối rõ ràng, không mất/hỏng dữ liệu".
- BV-09..BV-11 không có biên theo spec (không nêu giá tối đa); mục đích là phát hiện lỗi tràn/lưu sai giá trị.

- BV-14 (256 ký tự) là diễn giải từ FR-15; nếu lệch ghi "theo diễn giải".

5.4 Mobile FR-08/09 Thanh toán & mã giảm giá trên Mobile (Pool D)

Oracle: SRS `README.md` (FR-08 dòng 102–108; FR-09 dòng 110–135). Nhập từ `02_domain_testing.md`. Kỹ thuật: 3 giá trị tại mỗi biên (biên−1, biên, biên+1); nêu rõ biên đóng/mở.

1. Chọn đại lượng có thứ tự và biên theo spec

Đại lượng	Miền theo spec	Biên	Đóng/Mở	Giá trị kiểm thử	Nguồn
Tổng đơn so với `min_order_amount` (C3)	Tổng ≥ ngưỡng	ngưỡng của mã (`SAVE10` 300,000; `BIGBUY` 500,000)	**đóng** (`>=`)	ngưỡng−1, ngưỡng, ngưỡng+1	FR-09 dòng 118
Ngày hiện tại so với `expired_at` (C2)	hiện tại **trước** `expired_at`	`expired_at`	**mở** (`<`)	hôm qua, hôm nay, ngày mai (kiểu ngày); now−1 phút, now+1 phút (kiểu ngày giờ)	FR-09 dòng 117
Số lần đã dùng so với `max_uses_per_user` (C5)	đã dùng **<** giới hạn	`max`	mở (`<`)	`max-1`, `max` (và 0); `VIP100` có max = 2	FR-09 dòng 120
Tổng đơn so với giá trị giảm cố định D	`final = total - D`	tổng = D	—	D−1, D, D+1 (tổng thanh toán không âm: diễn giải)	FR-09 dòng 125–126
Giảm theo phần trăm	`total × value / 100`	value = 100 (giảm hết)	đóng	100%	FR-09 dòng 124
Phần thập phân của giảm %	số nguyên tiền	tổng = 9, 10 với 10%	—	9 (0.9), 10 (1.0)	FR-09 dòng 124
Số sản phẩm trong giỏ (điều kiện `cart.length > 1` trong code)	hiển thị/gửi đầy đủ sản phẩm	1 và 2	—	1, 2 (và 3 ở DT-31)	FR-08 dòng 106
Độ dài mã giảm giá	spec không nêu	—	—	1000 ký tự (cực trị, kiểm tra chịu lỗi)	—

Ghi chú: các mã `SAVE10` và `BIGBUY` có ngưỡng khác nhau nên mỗi mã có đủ bộ 3 giá trị. Các mã có hạn/giảm cố định/phần trăm đặc biệt được tạo bằng `POST /api/admin/coupons` (API này không kiểm tra role nên dùng được để chuẩn bị dữ liệu).

2. Test case BVA

Điều kiện chung: user `test@eshop.com` đã đăng nhập; `coupon_usage` của user được xóa trước mỗi test (trừ khi nói khác); tổng đơn truyền cho `POST /api/apply-coupon` đúng bằng giá trị nêu, và nhóm test UI dùng sản phẩm tạo riêng để có tổng đúng.

2.1 Ngưỡng đơn tối thiểu (C3, đóng)

TC ID	Mã	Tổng đơn	Vị trí so với biên	Expected (theo spec)	Lớp chạy
MFR-BV-01	`SAVE10`	299,999	ngưỡng−1	Từ chối (chưa đủ ngưỡng)	UI+API

TC ID	Mã	Tổng đơn	Vị trí so với biên	Expected (theo spec)	Lớp chạy
MFR-BV-02	`SAVE10`	300,000	**ngưỡng**	Chấp nhận: discount 30,000; final 270,000	UI+API
MFR-BV-03	`SAVE10`	300,001	ngưỡng+1	Chấp nhận: discount ≈ 30,000; final ≈ 270,001	API
MFR-BV-04	`BIGBUY`	499,999	ngưỡng−1	Từ chối	API
MFR-BV-05	`BIGBUY`	500,000	**ngưỡng**	Chấp nhận: discount 50,000; final 450,000	API
MFR-BV-06	`BIGBUY`	500,001	ngưỡng+1	Chấp nhận: discount 50,000; final 450,001	API

2.2 Hạn dùng (C2, mở: hiện tại phải trước `expired_at`)

Tạo mã `fixed` 10,000, min 0, với `expired_at` như sau; gọi `apply-coupon` với tổng 100,000. | TC ID | `expired_at` | Vị trí so với biên | Expected (theo spec) | Lớp chạy | |---|---|---|---|---| | MFR-BV-07 | ngày hôm qua (kiểu ngày) | trước biên | Từ chối (hết hạn) | API | | MFR-BV-08 | ngày hôm nay (kiểu ngày) | **biên** | Từ chối (hiện tại không "trước" `expired_at`) | API | | MFR-BV-09 | ngày mai (kiểu ngày) | sau biên | Chấp nhận | API | | MFR-BV-10 | giờ hiện tại − 1 phút (ISO ngày giờ) | biên−1 | Từ chối | API | | MFR-BV-11 | giờ hiện tại + 1 phút (ISO ngày giờ) | biên+1 | Chấp nhận | API |

2.3 Số lần dùng (C5, mở: đã dùng < max)

`VIP100` có `max_uses_per_user = 2`; lượt dùng được ghi bằng `POST /api/coupon-usage` (token user). Tổng đơn 400,000. | TC ID | Số lần đã dùng | Vị trí so với biên | Expected (theo spec) | Lớp chạy | |---|---|---|---|---| | MFR-BV-12 | 0 | dưới `max-1` | Chấp nhận | API | | MFR-BV-13 | 1 | **`max-1`** | Chấp nhận | API | | MFR-BV-14 | 2 | **`max`** | Từ chối (đã dùng đủ lượt) | API |

2.4 Giảm giá so với tổng đơn

Mã `fixed` D = 100,000, min 0 (`FRM-FIX100K`). | TC ID | Tổng đơn | Vị trí so với biên | Expected (diễn giải: tổng thanh toán không âm) | Lớp chạy | |---|---|---|---|---| | MFR-BV-15 | 99,999 | D−1 | `final_amount ≥ 0` (tức 0) | API | | MFR-BV-16 | 100,000 | **D** | `discount = 100,000`; `final = 0` | API | | MFR-BV-17 | 100,001 | D+1 | `discount = 100,000`; `final = 1` | API | | MFR-BV-18 | 1,000 (mã `percent` 100%, min 0) | giảm 100% | `discount = 1,000`; `final = 0` | API | | MFR-BV-19 | 9 (mã `percent` 10%, min 0) | phần lẻ 0.9 | `discount` = 0 hoặc 1 nhất quán (spec không nêu làm tròn); `final = total − discount`, số nguyên, ≥ 0 | API | | MFR-BV-20 | 10 (mã `percent` 10%, min 0) | phần lẻ 1.0 | `discount = 1`; `final = 9` | API |

2.5 Số sản phẩm trong giỏ và độ dài mã

TC ID	Kịch bản	Vị trí so với biên	Expected (theo spec)	Lớp chạy
MFR-BV-21	Giỏ 1 sản phẩm, xác nhận thanh toán; quan sát request	`cart.length = 1`	Request chứa đủ 1 sản phẩm	UI
MFR-BV-22	Giỏ 2 sản phẩm, xác nhận thanh toán; quan sát request	`cart.length = 2` (n+1)	Request chứa đủ 2 sản phẩm	UI

TC ID	Kịch bản	Vị trí so với biên	Expected (theo spec)	Lớp chạy
MFR-BV-23	Mã giảm giá dài 1000 ký tự	cực trị	Từ chối như mã không tồn tại; không lỗi server	API

3. Tham chiếu chéo với Domain Testing

Các biên còn lại đã có ở `02_domain_testing.md`: tổng nhỏ hơn ngưỡng (DT-20, DT-21), mã hết hạn (DT-18, DT-19), mã đã dùng hết lượt (DT-23, DT-24), giỏ 3 sản phẩm (DT-31), `fixed` lớn hơn tổng (DT-26), `percent` có phần lẻ (DT-25).

4. Thống kê

- **23** test case BVA (BV-01..BV-23).
- Cùng 40 test Domain Testing → **63** test case thiết kế cho Mobile FR-08/09.

5. Giới hạn

- BV-07..BV-11: múi giờ; `expired_at` kiểu ngày bị `new Date()` phân tích theo UTC, nên "hôm nay" tính theo ngày UTC; ghi múi giờ máy test (UTC+7) khi kết luận.
- BV-15..BV-20 dựa trên diễn giải "tổng thanh toán không âm" và "làm tròn nhất quán"; nếu lệch ghi "theo diễn giải".
- BV-21, BV-22 chỉ khả thi trên UI (quan sát request gửi đi bằng cách bọc `fetch` trong trình duyệt).

6. Kết quả thực thi

6.1 FR-03 Quên & đặt lại mật khẩu (Pool A)

- **Ngày chạy:** 2026-10-16 (giờ máy: ~13:25–13:40, tương ứng 06:25–06:40 UTC trong log).
- **Môi trường:** Windows 11, Node v22.20.0, backend `localhost:3000`, web `localhost:5173` (Vite) trong trình duyệt tích hợp của Claude desktop; dữ liệu seed gốc của repo.
- **Cách chạy:**
  - **API:** `evidence/run_api_tests.js` (HTTP thật tới backend; chỉ dùng DB để reset/seed trạng thái và để kiểm chứng mật khẩu có đổi hay không). Kết quả thô: `evidence/api_results.json`.
  - **UI:** thao tác trên form `/forgot-password` bằng script trong trình duyệt (set giá trị input theo cách React nhận biết rồi bấm nút submit thật; `alert()` được ghi lại thay vì hiện hộp thoại). Kết quả UI được ghi trong bảng dưới. Ảnh: `evidence/step1_forgot_password_ui.jpg`, `evidence/step2_reset_form_ui.jpg`.
  - Với các test mật khẩu trên UI, dùng **OTP sai (`0000`)** để không làm đổi dữ liệu: nếu UI chấp nhận mật khẩu thì request được gửi và server trả "Mã OTP không đúng"; nếu UI từ chối thì xuất hiện thông báo "Mật khẩu quá yếu".
- **Quy ước kết quả tổng:** `Fail` nếu **bất kỳ** lớp đã chạy (UI hoặc API) lệch spec.

1. Kết quả theo test case

Ký hiệu: ✓ = đúng spec, ✗ = lệch spec, — = không áp dụng/không chạy.

Domain Testing

TC ID	UI	API	Kết quả	Actual tóm tắt	Bug
FR03-DT-01	✗	✗	**Fail**	OTP sinh ra là **4 chữ số** (`4543`, `7523`...), nhãn "Mã OTP (4 số)"	BUG-01
FR03-DT-02	✓ (HTML `required` chặn)	✓ 404	Pass	Không cấp OTP	
FR03-DT-03	✓	✓ 404	Pass	Bị từ chối nhưng báo "User not found" (không nêu sai định dạng); ô email `type=text` nên không validate định dạng	BUG-07 (liên quan)
FR03-DT-04	✓	✓ 404	Pass	"User not found" — lộ việc email chưa đăng ký (quan sát, không tính bug)	
FR03-DT-05	✓	✓ 404	Pass	`" "` bị coi như email không tồn tại	
FR03-DT-06	✓	✓	Pass	Không lỗi server, không cấp OTP cho user nào	
FR03-DT-07	✗	—	**Fail**	Với mật khẩu hợp lệ theo spec `Newpass1!` UI báo "Mật khẩu quá yếu" → không hoàn tất được. Chỉ hoàn tất được khi dùng mật khẩu **có khoảng trắng** (`New pass1`): đổi thành công, về `/login`, đăng nhập mật khẩu mới OK, mật khẩu cũ bị từ chối	BUG-02
FR03-DT-08	✓ (`required`)	✓ 400	Pass		
FR03-DT-09	✓	✓ 400	Pass		
FR03-DT-10	✓	✓ 400	Pass		
FR03-DT-11	✓	✓ 400	Pass		
FR03-DT-12	✓	✓ 400	Pass		
FR03-DT-13	—	✓ 400	Pass	OTP của B không đổi được mật khẩu A	
FR03-DT-14	—	✓	Pass	Lần 1 thành công (200); lần 2 bị từ chối (400), mật khẩu không đổi	
FR03-DT-15	—	(chờ)	(xem mục 3)	OTP hết hạn	
FR03-DT-16	✓ (`required`)	✗	**Fail**	API chấp nhận `newPassword = ""` (HTTP 200, mật khẩu bị đổi thành rỗng)	BUG-03
FR03-DT-17	✓	✗	**Fail**	API chấp nhận `Ab1!xyz`	BUG-03
FR03-DT-18	✓	✗	**Fail**	API chấp nhận `newpass1!`	BUG-03
FR03-DT-19	✓	✗	**Fail**	API chấp nhận `NEWPASS1!`	BUG-03

TC ID	UI	API	Kết quả	Actual tóm tắt	Bug
FR03-DT-20	✓	✗	**Fail**	API chấp nhận `Newpass!!`	BUG-03
FR03-DT-21	✓	✗	**Fail**	API chấp nhận `Newpass12`	BUG-03
FR03-DT-22	✓	✗	**Fail**	API chấp nhận `Newpass1#` (diễn giải chặt)	BUG-03
FR03-DT-23	✗	—	**Fail**	Không có trường Xác nhận mật khẩu; không thể test	BUG-04
FR03-DT-24	✗	—	**Fail**	Như trên	BUG-04
FR03-DT-25	✗	—	**Fail**	Như trên	BUG-04
FR03-DT-26	✗	—	**Fail**	Bước 1 không có "Bước 1 / 2"	BUG-05
FR03-DT-27	✗	—	**Fail**	Bước 2 không có "Bước 2 / 2"	BUG-05
FR03-DT-28	✗	—	**Fail**	Không có nút "Quay lại đăng nhập"; chỉ có "← Quay lại" (về bước 1) ở bước 2	BUG-06
FR03-DT-29	✗	—	**Fail**	`input type="text"`	BUG-07
FR03-DT-30	✗	—	**Fail**	Nhãn không có `*`	BUG-08
FR03-DT-31	✗	—	**Fail**	Lỗi hiển thị bằng `alert()` của trình duyệt, không có vùng lỗi phía trên nút submit	BUG-09
FR03-DT-32	✓	—	Pass	Ô mật khẩu mới `type="password"`	

BVA

TC ID	UI	API	Kết quả	Actual tóm tắt	Bug
FR03-BV-01	✓	✓	Pass	OTP rỗng bị từ chối	
FR03-BV-02	✓	✓	Pass	1 chữ số bị từ chối	
FR03-BV-03	✓	✓	Pass	5 chữ số bị từ chối	
FR03-BV-04	—	✓	Pass	OTP seed `123456` được chấp nhận (logic `reset-password` khớp đúng 6 chữ số)	
FR03-BV-05	✓	✓	Pass	7 chữ số bị từ chối	
FR03-BV-06	—	✓	Pass	`012345` được chấp nhận (số 0 đầu)	

TC ID	UI	API	Kết quả	Actual tóm tắt	Bug
FR03-BV-07	—	✓	Pass	`12345` (mất số 0 đầu) bị từ chối	
FR03-BV-08	—	✗	**Fail**	20 OTP sinh ra đều dài 4; giá trị từ 1001 đến 9316 (không bao giờ có OTP bắt đầu bằng 0 hay đủ 6 chữ số)	BUG-01
FR03-BV-09	✓	✗	**Fail**	API chấp nhận mật khẩu 7 ký tự	BUG-03
FR03-BV-10	✗	✓	**Fail**	UI từ chối mật khẩu 8 ký tự hợp lệ; API chấp nhận	BUG-02
FR03-BV-11	✗	✓	**Fail**	UI từ chối 9 ký tự hợp lệ	BUG-02
FR03-BV-12	✗	✓	**Fail**	UI từ chối 256 ký tự hợp lệ; API chấp nhận	BUG-02
FR03-BV-13	✗	✓	**Fail**	UI từ chối (đúng 1 chữ hoa)	BUG-02
FR03-BV-14	✗	✓	**Fail**	UI từ chối (đúng 1 chữ thường)	BUG-02
FR03-BV-15	✗	✓	**Fail**	UI từ chối (đúng 1 chữ số)	BUG-02
FR03-BV-16	✗	✓	**Fail**	UI từ chối (đúng 1 ký tự đặc biệt)	BUG-02
FR03-BV-17	✗	✓	**Fail**	UI từ chối khi ký tự đặc biệt là `@`	BUG-02
FR03-BV-18	✗	✓	**Fail**	`$`	BUG-02
FR03-BV-19	✗	✓	**Fail**	`!`	BUG-02
FR03-BV-20	✗	✓	**Fail**	`%`	BUG-02
FR03-BV-21	✗	✓	**Fail**	`*`	BUG-02
FR03-BV-22	✗	✓	**Fail**	`?`	BUG-02
FR03-BV-23	✗	✓	**Fail**	`&`	BUG-02
FR03-BV-24	✓	✗	**Fail**	API chấp nhận `+` (diễn giải chặt)	BUG-03
FR03-BV-25	✓	✗	**Fail**	API chấp nhận `"` (diễn giải chặt)	BUG-03
FR03-BV-26	✗	—	**Fail**	Không có trường xác nhận	BUG-04
FR03-BV-27	✗	—	**Fail**	Như trên	BUG-04
FR03-BV-28	✗	—	**Fail**	Như trên	BUG-04

2. Quan sát thêm (không tính vào số bug chính)

- OTP được trả thẳng trong response của `forgot-password` (đúng với môi trường demo của spec, nhưng không có bước gửi email).
- `forgot-password` trả 404 "User not found" cho email chưa đăng ký → có thể liệt kê email đã đăng ký.
- OTP sinh bằng `Math.random()` (không phải nguồn ngẫu nhiên an toàn mật mã).
- `reset-password` không kiểm tra thời hạn; mật khẩu lưu plaintext (ngoài phạm vi FR-03).

3. Test hết hạn OTP (FR03-DT-15)

- Cấp OTP cho một user riêng (`userc@eshop.com`, không bị các test khác reset), chờ **5,5 phút**, rồi gọi `reset-password`: **HTTP 200, mật khẩu bị đổi** → OTP vẫn dùng được → **Fail** (`BUG-10`).
- Hạn chế: SRS (SEC-07) chỉ nói "có thời hạn", không nêu số phút. Kết luận dựa trên cả quan sát (5,5 phút vẫn hợp lệ) lẫn code: bảng `users` chỉ có cột `reset_token`, không có thời điểm tạo/hết hạn, và `reset-password` không kiểm tra thời gian (`database.js:50-61`, `server.js:87-98`).
- Lần chạy đầu tiên của test này (sau ~12 giây) bị **loại bỏ** vì quá sớm, không đại diện cho "đã hết hạn" (xem `05_ai_gap.md`, bài học về kiểm tra tiền đề thời gian). Log: `evidence/expiry_run.log`.

4. Test khám phá thêm sau khi chạy (`added-after-run`)

Mục đích: khoanh vùng lỗi xử lý đầu vào của API (X-01..X-04) và kiểm tra các thuộc tính ngoài miền một input (X-05..X-07, được thêm khi làm gap analysis). Không có bug mới; X-05 và X-06 ghi là quan sát. | ID | Request | Kết quả | |---|---|---| | X-01 | `forgot-password` không có `email` | 404 "User not found", server vẫn sống | | X-02 | `reset-password` không có `resetToken` | 400 "Invalid token or email" | | X-03 | `resetToken` là object | 400, server vẫn sống | | X-04 | `resetToken: null` | 400 | | X-05 | 300 lần đoán OTP sai liên tiếp (`reset-password`) | 300 × HTTP 400, không khóa/làm chậm (quan sát: không giới hạn số lần đoán) | | X-06 | `forgot-password` với `TEST@ESHOP.COM` | 404: email phân biệt hoa/thường (SRS không nêu) | | X-07 | Xin OTP hai lần rồi dùng OTP cũ | 400: OTP cũ bị vô hiệu khi cấp OTP mới (hợp lý) |

5. Thống kê FR-03

Hạng mục	Số lượng
Test case thiết kế	**60** (32 Domain Testing + 28 BVA)
Đã thực thi	60
Pass	20 (DT: 13, BV: 7)
Fail	40 (DT: 19, BV: 21)
Chưa thực thi	0
Bug phân biệt (nguyên nhân gốc)	**10** (BUG-01 … BUG-10, xem `06_bugs.md`)
Test khám phá thêm	7 (X-01..X-07), không có bug mới (X-05, X-06 là quan sát)

Nhiều test Fail cùng một nguyên nhân gốc (ví dụ 14 test BV từ BV-10 đến BV-23 đều do BUG-02), nên số bug nhỏ hơn nhiều so với số test Fail.

6.2 FR-10 Máy trạng thái đơn hàng (Pool B)

- **Ngày chạy:** 2026-10-16. **Môi trường:** Windows 11, Node v22.20.0, Backend `localhost:3000`, Web `localhost:5173`, Admin `localhost:5174` (trình duyệt tích hợp Claude desktop), dữ liệu seed gốc của repo.
- **Cách chạy:**
  - **API (60 kiểm tra: DT-01..43 và BV-01..17):** `evidence/run_api_tests.js` — gọi HTTP thật; DB chỉ dùng để xác minh trạng thái đơn đã lưu và xóa bảng `orders` trước nhóm BV ID (để ID là 1..3). Kết quả thô: `evidence/api_results.json`.
  - **UI (DT-44..54):** dùng `evidence/seed_ui_orders.js` tạo 5 đơn ở 5 trạng thái cho `test@eshop.com`; nạp token vào `localStorage` rồi thao tác trên trang thật (Web Admin tab Đơn hàng; Web `/profile`). `window.alert` được ghi lại để lấy nội dung. Kết quả thô: `evidence/ui_results.json`; ảnh: `admin_orders_ui_states.jpg`, `web_profile_orders_before.jpg`, `web_profile_cancel_shipping_after.jpg`.
- **Quy ước kết quả:** "từ chối" = HTTP ≥ 400 **và** trạng thái trong DB không đổi; "chấp nhận" = HTTP 200 **và** trạng thái đúng như đích.
- Lần chạy API đầu tiên có 8 test BV-01..08 báo Fail vì script quên gửi token Admin (401); đã sửa script và chạy lại toàn bộ — kết quả dưới đây là lần chạy sau.

1. Kết quả theo test case

Domain Testing

TC ID	Lớp chạy	Kết quả	Actual tóm tắt	Bug
FR10-DT-01 … DT-23	API	Pass	Mọi ô ma trận đúng spec: 4 ô hợp lệ (pending→confirmed, pending→canceled, confirmed→shipping, confirmed→canceled) chấp nhận; các ô không hợp lệ trả 400 và không đổi	
FR10-DT-24	API	**Fail**	`canceled → delivered`: HTTP 200, DB = `delivered` (spec: `canceled` là trạng thái cuối, phải từ chối)	BUG-01
FR10-DT-25	API	Pass	`canceled → canceled` bị từ chối	
FR10-DT-14	API	Pass	`shipping → delivered` chấp nhận (nằm trong DT-01..23)	
FR10-DT-15	API	Pass	`shipping → canceled` (Admin) bị từ chối — đúng theo diễn giải chặt	
FR10-DT-26	API	Pass	User hủy đơn `pending` thành công	
FR10-DT-27	API	Pass	User hủy đơn `confirmed` thành công	
FR10-DT-28	API	**Fail**	User hủy đơn `shipping`: HTTP 200, DB = `canceled` (spec: User không được hủy khi `shipping`)	BUG-03
FR10-DT-29	API	Pass	Hủy đơn `delivered` bị từ chối ("Cannot cancel this order.")	
FR10-DT-30	API	Pass	Hủy đơn `canceled` bị từ chối	

TC ID	Lớp chạy	Kết quả	Actual tóm tắt	Bug
FR10-DT-31	API	Pass	Admin API không token → 401, không đổi	
FR10-DT-32	API	Pass	Hủy không token → 401, không đổi	
FR10-DT-33	API	**Fail**	**Token của User thường** gọi `PUT /api/admin/orders/:id/status`: HTTP 200, đơn đổi sang `confirmed` (FR-12/SEC-03: phải kiểm tra `role=admin`)	BUG-05
FR10-DT-34	API	Pass	User B hủy đơn của User A → 404, đơn A không đổi	
FR10-DT-35	API	Pass	Admin API với id không tồn tại → 404	
FR10-DT-36	API	Pass	Hủy với id không tồn tại → 404	
FR10-DT-37 … DT-41	API	Pass	`status` rỗng/`refunded`/`CONFIRMED`/`null`/`123` đều bị từ chối 400, đơn không đổi	
FR10-DT-42	API	Pass	Chuỗi `pending→confirmed→shipping→delivered` thành công; sau `delivered` mọi chuyển tiếp bị từ chối	
FR10-DT-43	API	**Fail**	Hủy bởi User thành công, nhưng sau đó `canceled → delivered` (Admin) cũng thành công: HTTP 200, DB = `delivered`	BUG-01
FR10-DT-44	UI-Admin	Pass	`pending`: nút "Xác nhận", "Hủy"	
FR10-DT-45	UI-Admin	Pass	`confirmed`: nút "Giao hàng", "Hủy"	
FR10-DT-46	UI-Admin	Pass	`shipping`: nút "Hoàn thành"	
FR10-DT-47	UI-Admin	Pass	`delivered`: không có nút	
FR10-DT-48	UI-Admin	**Fail**	`canceled`: vẫn có nút **"Đánh dấu Đã giao"** (spec: trạng thái cuối, không có hành động)	BUG-02
FR10-DT-49	UI-Web	Pass	Đơn `pending`: có nút "Hủy đơn"	
FR10-DT-50	UI-Web	Pass	Đơn `confirmed`: có nút "Hủy đơn"	
FR10-DT-51	UI-Web	**Fail**	Đơn `shipping`: vẫn có nút "Hủy đơn"; bấm vào thì hủy thành công ("Hủy đơn thành công!", đơn #3 từ "Đang giao" sang "Đã hủy")	BUG-04 (và BUG-03)
FR10-DT-52	UI-Web	Pass	Đơn `delivered`: không có nút	
FR10-DT-53	UI-Web	Pass	Đơn `canceled`: không có nút	
FR10-DT-54	UI-Admin	**Fail**	Thao tác trên dữ liệu cũ: hiện `alert` "Lỗi: Invalid state transition from confirmed to confirmed" — **tiếng Anh**, lộ chi tiết kỹ thuật (FR-21 yêu cầu tiếng Việt)	BUG-06

BVA

TC ID	Lớp chạy	Kết quả	Actual tóm tắt	Bug
FR10-BV-01	API	Pass	id `0` → 404, không đơn nào đổi	
FR10-BV-02	API	Pass	id `-1` → 404	
FR10-BV-03	API	Pass	id `1` (nhỏ nhất) → 200, đơn 1 = confirmed	
FR10-BV-04	API	Pass	id `3` (lớn nhất) → 200, đơn 3 = confirmed	
FR10-BV-05	API	Pass	id `4` (N+1) → 404	
FR10-BV-06	API	Pass	id `abc` → 404, server sống	
FR10-BV-07	API	Pass	id `1.5` → 404, không đơn nào đổi	
FR10-BV-08	API	Pass	id `9223372036854775808` → 404	
FR10-BV-09	API	Pass	User hủy id `0` → 404	
FR10-BV-10	API	Pass	User hủy id N+1 → 404	
FR10-BV-11	API	Pass	3 bước tiến thành công; bước 4 (`delivered → canceled`) bị từ chối	
FR10-BV-12	API	Pass	Hủy lần 1 thành công; lần 2 bị từ chối	
FR10-BV-13	API	Pass	`confirme` bị từ chối	
FR10-BV-14	API	Pass	`confirmed` chấp nhận	
FR10-BV-15	API	Pass	`confirmedd` bị từ chối	
FR10-BV-16	API	Pass	`confirmed` (khoảng trắng đầu) bị từ chối	
FR10-BV-17	API	Pass	`confirmed` (khoảng trắng cuối) bị từ chối	

2. Quan sát thêm (không tính vào số bug của FR-10)

Phát hiện khi chạy, thuộc feature của thành viên khác trong nhóm; ghi lại để báo cho đúng người:

- **FR-13 (Dashboard):** doanh thu hiển thị **300,000 ₫** trong khi chỉ có một đơn `delivered` 150,000 ₫ (code nhân đôi `total_amount`, `App.jsx:218`). Ảnh: `evidence/observation_dashboard_revenue.jpg`.
- **FR-11 (Lịch sử đơn):** `GET /api/orders/1` **không cần token** vẫn trả đầy đủ thông tin đơn (HTTP 200) — ai cũng xem được đơn của người khác.
- **FR-18 (Quản lý đơn Admin):** địa chỉ giao hàng hiển thị bằng `dangerouslySetInnerHTML` (`App.jsx:799-804`), chưa kiểm chứng XSS vì ngoài phạm vi.
- Thông báo lỗi API cho chuyển không hợp lệ là tiếng Anh ("Invalid state transition from X to Y"); SRS chỉ yêu cầu "thông báo phù hợp", nên chỉ tính lỗi khi hiển thị thẳng trên UI (BUG-06).

3. Test khám phá thêm sau khi chạy (`added-after-run`)

ID	Kịch bản	Kết quả
X-01	60 lần: tạo đơn `pending`, gửi **đồng thời** "Admin xác nhận" và "User hủy" (`evidence/race_test.js`)	Cả hai request đều trả 200 ở cả 60 lần. Trạng thái cuối: `canceled` 59 lần, **`confirmed` 1 lần** → có lúc đơn đã bị User hủy rồi bị Admin "xác nhận" đè lên (đơn hủy bị hồi sinh), vi phạm "`canceled` là trạng thái kết thúc". Nguyên nhân: kiểm tra trạng thái (`SELECT`) và cập nhật (`UPDATE`) là hai bước riêng, `UPDATE` không có điều kiện theo trạng thái cũ (`server.js:528-562`). Ghi nhận là **BUG-07** (xác suất thấp). Kết quả thô: `evidence/race_result.json`.

4. Thống kê FR-10

Hạng mục	Số lượng
Test case thiết kế	**71** (54 Domain Testing + 17 BVA)
Đã thực thi	71
Pass	64 (DT: 47, BV: 17)
Fail	7 (DT: 7, BV: 0)
Chưa thực thi	0
Bug phân biệt (nguyên nhân gốc)	**7** (BUG-01 … BUG-07, xem `06_bugs.md`)
Test khám phá thêm	1 (X-01) — phát hiện BUG-07

6.3 FR-16 Import sản phẩm từ CSV (Pool C)

- **Ngày chạy:** 2026-10-16. **Môi trường:** Windows 11, Node v22.20.0, Backend `localhost:3000`, Web Admin `localhost:5174` (trình duyệt tích hợp Claude desktop), dữ liệu seed gốc (5 sản phẩm ban đầu).
- **Cách chạy:**
  - **API (39 kiểm tra):** `evidence/run_api_tests.js` — `POST /api/admin/import-products` với mảng JSON; đếm số sản phẩm trong DB trước/sau, xóa bản ghi do test tạo. Kết quả thô: `evidence/api_results.json`, phản hồi lỗi 500: `evidence/dt39_response.txt`.
  - **UI (≈ 45 file CSV thật):** gán file vào `<input type="file">` của Web Admin (tab Sản phẩm), đọc bảng xem trước, bấm nút Import thật, đọc thông báo, đếm sản phẩm trong DB rồi xóa. Kết quả: `evidence/ui_results.json`; ảnh: `evidence/ui_partial_import_green_banner.jpg`, `evidence/ui_quoted_comma_preview.jpg`.
- **Quy ước:** "từ chối/không import" = **số sản phẩm trong DB không đổi**; "chấp nhận N" = DB tăng đúng N. Kết quả tổng là **Fail** nếu bất kỳ lớp đã chạy (UI hoặc API) lệch spec.
- **Chạy lại có chủ ý:** (1) lần chạy đầu của DT-02 trên UI bị loại vì bảng xem trước chưa kịp cập nhật nên import nhầm dữ liệu của test trước; chạy lại có chờ bảng xem trước khớp nội dung rồi mới bấm. (2) BV-18 lần đầu bị lỗi 413 (payload 131 KB) nên chưa kiểm được rollback 1000 dòng; chạy lại với dòng gọn (~80 KB).

1. Kết quả theo test case

Domain Testing

TC ID	Lớp chạy	Kết quả	Actual tóm tắt	Bug
FR16-DT-01	UI	Pass	3 dòng hợp lệ → "Import hoàn tất: 3/3", DB +3	
FR16-DT-02	UI	**Fail**	Tên có dấu phẩy trong nháy kép bị cắt: lưu `name="FR16-Áo`, `price=size M"`, `description=100000` (ảnh `ui_quoted_comma_preview.jpg`)	BUG-03
FR16-DT-03	UI	**Fail**	`""` không được bỏ escape: tên lưu `"FR16-Màn hình 27"" IPS"` (còn nguyên nháy kép)	BUG-03
FR16-DT-04	UI	Pass	CRLF xử lý đúng, tên/giá không chứa `\r`	

TC ID	Lớp chạy	Kết quả	Actual tóm tắt	Bug
FR16-DT-05	UI	Pass	Tên tiếng Việt lưu đúng	
FR16-DT-06	UI+API	Pass	Giá `0.5` được chấp nhận	
FR16-DT-07	UI	**Fail**	File `.txt` vẫn import được (DB +2); ô chọn file không có `accept`	BUG-04
FR16-DT-08	UI	**Fail**	File `.xlsx` (nội dung CSV) vẫn import được (DB +2)	BUG-04
FR16-DT-09	UI	Pass	File rỗng → nút Import bị vô hiệu, DB không đổi	
FR16-DT-10	UI	Pass	Chỉ header → nút vô hiệu	
FR16-DT-11	UI	Pass	Chỉ khoảng trắng → nút vô hiệu	
FR16-DT-12	UI	**Fail**	Header sai thứ tự vẫn import (DB +1), không kiểm tra header	BUG-05
FR16-DT-13	UI	**Fail**	Thiếu cột `price` vẫn import (DB +1)	BUG-05
FR16-DT-14	UI	**Fail**	Thừa cột `sku` vẫn import (DB +1)	BUG-05
FR16-DT-15	UI	**Fail**	Header `Name,Price,...` (sai hoa/thường) vẫn import (DB +1)	BUG-05
FR16-DT-16	UI	Pass	Không có header: dòng đầu bị coi là header, DB không đổi; nhưng hiện banner "✅ Import hoàn tất: 0/1" (xem BUG-08)	
FR16-DT-17	UI+API	Pass	Tên rỗng bị từ chối ("Hàng 2: Thiếu tên sản phẩm"), DB không đổi	
FR16-DT-18	UI+API	**Fail**	UI từ chối (đã `trim`), nhưng API nhận `name=" "` và **thêm** sản phẩm	BUG-06
FR16-DT-19	UI+API	**Fail**	Giá `-1` được thêm	BUG-02
FR16-DT-20	UI+API	**Fail**	Giá `0` được thêm	BUG-02
FR16-DT-21	UI+API	**Fail**	Giá `abc` được thêm	BUG-02
FR16-DT-22	UI+API	**Fail**	Giá rỗng được thêm (UI chuyển thành 0)	BUG-02
FR16-DT-23	UI+API	**Fail**	`category_id = 999` (không tồn tại) được thêm (diễn giải FR-15)	BUG-07
FR16-DT-24	UI+API	**Fail**	`category_id` rỗng được thêm, tự gán 1 (diễn giải FR-15)	BUG-07
FR16-DT-25	UI+API	**Fail**	3 dòng, dòng 1 lỗi: DB +3 (không rollback)	BUG-01 (và BUG-02)

TC ID	Lớp chạy	Kết quả	Actual tóm tắt	Bug
FR16-DT-26	UI+API	**Fail**	Dòng 2 lỗi: DB +3	BUG-01 (và BUG-02)
FR16-DT-27	UI+API	**Fail**	Dòng 3 lỗi: DB +3	BUG-01 (và BUG-02)
FR16-DT-28	UI+API	**Fail**	2/5 dòng lỗi: DB +5	BUG-01 (và BUG-02)
FR16-DT-29	UI+API	**Fail**	Cả 3 dòng lỗi: DB +3	BUG-01 (và BUG-02)
FR16-DT-30	UI+API	Pass	5 dòng hợp lệ → DB +5	
FR16-DT-31	UI	Pass	Báo cáo thành công nêu "3/3 sản phẩm được thêm"	
FR16-DT-32	UI	**Fail**	3 dòng, dòng 2 thiếu tên: **2/3 được thêm** (dòng 1, 3 vẫn vào DB), banner xanh " ✅ Import hoàn tất" + "Hàng 3: Thiếu tên sản phẩm"; không nêu số dòng lỗi và không nói import bị hủy (ảnh `ui_partial_import_green_banner.jpg`)	BUG-01, BUG-08
FR16-DT-33	API	**Fail**	Có dòng lỗi vẫn trả HTTP 200 "Import hoàn tất", DB +3	BUG-01, BUG-08
FR16-DT-34	API	Pass	Không token → 401	
FR16-DT-35	API	**Fail**	**Token User thường** import được sản phẩm (HTTP 200, DB +1)	BUG-09
FR16-DT-36	API	Pass	Thiếu `products` → 400 "Không có dữ liệu để import"	
FR16-DT-37	API	Pass	`products: []` → 400	
FR16-DT-38	API	Pass	`products: "abc"` → 400	
FR16-DT-39	API	**Fail**	`products: [null]` → HTTP **500**, trả trang HTML lỗi chứa stack trace và đường dẫn tuyệt đối tới `server.js:214`; server vẫn sống	BUG-10
FR16-DT-40	UI	Pass	Nút "Import 0 sản phẩm" bị vô hiệu khi chưa chọn file	
FR16-DT-41	UI	Pass	Xem trước hiển thị đúng số dòng và 5 tên cột	
FR16-DT-42	UI	Pass	File mẫu có header đúng, import được (DB +1)	
FR16-DT-43	UI	**Fail**	Nháy kép không đóng: vẫn import, tên lưu `"FR16-Áo` (cắt tại dấu phẩy)	BUG-03

BVA

TC ID	Lớp chạy	Kết quả	Actual tóm tắt	Bug
FR16-BV-01	UI+API	Pass	1 dòng → DB +1	
FR16-BV-02	UI+API	Pass	2 dòng → DB +2	
FR16-BV-03	UI+API	Pass	100 dòng → DB +100	
FR16-BV-04	API	**Fail**	1000 dòng (payload ~131 KB) → HTTP **413** (trang HTML), DB +0: vượt giới hạn body 100 KB mặc định; UI sẽ chỉ hiện "Request failed with status code 413" (suy ra từ `App.jsx:412-414`)	BUG-11
FR16-BV-05	UI	**Fail**	Dòng 4 trường vẫn import (DB +1, `category_id` tự gán 1)	BUG-05
FR16-BV-06	UI	**Fail**	Dòng 6 trường vẫn import, trường thừa bị bỏ qua (DB +1)	BUG-05
FR16-BV-07	UI+API	Pass	Giá `1` chấp nhận	
FR16-BV-08	UI+API	Pass	Giá `0.01` chấp nhận	
FR16-BV-09	API	Pass	Giá `2147483647` lưu đúng	
FR16-BV-10	API	Pass	Giá `2147483648` lưu đúng	
FR16-BV-11	API	Pass	Giá 2^{63}: không lỗi, lưu dạng số thực (ghi nhận)	
FR16-BV-12	UI+API	Pass	Tên 1 ký tự chấp nhận	
FR16-BV-13	UI+API	Pass	Tên 255 ký tự chấp nhận	
FR16-BV-14	UI+API	**Fail**	Tên 256 ký tự được chấp nhận (diễn giải FR-15)	BUG-07
FR16-BV-15	UI+API	**Fail**	1 dòng lỗi (giá −1): DB +1	BUG-01, BUG-02
FR16-BV-16	UI+API	**Fail**	2 dòng, dòng 2 lỗi: DB +2	BUG-01, BUG-02
FR16-BV-17	UI+API	**Fail**	100 dòng, dòng 100 lỗi: DB +100	BUG-01, BUG-02
FR16-BV-18	API	**Fail**	1000 dòng gọn, dòng 1000 lỗi: DB +1000 (không rollback)	BUG-01, BUG-02
FR16-BV-19	UI+API	**Fail**	Số dòng báo cáo **đúng** ("Hàng 2: Thiếu tên sản phẩm") nhưng 2/3 dòng vẫn được thêm	BUG-01

2. Quan sát thêm (không tính riêng thành bug)

- Số dòng lỗi trong báo cáo dùng `index + 2` (tính cả header) → đúng với số dòng trong file.
- Bảng xem trước hiển thị dữ liệu bằng React (không dùng `innerHTML`), không lộ XSS ở màn import (kiểm tra bằng đọc code, chưa chạy payload XSS).

- Sản phẩm có tên/giá hỏng do BUG-03 sẽ hiện trong danh sách sản phẩm; thuộc phạm vi FR-15 nếu xem xét hiển thị.
- Import cùng một file hai lần tạo bản ghi trùng (spec không nêu), không test thêm.

3. Test khám phá thêm sau khi chạy (`added-after-run`)

Chạy trên UI với file thật (`evidence/ui_exploratory.json`). Không có bug mới; các hiện tượng thuộc BUG-01/05/08. | ID | Kịch bản | Kết quả | |---|---|---| | X-01 | File UTF-8 có BOM ở đầu | Xử lý đúng, import 1/1 | | X-02 | Dòng trống nằm giữa hai dòng dữ liệu | Dòng trống bị tính là dòng lỗi "Thiếu tên sản phẩm"; 2/3 dòng được thêm (không rollback) | | X-03 | File phân cách bằng dấu chấm phẩy (kiểu Excel tiếng Việt) | Không nhận diện được cột; "0/1 ... Hàng 2: Thiếu tên sản phẩm" (banner xanh), thông báo không giải thích nguyên nhân | | X-04 | Giá trị có khoảng trắng hai đầu | Được `trim`, lưu đúng |

4. Thống kê FR-16

Hạng mục	Số lượng
Test case thiết kế	**62** (43 Domain Testing + 19 BVA)
Đã thực thi	62
Pass	28 (DT: 18, BV: 10)
Fail	34 (DT: 25, BV: 9)
Chưa thực thi	0
Bug phân biệt (nguyên nhân gốc)	**11** (BUG-01 … BUG-11, xem `06_bugs.md`)
Test khám phá thêm	4 (X-01..X-04), không có bug mới

Nhiều test cùng Fail do một nguyên nhân gốc (ví dụ các test rollback đều do BUG-01), nên số bug nhỏ hơn số test Fail.

6.4 Mobile FR-08/09 Thanh toán & mã giảm giá trên Mobile (Pool D)

- **Ngày chạy:** 2026-10-16. **Môi trường:** Windows 11, Node v22.20.0, Backend `localhost:3000`; ứng dụng Mobile chạy bằng **Expo Web** (`react-native-web`, `http://localhost:8081`) trong trình duyệt tích hợp Claude desktop; dữ liệu seed gốc.

- **Hạn chế môi trường (quan trọng):**

    - Không có thiết bị thật/emulator Android hay iOS; kết quả UI từ bản web chạy **cùng mã nguồn** `App.js`, nhưng giao diện RN-web có thể khác máy thật (font, locale định dạng số).
    - `API_URL` trong `App.js` cứng là `http://192.168.10.13:3000/api` (không khớp IP máy test 192.168.1.225) nên **đổi tạm** sang `http://localhost:3000/api` để chạy; đã `git checkout` khôi phục sau khi test (không có thay đổi nào được commit cho `frontend-mobile`). Ba gói web (`react-dom`, `react-native-web`, `@expo/metro-runtime`) cài bằng `npm install --no-save` nên `package.json` không đổi.
    - `Alert.alert` không hiện trên web: thông báo dạng Alert được suy ra gián tiếp (chuyển màn hình, trạng thái giỏ/đơn).

- **Cách chạy:**

    - **API (47 kiểm tra):** `evidence/run_api_tests.js` — gọi HTTP thật; số tiền kỳ vọng tính bằng công thức SRS (không lấy số hệ thống trả); DB chỉ dùng để chuẩn bị/dọn dữ liệu. Kết quả thô: `evidence/api_results.json`.
    - **UI:** thao tác trên màn hình Mobile (gõ mã, bấm "Áp dụng", "Xác Nhận Thanh Toán"), bọc `fetch` để ghi lại body request, đọc số liệu đơn từ DB sau khi xác nhận. Kết quả: `evidence/ui_results.json`; ảnh: `evidence/mobile_checkout_save10_negative_discount.jpg`.
- **Quy ước:** kết quả tổng là **Fail** nếu bất kỳ lớp đã chạy (UI hoặc API) lệch spec.
- **Chạy lại có chủ ý:** BV-11 lần đầu báo Fail do script của tôi tạo `expired_at` bằng giờ UTC không có "Z" trong khi server hiểu là giờ địa phương (UTC+7); đã sửa để dùng giờ địa phương và chạy lại. Sau lần chạy API đầu, lần chạy UI đầu tiên của luồng giỏ nhiều món còn sót một sản phẩm cũ trong giỏ (script xóa giỏ sai) nên đã chạy lại luồng 2 món với giỏ sạch (BV-22).

1. Kết quả theo test case

Domain Testing

TC ID	Lớp chạy	Kết quả	Actual tóm tắt	Bug
MFR-DT-01	UI	Pass	Khách bấm "Tiến hành thanh toán" → mở màn hình đăng nhập	
MFR-DT-02	API	Pass	`POST /api/checkout` không token → 401	
MFR-DT-03	UI	Pass	Màn thanh toán liệt kê "FRM-400k x 1 — 400,000 ₫"	
MFR-DT-04	UI	Pass	Giỏ 3 SP: liệt kê đủ 3 dòng với thành tiền	
MFR-DT-05	UI	Pass	Ô tổng tiền `readOnly`	
MFR-DT-06	UI	Pass	Giỏ rỗng: "Giỏ hàng của bạn đang trống", không có nút thanh toán	
MFR-DT-07	API	**Fail**	`total_amount = 1` kèm `items` 30,000,000 ₫: HTTP 200, đơn lưu tổng **1**	BUG-03
MFR-DT-08	UI	Pass	Thanh toán không mã: "Thanh toán thành công!", giỏ về 0, đơn `pending` tổng 300,000 ₫ khớp	
MFR-DT-09	UI+API	**Fail**	`SAVE10` @400,000: `discount_amount = -3,600,000`, `final_amount = 4,000,000`; UI hiện "Tiết kiệm: -3,600,000 ₫", "Tổng thanh toán: 4,000,000 ₫" (ảnh `mobile_checkout_save10_negative_discount.jpg`)	BUG-01
MFR-DT-10	UI+API	Pass	`BIGBUY` @600,000: 50,000 / 550,000	
MFR-DT-11	UI+API	Pass	`VIP100` @400,000: 100,000 / 300,000	
MFR-DT-12	UI+API	Pass	`NOPE` bị từ chối (404, thông báo hiển thị)	

TC ID	Lớp chạy	Kết quả	Actual tóm tắt	Bug
MFR-DT-13	UI+API	Pass	Mã `is_active = 0` bị từ chối	
MFR-DT-14	UI	Pass	Mã rỗng: bấm "Áp dụng" không gửi request nào	
MFR-DT-15	UI	Pass	`save10` được chấp nhận (UI đổi sang chữ hoa) — nhưng tính tiền vẫn sai do BUG-01	
MFR-DT-16	UI	Pass	`SAVE10` được chấp nhận (UI cắt khoảng trắng)	
MFR-DT-17	API	Pass	Chuỗi SQL bị từ chối như mã không tồn tại, không lỗi server	
MFR-DT-18	UI+API	Pass	`EXPIRED` @400,000: "Mã giảm giá đã hết hạn"	
MFR-DT-19	API	Pass	`EXPIRED` @50,000: từ chối nhưng báo "chưa đủ giá trị tối thiểu" (không báo hết hạn; thứ tự không quy định)	
MFR-DT-20	UI+API	Pass	`SAVE10` @200,000: từ chối vì ngưỡng 300,000	
MFR-DT-21	UI+API	Pass	`BIGBUY` @400,000: từ chối vì ngưỡng 500,000	
MFR-DT-22	API	**Fail**	`apply-coupon` **không token**: HTTP 200 áp dụng thành công (C4 yêu cầu đăng nhập)	BUG-04
MFR-DT-23	UI+API	Pass	`SAVE10` lần 2: "Bạn đã sử dụng mã này 1 lần (đã đạt giới hạn)"	
MFR-DT-24	API	**Fail**	Bỏ `user_id` khỏi request: HTTP 200, qua mặt kiểm tra lượt dùng (C5)	BUG-04
MFR-DT-25	API	**Fail**	`SAVE10` @333,333: `discount_amount = -2,999,997`	BUG-01
MFR-DT-26	API	**Fail**	Mã `fixed` 1,000,000 @100,000: `final_amount = -900,000`	BUG-05
MFR-DT-27	UI	**Fail**	Ô "Tổng tiền thanh toán (VND)" hiện `400000` không có `đ`, không phân cách hàng nghìn (FR-21); khi áp `SAVE10` các số "Tiết kiệm/Thành tiền" sai (BUG-01)	BUG-08, BUG-01
MFR-DT-28	UI	Pass	Sửa ô mã sau khi áp: kết quả cũ biến mất, "Tổng thanh toán" về 400,000 đ	
MFR-DT-29	UI	Pass	Mã sai rồi mã đúng: lỗi cũ biến mất, hiện kết quả mới	
MFR-DT-30	UI	**Fail**	Áp `SAVE10` (tổng 400,000) rồi xác nhận: request `total_amount = 4,000,000`, đơn #75 lưu **4,000,000** (đúng ra 360,000); giỏ rỗng, `coupon_usage` +1	BUG-01, BUG-03
MFR-DT-31	UI	**Fail**	Giỏ 3 SP hiển thị đủ 3 nhưng request `items` chỉ có 2 (mất sản phẩm cuối)	BUG-07
MFR-DT-32	API	**Fail**	`checkout` thiếu `total_amount`: HTTP 200, tạo đơn rác	BUG-03
MFR-DT-33	API	**Fail**	`total_amount = -100`: HTTP 200, tạo đơn	BUG-03
MFR-DT-34	API	**Fail**	`total_amount = "abc"`: HTTP 200, tạo đơn	BUG-03

TC ID	Lớp chạy	Kết quả	Actual tóm tắt	Bug
MFR-DT-35	API	Pass	`coupon-usage` không token → 401	
MFR-DT-36	API	**Fail**	`coupon_id = 99999` (không tồn tại): HTTP 200, ghi bản ghi `coupon_usage`	BUG-06
MFR-DT-37	API	Pass	Thiếu `code` → 400	
MFR-DT-38	API	Pass	Thiếu `total_amount` → 400	
MFR-DT-39	API	Pass	`total_amount` âm → 400	
MFR-DT-40	API	Pass	`total_amount = "abc"` → 400	

BVA

TC ID	Lớp chạy	Kết quả	Actual tóm tắt	Bug
MFR-BV-01	UI+API	Pass	`SAVE10` @299,999: từ chối	
MFR-BV-02	UI+API	**Fail**	`SAVE10` @**300,000** (= ngưỡng): bị từ chối "chưa đủ giá trị tối thiểu 300.000 ₫"	BUG-02
MFR-BV-03	API	**Fail**	`SAVE10` @300,001: `discount_amount = -2,700,009`	BUG-01
MFR-BV-04	API	Pass	`BIGBUY` @499,999: từ chối	
MFR-BV-05	API	**Fail**	`BIGBUY` @**500,000**: bị từ chối	BUG-02
MFR-BV-06	API	Pass	`BIGBUY` @500,001: 50,000 / 450,001	
MFR-BV-07	API	Pass	`expired_at` hôm qua: hết hạn	
MFR-BV-08	API	Pass	`expired_at` hôm nay (kiểu ngày): hết hạn	
MFR-BV-09	API	Pass	`expired_at` ngày mai: chấp nhận	
MFR-BV-10	API	Pass	now − 1 phút: hết hạn	
MFR-BV-11	API	Pass	now + 1 phút (giờ địa phương): chấp nhận	
MFR-BV-12	API	Pass	`VIP100` đã dùng 0 lần: chấp nhận	
MFR-BV-13	API	Pass	`VIP100` đã dùng 1 lần (`max−1`): chấp nhận	
MFR-BV-14	API	Pass	`VIP100` đã dùng 2 lần (`= max`): từ chối	
MFR-BV-15	API	**Fail**	Mã `fixed` 100,000 @99,999: `final_amount = -1`	BUG-05
MFR-BV-16	API	Pass	@100,000: `final = 0`	
MFR-BV-17	API	Pass	@100,001: `final = 1`	
MFR-BV-18	API	**Fail**	Mã `percent` 100% @1,000: `discount = -99,000`, `final = 100,000`	BUG-01
MFR-BV-19	API	**Fail**	`percent` 10% @9: `discount = -81`	BUG-01
MFR-BV-20	API	**Fail**	`percent` 10% @10: `discount = -90`, `final = 100`	BUG-01
MFR-BV-21	UI	Pass	Giỏ 1 SP: request `items` có 1 SP	
MFR-BV-22	UI	**Fail**	Giỏ đúng 2 SP (FRM-100k, FRM-200k): request `items` chỉ có FRM-100k	BUG-07

TC ID	Lớp chạy	Kết quả	Actual tóm tắt	Bug
MFR-BV-23	API	Pass	Mã dài 1000 ký tự: 404, không lỗi server	

2. Quan sát thêm (không tính vào số bug)

- Đơn tạo từ Mobile có `shipping_address = NULL` (Mobile không gửi địa chỉ); SRS FR-08 không yêu cầu địa chỉ nên chỉ ghi nhận (Web Admin hiển thị "Chưa cập nhật").
- Thông báo kiểm tra theo thứ tự "ngưỡng" trước "hết hạn": mã hết hạn kèm đơn nhỏ báo "chưa đủ giá trị tối thiểu" (DT-19); spec không quy định thứ tự.
- Ngoài phạm vi (thuộc feature khác): màn hình đăng nhập Mobile ghi nhãn "Username" nhưng placeholder "Email" và nút "Sign In" bằng tiếng Anh (FR-21/FR-02); ô số lượng trong giỏ cộng thêm 1 khi gõ (`App.js:615-623`, FR-20); nhãn "Tổng tạm tính" (FR-07/FR-20).
- Logic server của FR-08 và FR-09 cũng nằm ở Web của thành viên khác: bug BUG-01..06 là lỗi backend dùng chung, báo ở đây kèm bằng chứng từ Mobile.

3. Thống kê Mobile FR-08/09

Hạng mục	Số lượng
Test case thiết kế	**63** (40 Domain Testing + 23 BVA)
Đã thực thi	63
Pass	42 (DT: 27, BV: 15)
Fail	21 (DT: 13, BV: 8)
Chưa thực thi	0
Bug phân biệt (nguyên nhân gốc)	**8** (BUG-01 … BUG-08, xem `06_bugs.md`)

Một số test cùng Fail do một nguyên nhân gốc (ví dụ mọi kết quả giảm theo % đều do BUG-01), nên số bug nhỏ hơn số test Fail.

7. AI gap analysis

7.1 FR-03 Quên & đặt lại mật khẩu (Pool A)

Ngữ cảnh: AI ở đây là Claude Code (Sonnet 5.5) chạy trong phiên làm việc này, được dẫn qua từng bước của skill `domain-testing-bva` (xem `audit/AI_AUDIT_LOG.md`). "Bỏ sót" nghĩa là: thứ có trong bộ test/bug **cuối cùng** nhưng **không** có trong bản thiết kế đầu tiên của AI ở Bước 1–3, hoặc là chỗ AI làm sai và phải sửa.

Nhóm nguyên nhân: `Prompt` (đầu vào/yêu cầu của mình chưa đủ) | `Giới hạn công cụ` | `Độ phức tạp feature`.

#	Thứ AI bỏ sót / làm sai	Phát hiện bằng cách nào	Nhóm nguyên nhân	Giải thích	Cách khắc phục
G1	**Test theo hình dạng request** (thiếu trường, `null`, kiểu object) cho `forgot-password` / `reset-password`	Khi chạy thật, nhận ra thiết kế chỉ có giá trị "hợp lệ/không hợp lệ" của từng ô, không có request lệch cấu trúc → thêm X-01..X-04 (không ra bug mới)	Prompt	Prompt Bước 2 yêu cầu chia lớp "theo từng input" nên AI chỉ nghĩ tới giá trị chuỗi người dùng gõ, không nghĩ tới client không phải trình duyệt	Thêm vào skill: sau khi chia lớp theo giá trị, luôn thêm nhóm "request shape" (thiếu/null/sai kiểu) cho mọi API
G2	**Không giới hạn số lần đoán OTP** (300 lần đoán sai liên tiếp đều 400, không khóa/chậm lại) — kết hợp OTP chỉ có 4 chữ số (9000 giá trị) thì đoán ra trong vài giây	Nghĩ lại về SEC-07 ("đủ entropy") sau khi thấy OTP 4 số; chạy X-05	Độ phức tạp feature	Đây là thuộc tính qua nhiều request, không phải miền của một input; phân hoạch/BVA tập trung vào một request nên khó nảy ra. AI chỉ dùng phần "tối thiểu 6 chữ số" của SEC-07 mà bỏ phần "đủ entropy"	Bổ sung bước "thuộc tính phi chức năng liên quan feature (SEC-xx)" vào skill; mục này thành quan sát chứ không tính bug vì SRS không yêu cầu rate limit cụ thể
G3	**Chuẩn hóa email** (chữ hoa/thường, khoảng trắng đầu/cuối)	Nghĩ lại về lớp email; chạy X-06: `TEST@ESHOP.COM` → 404 (phân biệt hoa thường)	Prompt	SRS im lặng; AI mặc định "spec không nói thì không test" nên bỏ cả lớp. Với email, hoa/thường là biên thực tế của người dùng	Trong skill: khi spec im lặng về một lớp phổ biến, vẫn thiết kế test và ghi expected là "quan sát", không phải "bug"
G4	**Lớp mật khẩu có khoảng trắng**	Ở Bước 1 AI đã thấy regex đòi `\s` nhưng không thêm lớp tương ứng; phải chạy `New pass1` ngoài kế hoạch mới xác nhận UI chỉ nhận mật khẩu có khoảng trắng	Prompt	Mình dặn "expected lấy từ spec, code chỉ gợi ý" nên AI không biến gợi ý trong code thành lớp test	Skill: gợi ý từ code ("Spec vs Code") phải được chuyển thành lớp test bổ sung (kiểm thử hộp đen dựa trên giả thuyết)
G5	**Expected của DT-03 quá cụ thể** ("báo sai định dạng") trong khi API chỉ trả "User not found"	Khi đối chiếu kết quả, AI lúc đầu chấm Pass dù thông báo không phải về định dạng	Giới hạn công cụ	AI viết expected từ suy luận chứ không dựa vào chuỗi cụ thể nêu trong SRS; khi chấm lại dễ "dễ dãi" để khớp	Chỉ ghi expected ở mức hành vi mà SRS nêu (từ chối, không cấp OTP) và ghi riêng "chất lượng thông báo" thành quan sát
G6	**Gộp nhiều nguyên nhân vào cùng nhóm test** — 14 test BV (BV-10..BV-23) cùng Fail vì **một** lỗi (regex UI) nên số test Fail (40) không phản ánh số lỗi (10)	Tổng hợp kết quả	Độ phức tạp feature	Hai lớp ràng buộc (UI + API) cùng áp lên một giá trị; một lỗi ở lớp UI làm "hợp lệ" thành Fail ở hàng loạt test	Báo cáo luôn có cột "Bug" để nhóm theo nguyên nhân gốc; không dùng số test Fail làm số bug
G7	**Lỗi trong chính test script của AI**: (a) DT-06 báo Fail giả do trạng thái chung (user C của test hết hạn có `reset_token`); (b) DT-15 lần đầu chạy chỉ sau ~12 giây đã kết luận	Đọc kết quả bất thường, đối chiếu thời gian trong log	Giới hạn công cụ	AI không có cảm giác về thời gian thực và dễ bỏ qua tương tác giữa các test dùng chung DB	Skill: mỗi test dài (có chờ) dùng dữ liệu riêng; test phụ thuộc thời gian phải ghi thời điểm cấp và thời điểm dùng rồi tính số phút trước khi kết luận

Tóm tắt nguyên nhân

- **Prompt (3 mục: G1, G3, G4):** chủ yếu do cách mình đặt yêu cầu ở Bước 2 — "theo từng input" và "spec là oracle" — khiến AI bỏ qua các lớp ngoài spec hoặc ngoài giá trị người gõ.
- **Giới hạn công cụ (G5, G7):** AI dễ "dễ dãi" khi chấm kết quả và không tự theo dõi thời gian/trạng thái dùng chung.
- **Độ phức tạp feature (G2, G6):** thuộc tính xuyên nhiều request và nhiều lớp ràng buộc không nằm gọn trong một bảng lớp tương đương.

Điều AI làm đúng (để đối chiếu)

- Bắt đúng ở Bước 1 các giả thuyết lớn: OTP 4 số, regex mật khẩu sai, thiếu trường xác nhận, thiếu Step Indicator, thiếu nút quay lại đăng nhập, `type="text"` cho email, không có thời hạn OTP. Tất cả được xác nhận khi chạy.
- Dự đoán sai/khẳng định thừa: H13 và H15 ("cần thử") hóa ra không có lỗi (X-01..X-04).

7.2 FR-10 Máy trạng thái đơn hàng (Pool B)

Ngữ cảnh: AI là Claude Code (Sonnet 5.5) trong phiên này, dẫn qua từng bước của skill `domain-testing-bva` (xem `audit/AI_AUDIT_LOG.md`). "Bỏ sót" = có trong bộ test/bug cuối nhưng không có trong bản thiết kế đầu (Bước 1–3), hoặc AI làm sai và phải sửa. Đây là phiên bản đã áp dụng các bài học của FR-03 (request shape, quyền, thuộc tính xuyên request), nên một số lỗ hổng cũ không lặp lại.

Nhóm nguyên nhân: `Prompt` | `Giới hạn công cụ` | `Độ phức tạp feature`.

#	Thứ AI bỏ sót / làm sai	Phát hiện bằng cách nào	Nhóm nguyên nhân	Giải thích	Cách khắc phục
G1	**Race condition** khi hai thao tác xung đột chạy đồng thời (Admin xác nhận × User hủy): đơn đã hủy bị "hồi sinh" thành `confirmed`	Sau khi chạy xong ma trận, nghĩ lại về tính bất biến "`canceled` là trạng thái cuối" và chạy X-01 (60 lần song song); 1/60 vi phạm	Độ phức tạp feature	Ma trận trạng thái × đích mô tả từng chuyển **tuần tự**. Lỗi chỉ lộ khi hai request xen kẽ, và xác suất thấp nên cũng không thấy ở test đơn lẻ	Thêm vào skill: với feature có trạng thái cuối/bất biến, thêm test đồng thời (chạy N lần) cho các cặp thao tác xung đột
G2	**Khác biệt giữa UI và backend ở cùng một quy tắc** chỉ được phát hiện vì chạy riêng từng lớp: UI Web hiện nút hủy cho `shipping` (BUG-04) trong khi UI Admin ẩn đúng	Chạy thật UI từng màn hình	Prompt	Prompt Bước 2 yêu cầu nêu "Lớp chạy" cho mỗi test nhưng chưa yêu cầu **lặp quy tắc ở mọi giao diện có thể thao tác** (Admin, Web, Mobile). AI chỉ chắc chắn bao gồm cả hai nhờ đọc code Profile.jsx ở Bước 1	Skill: khi một quy tắc có nhiều điểm thao tác (nhiều UI + API), lập bảng "điểm thao tác × trạng thái" trước khi viết test
G3	**Phát hiện ngoài phạm vi** (FR-13 doanh thu nhân đôi, FR-11 xem đơn không cần token, FR-18 `innerHTML`)	Nhìn thấy khi chụp màn hình Dashboard và gọi `GET /api/orders/1` để dọn dữ liệu	Prompt	Bộ test chỉ thiết kế cho FR-10 nên không cố ý quan sát các feature lân cận; những thứ này lộ ra ngẫu nhiên. Có thể còn sót nhiều thứ tương tự	Skill: giữ mục "Quan sát ngoài phạm vi" và dành vài phút khám phá trên cùng màn hình; chuyển cho thành viên phụ trách feature đó thay vì tính vào bug của mình
G4	**Diễn giải mơ hồ** "chỉ Admin mới có thể thao tác" khi `shipping`: AI chọn nghĩa chặt (Admin không được hủy)	Phân tích ở Bước 1; backend cũng từ chối `shipping → canceled` nên kết quả Pass không phân biệt được hai nghĩa	Giới hạn công cụ	AI không thể tự quyết ý định của đề; chọn một nghĩa rồi đối chiếu code dễ vô tình xác nhận nghĩa đó	Ghi rõ mơ hồ và đặt câu hỏi cho giảng viên/TA; DT-15 đã gắn nhãn "diễn giải chặt"

#	Thứ AI bỏ sót / làm sai	Phát hiện bằng cách nào	Nhóm nguyên nhân	Giải thích	Cách khắc phục
G5	**Lỗi trong script test của AI**: BV-01..08 báo Fail giả (401) vì hàm trợ giúp quên gắn token Admin	Thấy 8 test cùng lỗi 401 ngay ở lần chạy đầu	Giới hạn công cụ	AI viết hàm riêng cho nhóm test mới và sao chép thiếu tham số xác thực; không có bước tự kiểm "request hợp lệ trước, rồi mới thử sai"	Skill: chạy một request hợp lệ làm "đối chứng" cho mỗi nhóm test trước khi tin kết quả Fail; nhiều test cùng một mã lỗi lạ (401) là dấu hiệu lỗi script
G6	**Chưa test đường đi của Mobile** (Mobile FR-10 thuộc thành viên khác) và chưa test các hành động Admin khác (Admin hủy từ UI Admin tới trạng thái cuối) ngoài các nút có sẵn	Rà phạm vi cuối bước	Prompt	Phạm vi được cắt từ đầu; Admin UI chỉ được kiểm bằng việc đọc các nút chứ không bấm từng nút (đã bấm nút "Xác nhận" ở DT-54)	Có thể bấm thêm các nút còn lại nếu còn thời gian; ghi rõ trong README

Tóm tắt nguyên nhân

- **Độ phức tạp feature (G1):** lỗi nằm ở tương tác giữa các request, không nằm trong một ô của ma trận.
- **Prompt (G2, G3, G6):** cách đặt yêu cầu của mình chưa buộc AI duyệt hết các điểm thao tác và các màn hình lân cận.
- **Giới hạn công cụ (G4, G5):** AI không tự xác định ý đề khi spec mơ hồ, và tin kết quả script chưa đối chứng.

Điều AI làm đúng (để đối chiếu)

- Ở Bước 1, AI đoán đúng 5/5 điểm lệch chính (H1 `canceled → delivered`, H2 nút Admin UI, H3 User hủy `shipping`, H4 nút Web hủy `shipping`, H5 thiếu kiểm tra role) và đều được xác nhận khi chạy.
- Các giả thuyết "có vẻ đúng" (H6, H8–H12: chủ đơn, trạng thái cuối `delivered`, giá trị `status` lạ, id không tồn tại) đều đúng; toàn bộ biên ID/chuỗi cho kết quả như dự đoán, và trong 25 ô ma trận chỉ có đúng 1 ô lệch (`canceled → delivered`).
- Ma trận 5×5 cho thấy giá trị rõ nhất của Domain Testing với state machine: mỗi bug gắn với một ô cụ thể (`canceled → delivered`) hay một cặp (vai trò × trạng thái).

7.3 FR-16 Import sản phẩm từ CSV (Pool C)

Ngữ cảnh: AI là Claude Code (Sonnet 5.5) trong phiên này, dẫn qua từng bước của skill `domain-testing-bva` (xem `audit/AI_AUDIT_LOG.md`). "Bỏ sót" = có trong bộ test/bug cuối nhưng không có trong bản thiết kế đầu (Bước 1–3), hoặc AI làm sai và phải sửa. Đã áp dụng các bài học của FR-03 và FR-10 (request shape, quyền, UI/API, race), nên một số lỗ hổng cũ không lặp lại.

Nhóm nguyên nhân: `Prompt` | `Giới hạn công cụ` | `Độ phức tạp feature`.

#	Thứ AI bỏ sót / làm sai	Phát hiện bằng cách nào	Nhóm nguyên nhân	Giải thích	Cách khắc phục
G1	**Biến thể file thực tế**: dấu phân cách `;` (Excel tiếng Việt), BOM, dòng trống giữa file, giá trị có khoảng trắng đầu/cuối	Nghĩ lại về người dùng thật sau khi chạy xong; chạy X-01..X-04	Prompt	Prompt Bước 2 gắn chặt với "RFC 4180" trong spec nên AI chỉ chia lớp theo những gì spec nêu; phần "đầu vào do công cụ khác sinh ra" (Excel, Notepad) không nằm trong spec nên bị bỏ qua. Dấu `;` đáng chú ý vì file CSV xuất từ Excel ở máy cài tiếng Việt thường dùng dấu này	Skill: với feature nhận file, thêm nhóm "file do công cụ phổ biến xuất ra" (BOM, dấu phân cách địa phương, xuống dòng, dòng trống, khoảng trắng) kể cả khi spec không nêu
G2	**Kiểm tra bảng xem trước đã cập nhật chưa** trước khi bấm Import (harness của AI): lần chạy đầu DT-02 import nhầm dữ liệu của test trước	Tên sản phẩm trả về là `FR16-1..3` trong khi file chỉ có 1 dòng khác tên	Giới hạn công cụ	`FileReader` chạy bất đồng bộ; AI dùng thời gian chờ cố định (350 ms) thay vì chờ tới khi nội dung giao diện khớp file đã chọn	Skill: với UI bất đồng bộ, chờ điều kiện cụ thể (nội dung xem trước khớp) thay vì chờ cố định; kiểm tra dữ liệu thực tế sinh ra có khớp đầu vào
G3	**Kích thước payload khi thiết kế BV-18**: dòng 1000 có mô tả dài làm tổng ~131 KB, vượt giới hạn 100 KB nên bị 413 và che mất việc kiểm tra rollback	Kết quả BV-18 "Pass" chỉ vì HTTP 413 (không có dòng nào được thêm) — nghi ngờ vì lý do không đúng	Độ phức tạp feature	Hai thuộc tính (kích thước body, rollback) tương tác; AI đã lường tới giới hạn body (BV-04) nhưng không tính độ dài dòng khi thiết kế BV-18	Skill: khi một kết quả "Pass" của test từ chối có thể đến từ một lý do khác, kiểm tra **mã lỗi/nội dung phản hồi** có đúng lý do mong đợi không
G4	**Trùng lặp**: import cùng một file hai lần, hoặc có hai dòng trùng tên trong một file	Rà phạm vi cuối bước	Prompt	Spec không nêu và AI áp dụng quy tắc "spec không nói thì không thiết kế"	Ghi nhận là chưa test; có thể bổ sung nếu giảng viên coi trùng lặp là lỗi
G5	**Giá có dấu phân cách hàng nghìn** (`"100,000"` hoặc `100.000`) — định dạng quen thuộc với người dùng Việt	Rà phạm vi cuối bước	Prompt	Không có trong spec; trùng với lỗi parser nháy kép (BUG-03) nên khó tách riêng	Ghi nhận chưa test; liên quan BUG-02 và BUG-03
G6	**Kết quả Pass không đầy đủ**: DT-16 (không có header) "Pass" theo tiêu chí DB không đổi, nhưng giao diện hiện banner xanh "Import hoàn tất"	Đọc nội dung banner của từng test thay vì chỉ đọc số dòng được thêm	Giới hạn công cụ	Tiêu chí "DB không đổi" của AI chỉ đo kết quả dữ liệu, không đo thông điệp cho người dùng	Đã ghi thông điệp sai thành BUG-08; skill: với test từ chối, kiểm tra cả dữ liệu lẫn thông báo

Tóm tắt nguyên nhân

- **Prompt (G1, G4, G5):** AI bám sát spec và bỏ qua các tình huống thực tế quanh nó.
- **Giới hạn công cụ (G2, G6):** kiểm thử UI bất đồng bộ và tiêu chí chấm quá hẹp.
- **Độ phức tạp feature (G3):** tương tác giữa giới hạn kích thước request và tính nguyên tử.

Điều AI làm đúng (để đối chiếu)

- Ở Bước 1, các giả thuyết lớn đều đúng: H1 không rollback, H2 không validate giá, H3 `split(",")` hỏng nháy kép, H4 không kiểm đuôi file, H5 không kiểm header, H7 thiếu kiểm tra role, H8 API nhận tên toàn khoảng

trắng (khác UI).
- Dự đoán trước được giới hạn body 100 KB của `body-parser` (BV-04) từ hiểu biết về công cụ, và nó được xác nhận (HTTP 413).
- Các giả thuyết "có vẻ đúng" (H10 file rỗng/chỉ header, H11 số dòng báo cáo `index+2`, H12 file mẫu) đều đúng.

7.4 Mobile FR-08/09 Thanh toán & mã giảm giá trên Mobile (Pool D)

Ngữ cảnh: AI là Claude Code (Sonnet 5.5) trong phiên này, dẫn qua từng bước của skill `domain-testing-bva` (xem `audit/AI_AUDIT_LOG.md`). "Bỏ sót" = có trong kết quả/bộ test cuối nhưng không có trong bản thiết kế đầu (Bước 1–3), hoặc AI làm sai và phải sửa. Đã áp dụng bài học của FR-03, FR-10, FR-16.

Nhóm nguyên nhân: `Prompt` | `Giới hạn công cụ` | `Độ phức tạp feature`.

#	Thứ AI bỏ sót / làm sai	Phát hiện bằng cách nào	Nhóm nguyên nhân	Giải thích	Cách khắc phục
G1	**Chưa kiểm tra có chạy được thành phần Mobile hay không trước khi thiết kế**: `API_URL` cứng là IP LAN `192.168.10.13` (không khớp máy test), thiếu gói web cho Expo (`react-dom`, `react-native-web`, `@expo/metro-runtime`)	Chỉ phát hiện lúc bắt đầu Bước 4	Giới hạn công cụ	AI thiết kế test từ code trước, rồi mới dựng môi trường; không có bước "chạy thử thành phần" ở Bước 0	Skill: Bước 0 phải ghi rõ cách chạy từng thành phần (kể cả sửa tạm cấu hình) và dò trước các điều kiện chặn (IP cứng, thiếu phụ thuộc)
G2	**Thông báo dạng `Alert.alert` không quan sát được** trên bản web nên các nhánh lỗi (thanh toán thất bại, token hết hạn) không kiểm tra trực tiếp được	Khi bấm thử trên Expo Web	Giới hạn công cụ	Môi trường test (react-native-web) khác nền tảng thật; AI giả định mọi thông báo đều đọc được từ DOM	Ghi vào báo cáo là hạn chế; cần test lại trên emulator/thiết bị thật nếu có
G3	**Các hành vi riêng của thiết bị thật**: bàn phím số (`keyboardType="numeric"`), xoay màn hình, màn hình nhỏ, chạm nhanh hai lần	Rà phạm vi cuối bước	Giới hạn công cụ	Không có thiết bị/emulator; đề tài nhấn mạnh "Mobile" nhưng môi trường chỉ cho phép web	Ghi rõ chưa test; nếu có emulator thì bổ sung test thao tác chạm nhanh (double tap "Xác Nhận Thanh Toán") và hiển thị trên màn hình nhỏ
G4	**Lỗi múi giờ trong test hạn dùng**: BV-11 lần đầu Fail giả vì AI dựng `expired_at` bằng giờ UTC không có "Z" trong khi server hiểu là giờ địa phương	Kết quả "hết hạn" cho mã còn hạn 1 phút	Giới hạn công cụ	AI không nhận ra khác biệt cách `new Date()` diễn giải chuỗi ngày giờ không có múi giờ	Skill: test phụ thuộc thời gian phải dựng thời điểm theo cùng quy ước múi giờ của hệ thống, ghi múi giờ khi kết luận
G5	**Dữ liệu sót giữa các test UI**: script xóa giỏ làm sai nên giỏ còn sản phẩm cũ; luồng "2 món" thực tế gửi 3 món	Tổng đơn (700,000 thay vì 300,000) và danh sách sản phẩm trên màn hình không khớp dự kiến	Giới hạn công cụ	AI không kiểm tra giỏ rỗng trước mỗi kịch bản và dùng chỉ số mảng thay vì tên sản phẩm	Đã sửa (dựng giỏ theo tên, kiểm tra nội dung giỏ trước khi thanh toán) và chạy lại BV-22 với giỏ sạch; skill đã có quy tắc đối chiếu dữ liệu sinh ra với đầu vào
G6	**Các tình huống chưa thiết kế**: mất kết nối khi thanh toán/áp mã, nhấn "Xác Nhận Thanh Toán" hai lần liên tiếp (đơn trùng), thay đổi giỏ sau khi đã áp mã rồi quay lại	Rà phạm vi cuối bước	Prompt	Spec không nêu; AI bám vào C1..C5 và công thức nên bỏ qua các tình huống vận hành	Ghi nhận chưa test; có thể bổ sung nếu giảng viên cho phép mô phỏng mất kết nối

#	Thứ AI bỏ sót / làm sai	Phát hiện bằng cách nào	Nhóm nguyên nhân	Giải thích	Cách khắc phục
G7	**Một nguyên nhân gốc làm hàng loạt test Fail**: công thức % sai khiến 8 test (DT-09, 25, 27, 30; BV-03, 18, 19, 20) cùng Fail; lỗi `>` làm BV-02, BV-05 Fail	Tổng hợp kết quả	Độ phức tạp feature	Hai lớp (UI và API) cùng chạy một công thức; thiết kế không tách được test "áp mã" và test "tính tiền" nên một lỗi lan ra nhiều test	Báo cáo có cột Bug nhóm theo nguyên nhân gốc (63 test → 8 bug)
G8	**Lệch giữa spec và dữ liệu seed**: SRS ghi `Admin123!`, `setup_guide.md` ghi `admin123` (đã thử đăng nhập `admin@eshop.com` / `admin123` → 401 "Invalid email or password"; chỉ `Admin123!` đăng nhập được, khớp `database.js`)	Khi đăng nhập Admin để tạo mã	Prompt	Hai tài liệu chính thức mâu thuẫn; AI chọn theo SRS (đã kiểm chứng ở `database.js`)	Ghi nhận trong báo cáo là điểm tài liệu không nhất quán

Tóm tắt nguyên nhân

- **Giới hạn công cụ (G1–G5):** môi trường test Mobile không phải thiết bị thật, kèm lỗi script của AI (múi giờ, giỏ hàng).
- **Prompt (G6, G8):** chỉ thiết kế quanh điều kiện và công thức trong spec, bỏ qua tình huống vận hành và tài liệu mâu thuẫn.
- **Độ phức tạp feature (G7):** một lỗi trong công thức lan sang nhiều test.

Điều AI làm đúng (để đối chiếu)

- Ở Bước 1 AI đoán đúng các lệch chính và đều được xác nhận khi chạy: H1 công thức % âm, H2 `>` thay `>=`, H3 `apply-coupon` không cần token/bỏ qua C5 khi thiếu `user_id`, H5 backend tin `total_amount`, H6 Mobile bỏ mất sản phẩm cuối, H11 `fixed` lớn hơn tổng ra số âm, H14 `API_URL` cứng.
- Dự đoán đúng điều kiện "ngưỡng kiểm tra trước hạn dùng" (H10) và hành vi `category` mặc định không liên quan feature này.
- Nhờ tính expected bằng công thức SRS (thay vì lấy số hệ thống trả) nên phát hiện ngay "Tiết kiệm: -3,600,000 ₫" thay vì coi đó là kết quả bình thường.

8. Bug report

Toàn bộ 36 bug được tổng hợp trong `02_BugReport/BugReport_HW02_23120231.pdf` (kèm screenshot) và đã đăng trên GitHub Issues: https://github.com/nhaajtdajt/eshop-hw02-domain-testing/issues

9. Hạn chế và trung thực

- Mobile chưa được thử trên thiết bị thật/emulator; kết quả UI Mobile đến từ Expo Web cùng mã nguồn `App.js`.
- Một số kết quả phụ thuộc diễn giải spec (Admin hủy đơn đang giao; `category_id` khi import; làm tròn khi giảm %). Các test này được gắn nhãn "diễn giải" và không coi là lỗi chắc chắn.
- Chưa test: import trùng lặp, giá có dấu phân cách hàng nghìn, mất kết nối/bấm hai lần ở thanh toán Mobile.
- Mức độ nghiêm trọng và nguyên nhân gap là đánh giá của AI, cần người kiểm thử xác nhận.

10. AI Audit Report (tóm tắt)

Báo cáo đầy đủ theo mẫu 5 mục cho từng artifact: `05_Templates_AI/[AI-02] AI Audit Report - 23120231.docx` (và `03_AI/AI_Audit_Report_23120231.md/.pdf`; nhật ký thô `audit/AI_AUDIT_LOG.md`). Tổng số artifact do AI sinh: **27** (Agent Skill và 25 sản phẩm theo từng bước của từng feature).

Kết quả đánh giá	Số lượng	Tỉ lệ
VALID (đúng, dùng nguyên)	13	48%
INVALID (sai, bị loại)	0	0%
INCOMPLETE (dùng được sau khi sửa)	14	52%

Khi nào nên / không nên dùng AI cho công việc này: nên dùng AI để liệt kê có hệ thống lớp tương đương, giá trị biên, ma trận trạng thái và giả thuyết lệch giữa spec và code, cũng như viết bản nháp script và báo cáo. Không nên tin kết quả thực thi do script của AI khi chưa có request đối chứng và chưa đối chiếu dữ liệu thật; không nên để AI tự quyết expected (phải lấy từ spec), tự đánh giá mức độ nghiêm trọng của bug, hoặc thay cho kiểm thử trên thiết bị thật. Không artifact nào bị loại hẳn, nhưng một nửa chỉ dùng được sau khi sửa; các chỗ phải sửa nằm ở khâu thực thi và ở những tình huống nằm ngoài chữ trong spec.

11. AI Critique (200–300 từ)

AI không sai ở chỗ khó, mà sai ở chỗ tin quá mức vào chính mình. Claude liệt kê lớp tương đương và giá trị biên rất nhanh, nhưng hầu hết sai sót nằm ở phần thực thi. Script test của AI nhiều lần cho kết quả giả: quên gắn token Admin nên cả nhóm BV-01..08 của FR-10 báo Fail; dùng giờ UTC trong khi server hiểu giờ địa phương (Mobile BV-11); kiểm tra hết hạn OTP chỉ sau 12 giây rồi kết luận; nạp file CSV mà không chờ FileReader nên import nhầm dữ liệu của test trước. Lần nào AI cũng tự tin báo kết quả.

AI cũng bỏ sót những thứ nằm ngoài chữ trong spec: file CSV dùng dấu chấm phẩy của Excel tiếng Việt, race condition làm đơn đã hủy bị xác nhận đè (1/60 lần), việc đoán OTP không bị giới hạn. Nguyên nhân là AI bám câu chữ của prompt và spec, không có cảm giác về thời gian, trạng thái dùng chung hay thói quen người dùng thật. Nó cũng dễ chấm Pass khi lý do không đúng (lỗi 413 che mất kiểm tra rollback).

Nguyên tắc tôi rút ra: giao cho AI phần liệt kê và tính toán, nhưng người kiểm thử giữ phần oracle. Expected phải lấy từ spec, không từ code hay kết quả hệ thống trả về, nên mới nhận ra "Tiết kiệm: -3,600,000 ₫" là lỗi thay vì chấp nhận nó. Luôn bắt AI chạy request đối chứng, đối chiếu dữ liệu sinh ra với đầu vào, và ghi rõ điều chưa test. Review phải dựa trên bằng chứng như số bản ghi trong DB hay body request, không dựa vào lời tóm tắt của AI.

12. Mandatory Disclosure

"The test analysis, Domain Testing and Boundary Value Analysis test designs, API test scripts, UI test procedures, execution reports, AI gap analyses, bug reports, the Agent Skill 'domain-testing-bva' and the submission documents were initially generated by Claude Code (Claude Sonnet 5.5). [SINH VIÊN ĐIỀN VÀ XÁC NHẬN: I reviewed and modified (sections/test cases ...), re-ran (scripts ...), added (edge cases ...); (sections ...) were written entirely by me, including the final AI Critique.] The detailed AI Audit Report is attached as Appendix A. I confirm I did not use AI to generate any artifact listed in the prohibited category."